

무선인식 (RFID) 개인정보보호에 관한 국내외 동향 조사연구

2006. 5

산 업 자 원 부
한국유통물류진흥원

제 출 문

한국유통물류진흥원장 귀하

본 보고서를 “무선인식 (RFID) 개인정보보호에 관한 국내외 동향 조사 연구 용역 사업 (사업기간 : 2006. 3. 2 ~ 2006. 5. 6)”의 최종보고서로 제출합니다.

2006. 5. 20.

주관연구기관명 : 동국대학교

책임연구원 : 이 용 한

연구원 : 김 지 영, 정 지 훈

목 차

표 목 차	viii
그 림 목 차	ix

제 1 장 RFID에서 개인정보보호의 의미 1

제1절 RFID 개인정보보호의 정의	1
1. 프라이버시의 이론적 배경	1
2. RFID에서의 개인정보보호	2
3. 기존의 시스템과 RFID 시스템의 차이점	5
제2절 RFID 개인정보보호의 중요성	6
1. RFID 개인정보보호의 위험 요인	6
가. 높은 식별성	7
나. 은밀성	9
다. 정보통합성	10
2. RFID 구성요소의 보안 취약성	10
가. 태그 데이터의 보안	10
나. 태그와 리더기의 통신 취약성	11
다. 리더기의 데이터 보안의 취약성	12
3. RFID 주요 문제점 및 대응 방향	12
가. 정보 수집 측면	12
나. 정보의 제공 측면	13
다. 타 정보와의 결합 측면	14
라. 정보의 관리 측면	15
마. RFID 위치정보 이용 측면	16
4. 주요 쟁점의 검토	16
가. 규제방식과 규제정도	16
나. RFID 식별정보에 대한 법적·정책적 문제	17

다. RFID 시스템에 대한 개념정의의 필요성	18
라. 정보주체의 권리보호	18

제 2 장 RFID 개인정보보호 관련 해외동향 20

제1절 주요국가의 정책현황 및 동향 20

1. 미국	20
가. 감사원의 보고서	21
나. 캘리포니아주	22
다. 유타주	24
라. Opt Out of ID Chips Act	25
마. REAL ID Act of 2005	25
2. 일본	26
가. 일본 경제산업성의 초안	27
나. 경제산업성과 총무성의 협동에 의한 전자태그(IC태그)에 관한 프라이버 시 보호 가이드라인	28
3. 유럽	30
가. 입법화	30
나. 가이드라인	31
다. RFID 개인정보보호 관련한 Issues	34

제2절 주요 국제기구의 개인정보보호 정책동향 35

1. OECD의 프라이버시 가이드라인	36
가. 권고안	36
나. 가이드라인	37
2. UN 가이드라인	39
3. APEC	41
4. 그 외 관련기관 및 시민단체 현황	43
가. CASPIAN	43
나. EPC Global	44
다. 미국 소비자보호 단체들의 RFID 성명서	47

제 3 장 RFID 개인정보보호 관련 국내동향	50
제1절 국내의 RFID 가이드라인	50
1. 국내의 RFID 가이드라인 비교	51
가. 시스템 정의 추가	52
나. 적용범위	52
다. 개인정보에 관련한 고지	53
라. 이용자의 권리보장	53
2. 소결	54
제2절 개인정보보호 법률 현황	54
1. 개인정보의 의미와 보호	54
2. 공공부문에서의 개인정보보호에 관한 법률	56
가. 목적	57
나. 개인정보수집제한	57
다. 개인정보파일의 보유범위 · 사전 통보	58
라. 개인정보의 안전성· 정확성 확보	58
마. 처리정보의 이용·제공의 제한	59
바. 개인정보 취급자의 의무	59
사. 열람권	60
아. 정정권	60
자. 권리구제	60
차. 문제 및 보완	61
카. 공공부문 개인정보보호 기구	61
3. 민간부문에서의 개인정보보호에 관한 법률	62
가. 목적 및 적용범위	63
나. 정보통신서비스제공자의 의무	64
다. 이용자의 권리	64
라. 개인정보분쟁조정위원회	65
마. 법률상 문제점과 보완	65
바. 민간부분 개인 정보보호 기구	66

제 4 장 RFID 개인정보 침해사례	68
제1절 RFID 개인정보보호 사례	68
제2절 개인정보보호관련 사례	80
1. RFID를 이용한 INTEROP의 방문객 관리	80
가. 서론	81
나. 개인정보보호를 위해 가이드라인 준수	81
다. TAG 무효화방법	82
라. 개인정보에 관련한 내용	82
2. 마루에쓰사의 유통물류 사례	82
가. 서론	82
나. 실험과정	83
다. 사생활 침해에 대비한 실험방법과 결과	84
3. 일본의 IC 카드 운전면허 실험사례	85
가. 서론	85
나. 사용목적	85
다. 개인정보보호 방법	86
4. 의약 유통 물류 관련 사례	86
가. 서론	86
나. Project jump Start	87
다. 개인정보보호 대책	89
5. P&G의 유통물류 사례	89
가. 서론	89
나. P&G의 프라이버시 정책	90
다. P&G의 Supply Chain RFID 적용	90
제 5 장 RFID 개인정보보호 관련 기술	94
제1절 침해기술	94
1. 도청공격	94
2. 트래픽분석	96

3. 스니핑(Sniffing), 스캐닝(Scanning), 스푸핑(Spoofing) 공격	98
4. 서비스거부(DoS, Denial of Service) 공격	101
가. 버퍼 오버플로우 공격	102
나. SYN Flooding	102
다. UDP Flooding	103
라. 눈물방울 공격	104
마. 스머프(Smurf) 공격	104
바. 바이러스	105
사. DDoS(Distributed Denial of Service)	105
아. DRDoS(Distributed Reflection Denial of Service)	105
자. ICMP Flooding	106
5. 세션 가로채기(Hijacking), 재생(Reply)공격, 중간자 공격(Man In Middle Attack)	106
6. 물리적 공격	107
7. 위조	107
제2절 보호기술	107
1. Kill Tag	108
2. Faraday Cage	111
3. Active Jamming	111
4. Hash-lock 기술	112
5. Random Hash-lock 기술	113
6. Silent Tree Walking 기술	114
7. Re-Encryption 기술	117
8. Blocker Tag	119
9. NTT Forward Secure 기술	123
10. 기타	123
가. Relabeling	123
나. 'Minimalist' cryptography	124
다. The Proxying Approach	125

제 6 장 RFID 개인정보보호 관련 전망 및 대응방안	126
제1절 RFID 개인정보보호의 전망	126
제2절 RFID 개인정보보호에 관한 대응방향	128
 [부록 1] RFID에서의 프라이버시 보호를 위한 10대 최소 가이드라인 v1.0	130
[부록 2] 정보통신부 가이드라인	134
[부록 3] KISA RFID 개인정보보호 가이드라인(안) - 2004. 11. 15	138
 참고문헌	141

표 목 차

[표 1-1] 기존시스템과 RFID 시스템과의 차이점	5
[표 1-2] 기존시스템과 RFID 시스템에서의 정보규제 차이점	5
[표 1-3] EPC의 RFID 프라이버시 위험요인 분석	6
[표 1-4] IPv4와 IPv6의 특징 비교	8
[표 2-1] 전자태그 관련 프라이버시 보호 가이드라인	28
[표 2-2] OECD 이사회의 합의안	36
[표 2-3] OECD의 권고안	37
[표 2-4] OECD 가이드라인 8원칙	37
[표 2-5] OECD 가이드라인 국제적용	38
[표 2-6] UN의 가이드라인	39
[표 2-7] APEC Privacy Principle	41
[표 2-8] CASPIAN 의 알권리 법안 제안 내용	44
[표 2-9] 제안된 프레임워크 내용	48
[표 2-10] 성명서 부록1의 내용정리	48
[표 2-11] 부록2에 수록된 KILL태그 반론 내용정리	49
[표 3-1] 제안된 프라이버시 보호 가이드라인	51
[표 3-2] 우리나라 개인정보보호 관련 법률 체계	56

그림 목 차

[그림 1-1] IPv4 구조와 IPv6 구조의 차이점	8
[그림 1-2] μ -chip 실제 크기	9
[그림 2-1] CASPIAN의 창시자 캐더린 엘브레히트과 로고	43
[그림 2-2] EPC Global	44
[그림 3-1] 공공부문에서의 개인정보보호 체계	57
[그림 3-2] 민간부문에서의 개인정보보호 체계	63
[그림 4-1] 'NetWorld+Interop 2004 Tokyo'의 IC 태그	81
[그림 4-2] 마루에쓰사의 2단계 실험 구성도	83
[그림 4-3] 2단계 실험의 IC 태그	84
[그림 4-4] 일본경찰청의 IC 태그 운전면허증	85
[그림 4-5] CVS 로고	86
[그림 4-6] Project Jump Start 구성도	88
[그림 5-1] RFID 시스템에서의 침해기술	94
[그림 5-2] 패킷 캡처 원리 및 패킷 손실	97
[그림 5-3] IP 스푸핑	99
[그림 5-4] SYN Flooding에 의한 DoS 공격	103
[그림 5-5] UDP Flooding에 의한 DoS 공격	104
[그림 5-6] Smurf에 의한 DOS 공격	106
[그림 5-7] RFID 시스템에서의 대응기술	108
[그림 5-8] Hash-Locking : Reader unlock protocol	112
[그림 5-9] Hash-Locking: Enhanced reader unlock protocol using a randomized hash	113
[그림 5-10] Tree Walk example : Each tag in this example has a 3-bit serial number	115
[그림 5-11] The forward reader to tag range is much greater than the less powerful tag to reader range	116
[그림 5-12] Silent Tree Walking: Left hand represents a non-collision; the right	

hand illustrates a collision	117
[그림 5-13] Using the rst bit to divide into public and private zones illustrated on the Tree Walk	121

제 1 장 RFID에서의 개인정보보호의 의미

정보통신의 현 주소는 차세대 기술인 ‘유비쿼터스’에 집중되고 있고, 이러한 유비쿼터스 사회를 이끄는 신기술인 RFID는 모든 산업에서 큰 주목을 얻고 있다.¹⁾ 특히 비접촉식의 빠른 처리를 이룰 수 있는 RFID는 기존의 바코드 시스템을 대체할 경우 재고관리, 유통관리 등에서 더 높은 생산성을 얻을 수 있는 장점을 가지고 있다.

RFID는 기존의 바코드와는 달리 개인정보에 관한 많은 논란을 야기하고 있다. 특히 비접촉식이기 때문에 정보 주체의 인식여부에 관계없이 수많은 다양한 정보가 수집될 수 있다는 점에서 프라이버시 침해 가능성을 제기할 수 있다.²⁾ 그리고 RFID 태그에 개인정보가 포함된 경우가 아니라도 어떤 시스템과 결합하느냐에 따라 개인정보와 연계될 수도 있는 점에서도 프라이버시의 침해 가능성이 제기될 수 있다. 또한 RFID는 RFID를 이용하는 사업자, 관리자에 의한 프라이버시 침해 외에도 RFID의 기술적 취약 부분을 겨냥한 제3자에 의한 프라이버시 침해 가능성도 존재한다.

본 장에서는 RFID에서 개인정보보호의 의미와 기존의 시스템들과의 차이점, 나아가 RFID에서의 위험요인과 주요문제점 및 대응방안, 그리고 주요 쟁점들에 대해서 언급하고자 한다.

제1절 RFID 개인정보보호의 정의

1. 프라이버시의 이론적 배경

개인정보와 관련한 수많은 논의에서는 개인정보의 개념을 대부분 프라이버시라는 개념으로 포괄하여 접근한다. 프라이버시는 대체적으로 서양에서 발전한 개념이다. 프라이버시 개념은 아주 오래전부터 시대나 역사 혹은 그 사회적인 조건에 따라 다양하게 정의되어 왔다. 초기의 프라이버시 개념은 ‘the right to be alone’³⁾의 개념

1) RFID는 기존의 바코드 시스템과는 달리 비접촉 방식으로 정보를 송수신하는 정보기술이다.

2) 한국전산원, “NCA CIO REPORT : RFID 도입과 프라이버시 보호 관련 법제 현안 분석”, 2004년 10월 15일(04-13호)

3) 1890년 미국의 사무엘 워렌(Samuel Warren)과 루이스 브랜다이즈(Luise Brendies)가 하버드 법률 회보(Harvard Law Review)에 게재한 논문(The right to Privacy)에서 프라이버시에 대한 권리를 홀로 있을 권리, 즉 간섭을 받지 않을 권리로 정의 하였다. 이는 다소 광범위하고 불명확하기 때문에 후에 또 다른 정의들이 등장하게 된다.

으로 개인적 삶의 영역에서의 최소한의 방어적 의미로 해석되었던 반면 최근에는 자신의 정보에 대한 통제권을 보장하는 정보 프라이버시권(information privacy)까지 확장된 개념으로 발전하였다. 프라이버시 권리는 대체적으로 인격권(right of personhood), 친교관계 비공개권(right of intimacy), 비밀성의 권리(right of secrecy), 자신에 대한 접근 통제권(right of limited access to the self) 및 정보 통제권(right of control over information)을 일반적으로 지칭한다. 이렇듯 초기에 비해 다양한 권리가 발생하게 되자 최근에는 개념적 접근보다는 권리의 중요성만 강조하는 경향이 보이기도 한다.⁴⁾ 또한 오늘날 개인적인 정보수집이 반강제적으로 이루어지는 경우가 빈번히 발생함에 따라, 프라이버시 보호의 개념도 단순한 최소한의 방어에서 적극적인 개념의 방어로 이해되는 것이 타당하다.

Daive Banister와 Simon Davis는 프라이버시의 개념을 다음의 네 가지 논의로 정의하고 있다.⁵⁾

첫째, 개인의 데이터를 통제하는데 관련한 정보 프라이버시 (information privacy)
둘째, 신체의 존엄성을 해치는 개인정보 침해에 관련한 신체적 프라이버시(bodily privacy)
셋째, 다양한 통신형태로 의사소통하는 개인의 이해관계와 관련한 통신 프라이버시(privacy of communications)
넷째, 특정 공간이나 영역으로의 침입을 제한하거나 경계설정과 관련한 영역적 프라이버시(territorial privacy)

국내의 경우, 고등법원의 한 판례에 의하면 “사생활의 비밀과 자유의 불가침은 사생활의 내용을 공개 당하지 아니할 권리, 자신에 관한 정보를 스스로 관리·통제할 수 있는 권리 등을 내용으로 하는 인격권으로서 오늘날 정보사회가 급속히 진행되면서 그 보호가 절실한 권리이다.”라고 판시된 적이 있다.⁶⁾

이처럼 시대의 변화와 국가에 따라 프라이버시는 다르게 해석된다.

2. RFID에서의 개인정보보호

개인정보보호의 정의에 앞서 프라이버시와 개인정보의 차이점에 대해서 먼저 알아

4) Solove Rotenberg, *Information Privacy Law*, Aspen Publishers, New York, 2003

5) David Banistar & Simon Davis, “Privacy And Human Rights: An International Survey Of Privacy Laws and Practice”, <<http://www.gilc.org/privacy/survey/intro.html>>, 2006

6) 서울 高判 1995.8.24 선고, 94구 39262

둘 필요가 있다. 개인정보보호 가이드라인이 발표되면서 프라이버시와 개인정보를 혼동하는 경향이 있으므로 이러한 용어에 대해서는 주의 깊은 이해가 필요하다.

프라이버시의 개념은 1960년 말부터 70년대 초에 이르러 정보화 사회가 진전됨에 따라 이전의 비밀스러운 사생활을 보호하기 위한 개인적인 이슈에서 벗어나 사회적 가치로 부각되었고, 컴퓨터를 통해 개인정보를 관리함으로써 개인정보에 관한 문제가 더욱 중요하게 받아들여졌다. 특히 이 부문과 관련된 프라이버시 문제를 정보프라이버시라고 하였는데 정보프라이버시는 “개개인이 자신이나 자신이 속한 그룹과 관련된 정보를 통제할 수 있는 권리”로 개인정보의 수집, 이용, 유포와 관련된다.

개인정보는 “생존하는 개인에 대한 정보로서 당해 정보에 포함되어 있는 성명, 주민등록번호, 주소, 전화번호 등의 사항에 의하여 당해 개인을 식별할 수 있는 부호·문자·음성·음향 및 영상 등의 정보와 더불어 개인의 신념, 신체, 재산, 사회적 지위, 신분 등에 관한 사실·판단·평가를 나타내는 일체의 정보”를 말한다. 그러므로 본 연구의 개인정보의 의미는 정보프라이버시에 더 가까운 의미로 프라이버시 정보라는 형태를 취하여 외형으로 나타남으로써 취급 및 관리가 가능하게 된 것을 말한다. 따라서 RFID 개인정보보호는 RFID 태그에 저장된 태그 소유주 개인들의 정보보호를 의미한다.

법적으로는 개인정보보호를 개인정보자기결정권이라고 명명하기도 한다. 개인정보자기결정권이란 자신에 관한 정보가 언제 어떻게 그리고 어느 범위까지 타인에게 전달되고 이용될 수 있는지를 그 정보주체가 스스로 결정할 수 있는 권리를 의미한다.⁷⁾ 이렇듯 개인정보를 보호하기 위한 한 방안으로서 개인정보자기결정권을 보장하는 것만으로는 개인정보 보호를 만족하지는 않으며, 그 실효성도 확정적인 것이 아니다.

오늘날 개인정보는 국가만이 수집 및 관리를 하는 정보가 아니다. 정보통신기술의 발달로 민간사업자, 즉 기업 등의 개인정보에 대한 수집, 관리, 이용이 국가이상으로 가능하게 되었다. 국가나 민간사업자의 입장에서는 개인정보는 경제적 측면에서 대중을 통제하는 방법으로 또는 마케팅의 방법으로 활용하고, 정보주체인 개인은 평등한 서비스를 향유한다는 측면에서 이익을 얻고 있다.

이처럼 개인정보의 이슈화는 개인정보관리자의 범위가 기업으로 확대됨에 따라 개인정보에 대한 침해가 논란이 되면서 시작된 것이다. 하지만 전형적인 국가 활동에 있어서 감시감독은 주요한 수단이 되며, 이러한 시스템이 유지되기 위해서 핵심적인 요소는 정보이며,⁸⁾ 또한 행정국가의 관리 능력은 사회전반에 대한 광범위한 지

7) 한국정보보호진흥원, “개인정보자기결정권의 한계와 제한에 관한 연구”, p.23, 2001

식정보의 관리에 달려 있는 점을 미루어보아 개인정보는 점차 중요한 요소로서의 역할을 하고 있다고 판단할 수 있다.⁹⁾

RFID에서의 개인정보보호 방법을 분류하자면 크게 기술영역, 자율적인 가이드 방식의 규제영역, 입법을 통한 강제성의 규제영역으로 분류할 수 있다. 기술영역은 제 5 장 RFID 개인정보보호 관련 기술에서 자세히 설명한다. 일반적으로는 입법과 가이드라인을 통한 규제방법을 통해 개인정보를 보호한다. 한국과 일본의 경우 자율적인 가이드라인이 우선적으로 실시되고 있으며, 미국의 경우 입법화를 추구하고 있다.¹⁰⁾

RFID 관련 개인정보보호 입법을 고려할 때는 무엇보다도 먼저 현재의 개인정보보호법률 등에서 규정하는 내용이 RFID와 관련된 개인정보보호에도 그대로 적용될 수 있는지 먼저 구분을 하여야 할 것이다. 입법은 미국과 같은 신규입법을 하는 방법이나 컴퓨터 관련 기존 법에서 개인정보보호를 수용하는 방법이 있는데, 전자는 먼저 기술의 다양한 분석과 확인을 거친 후에 가능하다.¹¹⁾ 하지만 RFID기술은 비록 RFID에 의한 개인정보 및 프라이버시 침해 문제가 여러 방면에서 논의되고 있으나, 아직까지 다양한 분야에서 적극적으로 활용한 분야가 많지 않은 점과 보편화가 되지 않은 현 단계에서 일반적인 침해유형을 확정짓는 것은 대단히 어려우므로 선불리 입법을 추진하는 것은 바람직하지 못할 것으로 판단된다. 또한 선부른 입법화추진은 RFID 외에도 신기술이 계속적으로 등장하고 있는 상황에 비추어 볼 때 RFID와 같은 신기술의 개인정보보호를 입법화로 대처할 경우 새로 생기는 신기술의 수만큼 법률수가 증가될 것이라는 문제가 발생된다.¹²⁾

개인의 인격성의 보호라는 프라이버시 보호의 차원에서 계속 프라이버시권의 보호를 받을 수 있지만 공동체의 운영상 필요에 의해 일정한 개인정보의 수집을 인정해주는 것이 필요하다. 이러한 권리는 단순히 사생활 보호의 측면으로만 바라보면 안 되고 정보활용권을 가진 정치적, 사회적인 통제와 감시권으로 인식할 필요도 있다. 따라서 향후 RFID 이용이 활성화될 것이 자명하다면 이러한 RFID의 차별성과 특징을 정확히 알고 모든 관련 사업자 및 주체 모두의 편익을 도모할 수 있도록 관계자들이 서로 노력하는 것이 중요하겠다.

8) 김종철, “헌법적 기본권으로서의 개인정보통제권의 재구성을 위한 시론”, 인터넷법률, 제4호, pp.23-44, 2001

9) 황종성 외, “IT 발전과 개인정보보호 관련 법적현안 분석”, 한국전산원, 2004

10) 김성철 외, “RFID 확산에 따른 정보보호 문제와 기업의 대응전략”, 정보통신정책연구 제12권 제1호, 2005

11) 황종성 외, “IT 발전과 개인정보보호 관련 법적현안 분석”, 한국전산원, 2004

12) 구병문, “RFID도입과 프라이버시 보호관련 법제 현안 분석”, CIO Report, 한국전산원, 2004

3. 기존의 시스템과 RFID 시스템의 차이점¹³⁾

다음의 표는 기존의 시스템과 RFID 시스템의 차이점을 설명한 것이다.

[표 1-1] 기존시스템과 RFID 시스템과의 차이점

	기존시스템	RFID 시스템
정보접근 매개요소	사용자 ID , 암호, 공인인증서	RFID 코드 ID
정보생성 주체	개인, 서비스 관련업체	제조업체[개인과 무관] ID이력, 실시간정보 관리 시스템
정보	개인신상정보[개인] 부가정보: 개인의 성향 등 관리정보[관리자]	물품정보, 제조업체 정보 이력정보, 실시간 정보
정보의 특징	정보와 개인간의 관계는 직접적이다.	개인과 직접 연관성이 없는 매개요소를 통한 정보의 생성 및 변화

기존의 시스템과의 차이점 중 가장 두드러지게 차이가 나는 부분은 정보의 연관성이 정보주체와 직접적인지 간접적인지에 있다고 할 수 있다. 특히 RFID는 비접촉식으로 정보주체가 아닌 제3자를 통하여 정보가 생성될 수도 있다. 이러한 점을 근거로 시민연대 측에서는 RFID 도입에 부정적인 견해를 보이고 있다.¹⁴⁾ 하지만 이러한 정보규제에 대해서 논의를 할 때 기존의 시스템과 RFID 정보시스템과의 정보규제의 차이점이 존재한다는 것을 간과해서는 안 된다. 다음의 표는 기존의 시스템과 RFID 시스템의 정보규제 측면에서의 차이점을 보여주고 있다.

[표 1-2] 기존시스템과 RFID 시스템에서의 정보규제 차이점

	기존 시스템	RFID 시스템
특징	개인의 신상정보, 또는 부가정보	원칙적으로 개인정보가 아닌 물품자체에 대한 정보
	정보주체가 정보생성에 대해 인식을 하고 동의를 한다.	정보수집상황을 인식하기가 어려울 수 있다.

13) 유승화 지음, *유비쿼터스 사회의 RFID*, 전자신문사, 2003년

14) 함께하는 시민연대, “제4차 빅브라더 보고서”, 2004년 11월

위의 표와 같이 기존의 시스템에서는 개인의 직접적인 신상정보 또는 부가정보가 정보로서의 역할을 하였지만 RFID 시스템에서는 원칙적으로 물품자체에 대한 정보이기 때문에 정보의 프라이버시적인 요소가 원칙적으로는 없다. 다만 정보에 개인 정보가 추가되거나 다른 시스템과의 결합에 의해서 개인정보가 생성되는 경우가 생길 수 있다.

제2절 RFID 개인정보보호의 중요성

1. RFID 개인정보보호의 위험 요인¹⁵⁾¹⁶⁾

RFID는 앞에서 언급한 것과 같이 개인정보 침해가능성이 존재한다. 본 2.1절에서는 개인정보를 침해할 수도 있는 RFID 위험요인에 대해 설명하려고 한다.

RFID 위험요인은 비접촉식인 기술의 특성과 무선의 취약성, 제3자의 리더기를 통한 정보수집 가능성 등 여러 가지 표현으로 요인을 나타낼 수 있다. 이는 RFID 시스템이 RFID의 독자적인 기술이 아니라 이전의 기술과의 융화적인 신기술이기 때문이다. 그렇기 때문에 RFID 위험요인은 이전의 기술들의 위험요인들까지도 같은 위험요인으로 인식하기 쉽다. 다음의 표는 EPC에서 위험요인을 분석한 표로서 RFID 기술의 위험요인을 정리한 표이다.

[표 1-3] EPC의 RFID 프라이버시 위험요인 분석

구분	설명
숨겨진 태그장소	RFID 태그들이 소유주인 정보주체가 인지하지 못한 상황에서 사물들과 문서에 내장될 수 있다. - 무선전파는 섬유, 플라스틱, 다른 물질들을 쉽고 조용하게 통과할 수 있기 때문에 지갑, 쇼핑, 백, 옷가방 등에 들어있는 사물 또는 옷에 부착된 RFID 태그들을 읽을 수 있다.
전 세계 모든 사물들을 위한 유일한 식별자	바코드와 달리 RFID는 EPC(전자제품코드)로 ID가 지정되어, 지구상에 모든 사물에 유일한 ID를 가지게 할 수 있다. - 유일한 ID번호 사용으로 개별 물리적인 사물이 판매 또는 이전시점에서 신원이 확인되고 구매자

15) 오길영, “개인정보보호를 위한 RFID 규제에 관한 연구”, 정보화정책, 2005년 제12권

16) KISA 정보통신부 “RFID 개인정보 가이드라인 해설서”

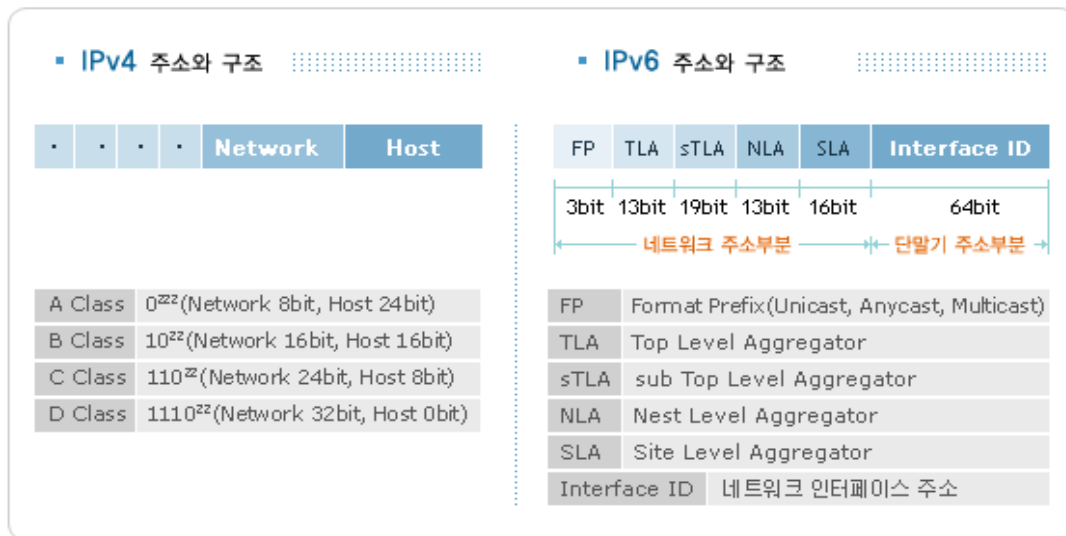
	또는 소유자와 연결될 수 있는 전 세계적인 사물 등록 시스템의 창조가 가능
대규모 데이터 통합	RFID 배치는 유일한 태그 데이터를 포함하고 있는 대량 데이터베이스의 개발을 요구하게 되며, 이는 데이터의 통합을 유발 할 수 있다.
숨어있는 리더	사람 또는 사물이 모여져 있는 어떤 환경에서도 보이지 않게 설치될 수 있는 리더들에 의해 태그들은 시야의 제한 없이 멀리서 읽혀질 수 있다.
개인추적과 개인정보프로파일	개인적인 신원이 유일한 RFID 태그 넘버와 연결되어 있다면 개인들이 인식하지 못하는 사이에, 프로파일(profile)되고 추적당할 수 있다.

위의 표와 같이 RFID는 몇 가지의 위험요인을 가지고 있다. 이러한 위험요인은 표현에 따라 추적성, 은밀성, 집적성 등의 명으로 설명되기도 한다. 여기에서는 위험요인을 높은 식별성, 은밀성, 정보통합성으로 나누어 설명하도록 하겠다.

가. 높은 식별성 (유일성, 추적성)

RFID의 태그 역할은 물품의 정보를 통한 식별을 주 역할로 한다. 이러한 점은 식별을 목적으로 하는 정보를 가진 바코드 체계와 비슷하다. 하지만 바코드 시스템과 RFID 시스템에서의 주된 차이점은 식별의 범위이다. 예를 들어 일반적인 바코드에서는 A 과자를 바코드로 인식할 경우 시스템은 A 과자로서 정보를 인식한다. 또한 제3자가 정보주체가 산 A 과자의 바코드를 인식하더라도 A 과자의 정보를 가져간다. RFID 시스템에서에서도 위와 같은 상황은 똑같은 A 과자의 정보를 인식할 수 있다. 하지만 바코드 체계에서 A 과자의 정보는 지구상 모든 A 과자가 공통적으로 가지고 있는 바코드 일련번호정보이다. 즉 바코드의 일련번호체계로는 정보주체가 산 그 ‘A 과자’를 특정해 구분할 수 없다. 하지만 RFID에서는 태그내의 정보가 당해 태그의 고유한 식별정보, ID를 부여하기 때문에 정보주체가 산 A 과자를 구분해 낼 수 있다. 즉 RFID 시스템에서는 종류와 무관하게 사물을 구별해 낼 수 있다. 이는 지구상의 고유한 신분과도 같은 역할로서 인식을 할 수도 있다.

이러한 전 세계 모든 물품에 일련번호를 줄 수 있는 RFID는 태그에 IP주소를 부여함으로써 주소체계를 해결하였다. 하지만 현재 IPv4의 주소체계로는 그 수가 부족한 상황이기 때문에 지구상의 모든 물품에 IP를 부여할 수는 없었다. 이를 기술적으로 해결한 것이 바로 IPv6이다. 아래의 그림은 기존의 IPv4와의 차이점을 그림으로 설명한 것이고 표는 IPv4와 IPv6의 특징을 비교한 것이다.



[그림 1-1] IPv4 구조와 IPv6 구조의 차이점

[표 1-4] IPv4와 IPv6의 특징 비교¹⁷⁾

구분	IPv4	IPv6
주소길이	32비트	128비트
표시방법	8비트씩 4부분으로 10진수로 표시 예) 203.24.78.63	16비트씩 8부분으로 16진수로 표시 예) 2004:2030:abod:ffff:oooo:oooo:ffff:1111
주소개수	약 43억 개	약 43억*43억*43억 개(거의 무한대)
주소할당	A, B, C, D등 class단위의 비 순차적 할당(비효율적)	네트워크 규모 및 단말기 수에 따른 순 차적 할당(효율적)
품질제어	Best Effort 방식으로 품질보 장이 곤란(Type of Service 에 의한 QoS일본 지원)	등급별, 서비스별로 패킷을 구분할 수 있어 품질 보장이 용이(Traffic Calss, Flow Label에 의한 QoS 지원)
보안기능	IPsec 프로토콜 별도설치	확장기능에서 기본으로 제공
Plug & Play	없음	있음(자동 네트워킹 가능)
Mobile IP	상당히 곤란(비효율적)	용이(효율적)
웹 캐스팅	곤란	용이(Scope Field 증가)

17) 한국전산원 IPv6그림 참조

위에서와 같이 IPv6의 주소체계는 세계인구가 60억이라 하였을 때 한 사람당 5.6양개의 주소를 줄 수 있다. 그래서 IPv6의 주소체계는 모든 사물에 IP 주소를 부여할 수 있게 되었다고 판단된다. 이러한 주소체계를 통해 RFID는 유일한 정보와 추적할 수 있는 고유 식별성을 가진 정보를 창출하게 된다. 이러한 기술적인 특성은 물품의 정보와 그 물품을 구매한 구매자의 정보가 결합되어 개인의 기호나 구매도 등 다양한 새로운 개인정보로의 재생성이 가능하다. 특히 옷, 약품 및 약물, 책 등은 선호도 및 민감한 개인의 사생활정보도 포함될 수 있다.

나. 은밀성 (숨어있는 리더)

RFID의 은밀성은 리더와 태그를 구분하여 설명할 수 있다. 먼저 태그에 대해 살펴 보겠다.

RFID의 기술발전은 태그의 최소화로 지속적인 발전을 하고 있다. 현재 최소형의 태그는 분말상태의 태그와 먼지입자를 목표로 계속 발전하고 있으며, 이러한 최소형의 태그에 식별정보는 물론 각종 센서들의 기능까지 포함할 수 있을 정도로 발전되었다. 히다찌의 뮤칩(μ -chip)은 눈으로 식별하기 어려울 정도의 크기의 RFID 칩으로 최소형의 칩에 센싱기능까지 추가할 수 있다. 이러한 태그의 기술발전이 빠른 것은 RFID 기술의 성패가 태그의 부착용이성에 달려 있기 때문이다.



[그림 1-2] μ -chip 실제 크기

태그 뿐 아니라 리더의 기술도 발전이 되어 은닉이 가능해졌다. 2006년 일본의 ID CARD 2006 박람회에서 선보인 리더의 모습들은 바닥 타일, 마루매트, 초소형의 핸드헬드 등으로 기술개발이 이루어지고 있다. 이러한 은닉가능성은 다양한 컴퓨팅기술들과 결합하는 유비쿼터스 사회에서는 정보주체의 인식 여부와는 관계없이, 혹은 정보주체의 동의 없이 정보를 수집할 수 있는 문제를 발생시킬 수도 있다.

정보수집자체의 효율 면에서는 RFID 구성요소인 태그와 리더가 정보주체의 행동에 지장을 주면 곤란하므로 정보수집의 수단인 태그와 리더의 최소화를 요구할 수 있다. 그러나 태그와 리더의 최소화로 이들의 부착여부를 정보주체가 알지 못할 수도 있으며 이러한 점을 악용할 경우 정보주체가 대응을 할 수 없다는 점에서 문제점이 발생한다.

다. 정보통합성 (데이터의 집적성, 데이터의 프로파일화)

RFID는 최종적으로 리더를 거쳐 네트워크를 통해 서버에 저장된다. 태그의 정보는 고성능, 대용량의 서버에 재 저장될 수도 있으며, 정보의 가공이 일어날 수도 있다. 이렇게 구축된 사업자들의 데이터베이스를 서로 통합한다면 비용적인 절감효과가 일어나며, 식별이 가능한 또 다른 정보와 결합을 하여 마케팅 자료 등으로 사용할 수도 있다. 이렇듯 정보의 통합 또는 연계를 통해 새로운 개인정보가 탄생할 수 있기 때문에 적절한 규제가 없으면 정보주체가 적절한 권리를 행사하지 못하는 상황이 연출될 수 있다.

2. RFID 구성요소의 보안 취약성

RFID 시스템은 구성요소인 태그와 리더기, 서버 혹은 호스트컴퓨터 사이에서 각각의 사이에 보안의 취약성을 가지고 있다. 태그와 리더 사이나 리더와 서버사이의 일반적인 무선 환경의 문제점이 나타날 수 있고, 불법적인 리더에 의한 정보 유출 가능성이 있고, 서버 내에서는 컴퓨터 보안문제 등이 나타날 수 있다. 본 절에서는 일반적인 무선 환경에서의 보안과 컴퓨터 보안(바이러스, 내부자보안 등)의 문제는 제외한 나머지 문제에 대해 언급하고자 한다.

가. 태그 데이터의 보안

RFID 태그 정보는 여러 가지가 있지만, 이 중 개인정보보호의 영역은 이력정보와 실시간 정보이다. 특히 인증의 권한을 태그데이터가 가지고 있다면 이의 위조, 변조 또한 일어날 수 있는 일이다. 이처럼 태그데이터를 불법사용자가 수정 또는 삭제하는 경우가 발생할 수 있으며, 데이터의 수정을 통해 피해를 줄 수 있다.

나. 태그와 리더기의 통신 취약성

RFID의 기술개발은 오래전부터 있었으나 최근 들어 각광을 받는 이유는 900MHz 대역으로 확장이 되면서 인식거리가 길어졌기 때문이다. 하지만 이러한 인식범위의 확장은 취약성의 발생가능성도 같이 높였다.

일반적으로 RFID 태그는 리더기에 데이터를 전송할 때와 리더기가 태그에게 전파를 보낼 때 취약성을 가질 수 있다. 태그와 리더기 사이의 취약성은 일반적인 무선 전파의 취약성과도 같은 맥락이다. 또 태그와 리더기 사이에서 다음의 경우에도 보안의 문제점이 발생한다.

(1) 불법적인 리더기를 통해 데이터를 수집하는 경우

인가되지 않은 리더기를 통해 태그에 의해 전송되는 데이터를 가로채는 경우를 말한다. 일반적인 RFID시스템에서는 상대방을 인식하기 위해서는 자신도 인증정보를 유지해야 한다. 이러한 인증정보를 통해 리더기의 인증을 확인하는 것이 일반적이거나 이러한 경우는 서버의 저장능력을 이용하는 경우이다. 따라서 일반적으로 불법적인 리더를 선별해서 태그가 응답하는 것은 어려운 항목이다. 따라서 최근에는 이러한 점을 해결해주는 기술들이 개발되고 있다.¹⁸⁾

(2) 제3자가 데이터 통신을 방해하거나 스푸핑하는 경우

불법적인 제3자가 태그와 리더기 사이의 통신을 막기 위해 여러 방법을 사용할 수 있다. 수많은 가짜 정보를 인식하게 해 과부하를 일으키게 하는 스푸핑 방법이 가장 일반적인 방법이다. 이러한 방법을 DOS(denial of service)공격이라고도 한다.

(3) 가짜 태그를 이용해 데이터를 보내는 경우

주파수 대역을 확인해 가짜 태그를 리더기에 전송하는 경우로서 이 경우 불필요한 정보나 부정확한 데이터를 리더기에 전송하게 된다. 가짜태그를 통해 기업체 또는 사업체에게 경제적인 손실을 줄 수 있다.

(4) 지속적인 도청을 하는 경우

18) 자세한 내용은 “제 5 장 RFID 개인정보보호 관련 기술”의 내용 참고

위에서도 언급하였듯이 태그에는 원칙적으로 물품의 정보가 들어 있다. 이러한 RFID 태그를 일회성으로 도청하는 것만으로는 큰 위협을 줄 수는 없다. 하지만 지속적인 도청을 통해서 태그를 추적할 수 있는 요지가 있다.

다. 리더기의 데이터 보안의 취약성

태그는 리더기에 데이터를 보내고 데이터의 전송을 완료할 때까지 메모리에 정보를 저장하고 부여된 기능을 실행하기 위해 데이터를 사용한다. 하지만 이러한 과정에서 리더기는 보안의 취약성을 가지게 된다. 즉, RFID 기술은 유비쿼터스 환경에 기반이 되는 기술로서 리더기와 로컬서버의 구간도 유선보다는 무선일 가능성이 높다. 대부분의 경우 유비쿼터스 환경에서 리더는 Handheld Reader로서의 역할을 하는 기기를 사용할 것이다. 따라서 이러한 리더기들은 이동성을 보장하기 위하여 무선 환경에서 로컬서버와의 연결을 할 것이라 판단된다.¹⁹⁾

이러한 무선환경, 무선랜 환경에서는 무선채널을 사용한다는 특징으로 인하여 보안상 취약점을 가지고 있다. 하지만 이러한 문제는 이전 무선인터넷 초창기부터 해결이 되어가는 문제들로 현대는 여러 가지 알고리즘이 제안 및 개발되고 있다.

3. RFID의 주요 문제점 및 대응 방향

RFID 기술이 유비쿼터스 환경에서 핵심적이고 중요한 기술이지만 개인정보 침해 가능성이라는 큰 문제점을 가지고 있다. 여기에서는 이 문제점을 좀 더 세분화하여 정보를 수집하거나 제공할 때, 타 정보와 결합할 때, 정보를 관리할 때, 그리고 위치정보를 이용하는 경우에 나타나는 문제점과 대응 방향에 대해서 알아보겠다.

가. 정보 수집 측면

(1) 문제점

(가) 정보의 무단 수집 : RFID 시스템의 기술적 특성상, 정보주체가 전혀 인식하지 않은 상황에서 물품 등에 부착된 RFID 태그를 통해 물품 및 연

19) Uwe Hansmann, Lothar Merk, Martin S. Nicklous, Thomase Stober, 역자 - 이근호, 이기혁, 한호현, *유비쿼터스 컴퓨팅 핸드북*, 진한도서, 2004

계된 개인정보 등이 무단으로 수집될 수 있다.²⁰⁾

(나) 연속적, 지속적인 개인정보의 수집 가능성 : RFID를 통한 개인정보의 수집은 단순히 일회성, 특정인이 아니라 수시로 계속적인 개인정보의 수집이 가능하다.²¹⁾

(2) 대응 방향

(가) RFID는 특성상 확인 및 시스템의 인식이 타 시스템 및 다른 기술이나 방법에 비해 어렵기 때문에 개인정보와 프라이버시 보호에서 보다 적극적인 보호조치를 취할 필요는 있다. 그러므로 정보주체가 RFID 리더의 여부, 태그의 부착여부, 수집할 때 수집되는 내용 등에 대해서 충분히 인식할 수 있는 권리가 있으며 이에 대해 보장할 필요가 있다.

(나) RFID 시스템을 통한 개인정보의 계속적인 수집에서는 예외적인 특별한 경우를 제외하고는 개인정보 주체의 포괄적 동의가 가능하도록 해야 한다. 이는 RFID를 이용하는 이용자의 권익과 나아가 사업자의 권익도 보호해야 할 필요성이 있기 때문이다. 또한 포괄적 동의의 경우에는 일반적으로 세부적인 내용에 대한 인식이 불가능한 경우가 발생할 수 있으며 이는 정보주체에게 불이익을 제공하는 경우가 많으므로, 개인정보 주체의 동의 철회 절차를 간소화하는 방법 등을 통해 개인정보 주체의 권익을 강하게 보호할 필요성도 있다.

나. 정보의 제공 측면

(1) 문제점

(가) 정보주체가 개인정보 수집에 대한 동의여부를 표시할 때 적극적인 방법으로 개인정보 수집 거부를 할 수 있는지가 문제될 수 있다.

(나) 정보주체가 개인정보를 제공하는 것을 거부하는 경우 물품판매업자나 서비스 제공업자가 물품 또는 서비스 제공을 거부할 수 있는가의 여부가 문제될 수 있다.

20) 이는 향후 RFID 태그의 활용도가 높아지면 높아질수록 RFID 태그를 이용한 개인정보의 수집도 이에 비례하여 증대할 것으로 예상할 수 있다.

21) 따라서 RFID 시스템에서의 개인정보의 수집은 정보주체의 포괄적인 동의여부에 의해 실시할 수 있도록 하는 규제가 필요하다.

(2) 대응 방향

(가) 정보주체가 적극적으로 거부할 수 있도록 사용자의 동의 없이도 RFID의 기능을 정지하거나 이용자체를 배제를 할 수 있는 권리를 보장할 필요가 있다. 즉, 인식되지 않은 RFID 리더로부터 개인정보를 보호하기 위해 RFID 리더 감지기나 전파 교란 장치를 휴대 및 사용할 수 있는 권리를 부여하고, 개인정보의 주체가 제공을 원하지 않는 개인정보가 포함되어 있거나 위치정보의 제공을 꺼려하는 경우에는 관련 RFID 태그를 스스로 제거하거나 기능 정지 또는 파괴할 수 있는 권리를 보장하여야 한다.

(나) RFID를 통한 개인정보의 제공 없이는 계약을 이행할 수 없는 경우가 있다. 이 경우 고객이 RFID를 통한 개인정보의 제공을 거절한다면 물품 판매업자나 서비스 제공자업자가 당연히 계약 체결을 거절할 수 있는 것으로 판단되지만 단지 개인정보를 제공하지 않는다는 이유로 서비스를 거절하는 것은 정보주체에 대해 불합리한 요소가 발생할 수 있다고 사료된다.

다. 타 정보와의 결합 측면

(1) 문제점

(가) RFID를 통해 수집된 정보가 기타 방법으로 기존의 가지고 있던 다른 정보들과 결합하여 개인정보화가 되는 경우나 또 다른 개인정보와 결합이 되어서 새로운 '개인정보'로 나타나는 경우가 발생할 수 있다. 22)

(나) RFID 위치정보가 기타 방법에 의해 또 다른 개인정보와 결합하게 되면, RFID 태그를 소지한 정보주체에 대한 실시간 위치추적이 가능하고

22) 여기서 '개인정보'라 함은 생존하는 개인에 관한 정보로서 성명·주민등록번호 등에 의하여 당해 개인을 알아볼 수 있는 부호·문자·음성·음향 및 영상 등의 정보(당해 정보만으로는 특정 개인을 알아볼 수 없는 경우에는 다른 정보와 용이하게 결합하여 알아볼 수 있는 것을 포함한다)를 말한다. 이는 정보통신망 이용촉진 및 정보보호 등에 관한 법률 제2조 제6호에 나타나 있는 내용이다.

그러나 정보들의 여러 결합으로 새로운 정보가 탄생하고 이 정보가 개인정보화가 될 경우가 발생할 수 있는 것은 바코드의 경우에서도 마찬가지이고 RFID라고 해서 특별할 것은 없다.

이에 따라 프라이버시 침해가 일어날 수 있다.

(2) 대응 방향

(가) RFID를 통한 비개인정보를 기타 방법으로 기존의 개인정보나 다른 방법으로 수집된 개인정보와 결합하는 경우에는 결국 개인정보화가 되므로 개인정보로서 동일한 보호를 받아야 된다. 따라서 원칙적으로는 비개인정보와 개인정보의 결합은 금지되어야 하며, 예외적으로 비개인정보와 개인정보를 결합하는 경우에는 정보주체로부터 정보의 수집동의와 함께 수집된 정보의 결합에도 동의를 받아야 한다.²³⁾

정보주체의 개인정보권리 보호를 강화하는 차원에서 RFID을 통해 수집된 비개인정보와 기타 개인정보의 결합이 가능한 경우에 대해서는 관련 법규에서 구체적으로 다룰 필요가 있다.

라. 정보의 관리 측면

(1) 문제점

(가) RFID를 통해 수집된 개인정보나 비개인정보와 개인정보의 결합을 통해 얻은 개인정보는 기업의 마케팅이나 CRM차원에서 무단접근, 유출, 불법거래 가능성이 높다.

(나) RFID의 무단 복제, 비인가 RFID 리더의 무단 사용, 시스템해킹 등 정보가 유출된 가능성 또한 있을 수 있다. ²⁴⁾

(2) 대응 방향

(가) RFID가 활성화되면 적용되는 사업 분야에 관계없이 광범위한 정보 수집이 가능하고, 이런 정보는 손쉽게 취합하거나 재분류할 수 있다는 점에서 RFID 관리자에게 책임범위를 확장하고 이에 대한 규제와 감독을 강

23) RFID를 통해 수집된 정보와 개인정보를 결합하는 경우에는 RFID의 특성상 민감한 개인정보 혹은 광범위한 개인정보에 따른 침해 가능성이 높고 이에 따른 파급효과도 높다고 한다면, 동의의 요건을 까다롭게 하고, 법률의 규정 등에 의해 예외를 인정하는 경우에도 지극히 제한적인 범위 내에서 인정하는 것이 바람직할 것으로 판단된다.

24) 무단 접근, 복제, 해킹을 통한 개인정보는 다른 범죄를 위한 도구로 재사용하는 경우가 발생할 수 있다.

화할 필요가 있다. 이 역시 위의 타 정보와의 결합과 마찬가지로 이전의 타 기술(바코드, 신용카드, 인터넷)에서부터 있었던 문제이므로 이전의 규제에 보완하는 방법이 현실적이라고 판단된다.

(나) 정보 수집에 대한 모든 관련자들에 대한 교육 강화, RFID 사용 등록제도 등 실질적인 규제를 보완할 필요도 있다.

마. RFID 위치정보 이용 측면

(1) 문제점

(가) RFID는 초창기 개발부터 항공기의 아군식별을 위한 위치정보의 제공이 주요 목적 중 하나임으로 정보주체의 위치정보가 프라이버시 또는 개인정보로서 침해될 여지가 있다.

(나) 특히, 정보주체의 동의와 관계없이 개인정보로서 위치정보가 이용될 수 있다. RFID리더가 있으면 상대방의 위치정보는 손쉽게 파악을 할 수 있는 가능성이 있기 때문이다.

(2) 대응 방향

(가) 위치정보와 개인정보의 결합은 원칙적으로 강력히 규제되어야 한다. 다만 긴급구조 등 정보주체의 생명과 관계된 긴급한 사유에서는 동의 없이도 위치정보를 이용이 가능하도록 할 필요가 있다.

4. 주요 쟁점의 검토²⁵⁾

가. 규제방식과 규제정도

RFID 프라이버시 및 개인정보의 규제는 나라마다 문화가 다르듯 차이점이 존재한다. 그러므로 다른 국가의 규제방식을 기준으로 삼아 자국의 규제정도를 결정하는 것은 바람직하지 않다고 판단된다. RFID 규제방식은 각국이 처해있는 상황과 기술동향을 반영하여 결정되는 것이 타당하다. 여러 국가들을 보면 규제의 방식에 있어서는 차이가 있지만 개인정보보호에 대한 인식의 부분에서는 큰 차이가 없다. 규제

25) 오길영, “개인정보보호를 위한 RFID 규제에 관한 연구”, 정보화정책, 2005년 제12권

방식은 강제적 규제방식으로서 RFID에 관한 개별 입법을 추진하는 방안, 기술진입의 시점에서 단기적으로 대응 가능한 가이드라인 방안, 그리고 중장기적으로 기존의 법제를 보완하는 방안으로 나눈다. 미국은 주로 개별입법을 추진하고 우리나라나 일본의 경우는 가이드라인을 제시하는 방향으로 가고 있다. 이렇게 각국의 프라이버시 대처방법의 차이는 기술수준의 차이나 프라이버시에 대한 인지차이가 아니라 RFID 기술진입에 대하여 각국의 사회적 상황이나 법제화의 현황을 반영한 결과이다. 따라서 특정의 방식이 결코 다른 방식보다 적절하다는 판단을 내리는 것은 불합리적인 생각이다. 각각의 방식에 장단점을 파악하고 능동적으로 대처해 나갈 필요가 있다.

RFID 기술은 단지 RFID 기술로서의 문제가 아니다. 유비쿼터스 환경의 일부분인 RFID로서 파악을 해야 한다. 즉 유비쿼터스 컴퓨팅의 환경까지 유기적으로 생각해야 할 필요가 있다. 이러한 생각에서는 기존의 법제를 활용하면서 RFID 특성을 반영한 가이드라인을 만든 우리나라와 일본의 방식이 적절한 선택이라고 볼 수도 있다.²⁶⁾

규제의 정도는 새로운 기술로서의 RFID를 판단하는 것도 중요하지만 개인정보보호 문제는 이전의 기술에서 나온 문제들과도 유사하거나 연속되는 점이 많다. 따라서 이러한 신기술에서의 규제는 정보의 유통에 대한 단속위주의 규제정책으로서만 일관하면 이는 기술의 역기능 방지가 아니라 기술자체를 부정하여 기술실패의 결과를 초래하게 된다.

다만, 기존의 개인정보보호법의 행사가 용이치 않은 RFID의 특성적인 부문에서는 좀 더 구체적인 방안마련과 새로운 규제 메커니즘 개발이 필요하다고 생각한다.

나. RFID 식별정보에 대한 법적·정책적 문제

RFID 태그내의 정보는 원칙적으로 ‘사물 정보’이지 ‘사람에 관한 정보’가 아니다. 따라서 RFID 데이터를 자체적으로 개인정보라고 규제하기에는 논리적인 비약이 있고, 개인을 식별할 수 있는 정보와 결합하여 개인정보화할 가능성이 높기 때문에 결합의 가능성이 있는 개인식별이 가능한 RFID 정보는 따로 규제방안을 마련하는 방법도 생각해 볼 필요가 있다.

이는 개인정보보호법에서 확장시켜 RFID 개인정보로 흡수하거나 RFID 관련법제를 만들어 특별하게 관리하는 방안으로 생각할 수 있다. 후자에서는 개인정보화하

26) 자세한 내용은 “제 2 장 RFID 개인정보보호 관련 해외동향”, “제 3 장 RFID 개인정보보호 관련 국내동향” 참고바람

는 단계를 강제로 규제하는 방안과 정보관리주체간의 자율적 규제에 일임하는 방안이 있겠다.

다. RFID 시스템에 대한 개념정의의 필요성

각국의 RFID 개인정보에 관한 정의가 다르듯이 RFID 시스템 또한 개념이 서로 다르다. 각국의 RFID에 대한 정의가 다르므로 이에 대한 법률적 정의를 하기에 곤란한 상황이다. 그리고 모든 입법례, 가이드라인에서 RFID 태그에 대한 언급은 있지만 RFID 리더나 서버에 대한 언급은 전혀 없다. 이는 현재 RFID 기술이 도입되고 있는 물류나 유통부문만을 주요한 모델로 상정하면서 생긴 문제점이라고 생각된다. 왜냐하면 물류나 유통분야에서의 시스템 경우 RFID 리더는 항상 사업자가 취급하게 되므로, 사업자만 정의하면 리더는 정의할 필요가 없어지기 때문이다. 그리고 RFID 보안 취약점은 태그에서 리더사이에서 취약점을 가장 크게 나타낸다는 점에 주목해야 할 필요가 있다. 도청자가 인가되지 않은 리더기를 가지고 사업장내부로 들어가면 굳이 서버를 해킹하지 않아도 정보를 얻어낼 수 있기 때문이다. 또한 서버의 경우, 기존의 서버보호기술을 통해 보호할 수 있으나 리더기는 도청이라는 전파의 맹점을 가진 상태이다.

위와 같은 문제는 정확한 개념의 정의 없이 규정대상에 의미를 부여하여 생긴 결과라고 판단된다. 따라서 태그의 중요성이 높은 물류나 유통에서의 국한되지 않은 전체적인 RFID 시스템에 대한 개념이 도입되어야 된다고 생각한다.

라. 정보주체의 권리보호

위에서 언급한 바와 같이 RFID를 통한 데이터는 원칙적으로 사물의 식별정보에 불과하고 사람에 대한 어떠한 정보도 없기 때문에, 리더기를 통해 얻어진 정보가 정보주체를 식별할 수 있는 정보와 연계되지 않은 한 현행개인정보보호법제에서 규정하는 개인정보에 해당될 수 없다는 어려운 점이 있다. 따라서, 일반적인 RFID 태그정보는 원칙적으로 개인정보화 할 가능성을 가지고 있는 정보로서 별도의 규제를 필요로 하는 것이지 RFID 정보 자체를 개인정보로서 규제하고자 하는 것은 아니다. 좀 더 자세히 설명하자면, 현행 개인정보보호법제의 규제대상에 해당될지 해당되지 않을지는 RFID 태그의 사용시점에서는 알 수 없고, 이는 수집정보가 리더에서 서버 단계까지 어떠한 정보로 정형화되고 데이터베이스화되는지에 따라서 결정되어진다. 따라서 개인정보의 개념을 확장하여 RFID 정보를 기존 개인정보보호법제로 흡수하

지 않는 한, RFID 관련규제에서의 사전동의 및 고지의무 조항은 독자적 의미를 가지는 것이다.

위에서 언급한 정보주체의 불합리한 피해를 입지 않도록 하는 사전고지의 필요성은 고지를 통해 정보가 어떤 목적으로 수집되는지, 언제, 어떻게 수집되는지 등을 정보주체가 인식하고, 정보제공 여부에 대한 권리를 보호할 수 있기 위한 것이다. 이러한 점에서는 단순히 RFID의 사용모델과 RFID를 개인정보 수집용으로 활용하는 것을 구분하여 파악하고 있는 우리나라 가이드라인의 규정내용은 다른 입법례에 비해 진일보한 규정으로 파악된다.²⁷⁾

27) 관련내용은 본 보고서의 제 3 장 “RFID 개인정보보호에 관련 국내동향” 참조

제 2 장 RFID 개인정보보호 관련 해외동향

제1장 주요국가의 정책 현황 및 동향

현재 각국의 개인정보보호에 관련한 행보는 위에서 언급한대로 각국의 사회성과 문화 등에 맞추어 입법화 또는 가이드라인 방식으로 이루어지고 있다. 미국은 강제성의 입법화를 추진 중에 있으며 일본은 우리나라와 마찬가지로 자율적인 가이드라인 방식을 채택하고 있다. 그리고 유럽은 미국, 일본과 우리나라의 행보를 주시하고 있다.

본 장에서는 미국, 일본, 유럽의 RFID 개인정보보호 관련 동향에 대해 살펴보겠다.

1. 미 국

RFID에 관한 입법추진과 여론의 의견이 활발한 미국은 RFID 프라이버시에 관한 이슈도 많은 국가이다. 미국의 소매업계 단체인 NRF가 실시한 RFID 관련 조사에 따르면 프라이버시 문제가 상위를 차지하고 있었고, 남녀별로 비교해 보면 여성은 트래킹을 우려하고 있었고, 남성은 원격인식을 걱정하고 있었다. 직불카드, 신용카드, 카메라폰과 같은 종래 기술들과 비교했을 때 RFID쪽이 더 큰 위협으로 인식하고 있었다. 프라이버시 대책의 요구사항을 물어본 결과 ‘법률에 의한 소비자 보호’가 62%로 가장 많았다.²⁸⁾

미국은 연방 차원에서의 입법화는 아니지만 감사원의 보고서와 시민단체의 입법화 추진, 개별 주별로 RFID와 개인정보 보호와 관련해 논의를 진행 중에 있으며, 캘리포니아주, 유타주, 미저리주, 메릴랜드주, 메사추세츠주 및 버지니아주 등은 법안을 제시 또는 시행을 준비하고 있다. 사우스 다코다주, 로드 아일랜드주 등에서는 각각 개인에게 RFID기기의 이식을 금지하고, 정부기관에서 종업원이나, 학생등의 움직임을 추적하기 위하여 RFID 기술을 사용하는 것을 금지하고 있다.

28) 참고적으로 이 조사는 RFID 초기 단계인 2003년의 조사로서 잠재적인 위협으로 크게 인식한 결과이다.

가. 감사원의 보고서²⁹⁾

2005년 6월 미국의 감사원은 RFID 기술의 문제점에 대한 보고서를 발표하였다. 이 보고서는 전반적인 도입을 하기 전에 해결해야 하는 문제점에 관련된 보고서이다. 이번 보고서는 미 정부의 조달 사업과도 관련이 깊기 때문에 이에 대한 대비책을 보완해서 RFID 상용화를 준비하면 경쟁력의 우위를 점할 수 있다고 판단된다.

감사원의 보고서에는 RFID 기술이 도입되면서 발생할 수 있는 개인 사생활 침해에 관한 문제점이 언급되어있다. 특히 기존의 사생활 보호법규 등은 이미 저장되어 있는 정보를 보호하는 방식 위주로 편성되어 있기 때문에 불법적인 또는 인가받지 않은 리더기로 정보를 갈취하는 방식 등 어떠한 방식으로 정보를 편취해 가는 것에 대한 보호는 상대적으로 미흡하다는 것을 지적하였다. 또, 정보의 수집의 경우에 대한 사생활 침해 가능성에 대해 지적하였는데 이는 RFID 태그의 데이터가 리더기를 통해 읽힘으로써 개인의 위치 추적과 개인의 소비패턴 등의 자료가 축적되어 프라이버시를 침해할 수 있다는 것이다. 그리고 정보가 축적된 이후에 타 정보와 연계되는 경우에도 프라이버시 침해 가능성이 있기 때문에 RFID 리더기를 통해 모아지는 자료를 저장하는 장치에 대한 정기적인 조사와 관리가 필요하다는 지적도 있었다.

감사원은 RFID 기술 자체에서는 RFID 칩의 오작동을 방지하는 것이 중요하다고 지적하였다. RFID 오작동은 신뢰성에 상처를 입게 되는 것이고 이는 상품계산에서도 재정적인 손실을 줄 수 있으므로 칩 자체의 오류를 막아야 된다고 강조하였다. 보고서의 내용에 따르면 관련 조사기관의 자료를 인용하여 RFID 칩에 안테나를 부착하는 제조과정에서만 약 30%의 불량품이 발생하고 있다고 전하며 RFID 칩의 오류방지가 중요하다고 다시 한 번 강조하고 있다.

감사원은 환경문제에 대해서도 언급하였는데, RFID의 상용화를 통하여 많은 양의 태그가 생산되면 이는 환경문제에 영향을 끼칠 것이라고 한다. 다시 말하면 RFID 칩을 제조하는 원료로 실리콘, 니켈, 알루미늄 등이 필요하지만 이러한 금속 태그들이 재처리를 하지 않고 무방비로 환경에 노출되면 새로운 환경문제를 야기할 수 있다는 것이다. 그러므로 이에 대한 분리수거와 재사용에 대한 논의가 필요하다고 지적한다.

개인 사생활 보호와 관련해 보고서에서의 해결책으로는

29) 미 감사원, "Key Considerations Related to Federal Implementation of RFID Technology", 2005년 6월

- 일정한 장소에는 RFID 리더기가 작동하고 있다는 것을 알려주는 장치 설치
 - 일정 상품에 붙은 태그는 상점을 벗어나면 자동적으로 활동이 중지되는 기술의 도입(Kill Tag)
 - 정보의 송수신에서의 암호화
- 등을 제시하였다.

나. 캘리포니아주

(1) 데보라 보웬이 제안한 ‘SB 1834’

캘리포니아주 상원의원 데보라 보웬(Debra Bowen)은 2004년 2월 20일 RFID 상용화와 관련해서 소비자 사생활보호 등을 주장한 법안 ‘SB 1834’를 제안하였다. 이후 법안은 4월 1일, 6월 14일 두 차례에 걸쳐 수정되어 주상원에 계류(繫留)를 하였으나, 결국 의회 통과가 무산되었다. 이는 RFID가 초기단계이고, 프라이버시 유형은 쉽게 정의할 수 없기 때문에 법률적인 문제로 해결하기에는 무리라는 이유에서 기인한 것으로 판단된다.³⁰⁾

이 법안은 2개 조항으로 구성되어 있는데 첫 번째 조항은 수정된 안으로 개인을 식별하기 위한 정보를 수집·이용의 목적으로 RFID 태그와 판독기를 사용하기 위해서는 일정한 조건을 준수하도록 하고 있다. 조건의 주요내용으로는 다음과 같다.

- RFID를 통해 개인정보를 수집하는 경우 서면 동의를 획득해야 수집가능하다.
- 개인식별정보는 RFID 태그가 부착되어 있는 제품을 소비자가 구매하는 경우 거래 성사와 관련된 수준의 정보만 제공할 수 있다.
- 거래 행위 성사 이전 또는 이후에 개인식별정보를 수집해서는 안 된다.
- 수집되는 정보는 실제 구매나 대여를 하기위해 제품을 제시하는 사람과 제품에 대한 것이어야 한다.
- 정보주체(소비자)에게 RFID 태그의 분리 또는 파괴에 대한 권한을 부여한다.
- RFID를 통해 개인정보 외의 정보를 수집하는 경우에는 본 법안의 적용을 배제한다.

두 번째 조항에서는 일반 상점을 대상으로 하는 것 이외에 도서관을 적용대상으로

30) 김성철외 3명, “RFID 확산에 따른 정보보호 문제와 기업의 대응전략”, 정보통신 정책연구, 제12권 제1호

규정하고 있다. 이는 도서관의 일반적인 프로세스는 직접 제품을 판매하는 것이 아니라 책 등을 관리하고 대출하는 과정이므로 RFID를 사용할 경우 많은 도움을 받을 수 있는 부분으로 여겨지고 있기 때문이다.³¹⁾

캘리포니아 RFID법안은 기존의 법안과 차이점을 가진다. 다른 법안에서는 법안의 기준을 태그가 활성화된 상태를 기준으로 하지만 이 법안에서는 소비자가 상점을 떠나기 전에 분리되거나 파괴되어야 한다는 점이 다른 법안과의 차이점이다. 하지만, 이 법안은 시스템에 관한 전반적인 법안이 아니라, 불공정경쟁 행위법에 속해있는 항목이라는 제한점이 걸려있다.

(2) 조 스미티안이 제안한 RFID 제한 입법

캘리포니아 상원의원 조 스미티안(Joe Smitian)의 발의로 마련된 RFID 제한 입법은 한 초등학교의 학생증에 RFID를 장착하기로 한 이슈에서 불거졌다.³²⁾

초등학교에서 학생들의 출석현황을 학생증에 RFID 기술을 도입해서 파악하기로 하였으나 학부모와 인권단체들의 사생활 침해에 대한 강력한 항의로 결국 이 계획은 무산되었다. 결국 상원의원은 이 문제를 계기로 RFID 제한 입법을 추진하였다. 2005년 4월에 상원의원 조 스미티안의 건의로 입법화를 추진하였고 캘리포니아 주 상원에서는 통과시켰다. 이 법이 제정되면 모든 ID카드에는 RFID 칩을 장착하지 못하게 되기 때문에 이미 시행되고 있는 연방정부의 E-passport 정책과의 마찰이 우려된다. 그래서 이 법안에서는 모든 ID 카드에 적용하지 못하도록 하였지만 예외적인 규정이 포함되어 있다. 예외적인 규정의 내용은 고속도로의 톨게이트나 교도소, 치료감호소 등을 포함한 교정기관, 의료기관(4세이하 어린이에게만 적용), 정부의 공익(사생활 침해와의 비교시 공익이 높은 경우에만 해당됨.)의 경우에는 RFID 기술을 사용할 수 있도록 하는 것이다.

(3) 신원보호법 (SB 682)

2005년 6월 캘리포니아 상원을 통과한 신원보호법 (The Identity Information Protection Act Of 2005)은 정부의 RFID 사용에 제한을 가하는 규정으로 되어있다. 신원보호법은 사람의 위치정보와 신원등의 각종 정보문서들에 대한 제한을 두

31) 정보통신정책연구원, “유비쿼터스 사회의 역기능에 관한 법제도적 기초연구”, 한국전산원, 2004년 12월

32) WIRED, "School RFID plan get F", 2006년,
<<http://www.wired.com/news/privacy/0,1848,66554,00.html>>

고 있다.³³⁾ 인권단체에서는 이 법안이 가이드라인적인 제시를 해주고 있다고 평가하고 있으나, 관련업체들은 법안이 과도하게 제한을 하게 될 수 있다고 우려하였다.³⁴⁾

다. 유타주³⁵⁾

유타주에서는 하원의원 호이그(Hogue)의 제안 하에 RFID알권리법안이 하원의회를 통과하였다. 이 법에서는 RFID 태그를 마이크로칩 제품으로 물품 혹은 제품에 관한 고유번호 혹은 식별자를 포함한 장치로 전파를 이용해 외부장치로 읽어낼 수 있거나 외부 장치에 전송할 수 있는 것으로 정의한다. 유타주의 RFID알권리법안의 구조를 살펴보면 RFID와 관련된 조항을 규정하기 위해 유타주 소비자 판매 행위법(Utha Consumer Sales Practices Act)을 개정하고 있음을 알 수 있다.

유타주 RFID알권리법안에서의 프라이버시에 관한 규정을 살펴보면 다음과 같다.

- 사업자에게 제품에 부착되어 있거나 패키지에 부착된 RFID 태그를 받아야 한다.
- RFID 시스템 태그는 소비자가 그 상점을 이탈하기 이전에 분리 또는 파기하도록 한다.
- 소비자에게 사전에 RFID 리더에 정보를 제공할 수 있음을 고지한다.
- 위의 고지방법으로 전시 제품 주위와 판매대에 로고로서 하거나 눈에 잘 띄는 다른 방법으로 하도록 한다.
- 소비자가 원하지 않는 한 제품 판매 완성 시점 이전에 RFID 태그의 기능을 정지시켜야 한다.

본 법안에서는 RFID 관련 내용을 고지하고, 태그 기능을 정지시킬지 여부에 대해 소비자에게 선택권을 주도록 하고 있다. 판매완료시점 이전에 태그의 기능을 정지시킬 수 있도록 함으로써 판매완료시점에 개인식별정보와 제품과의 연계를 끊도록 하고 있다. 유타주의 RFID 알권리법안은 미국 캘리포니아 주에 이어 두 번째 입법으로써 RFID 관련 입법안이 다른 주로 확산될 가능성을 보여주고 있다. 캘리포니아 주 입법안(데보라 보웬이 제안한 ‘SB 1834’)과 차이가 나는 것은 판매완료 시점 이전에 RFID 태그의 기능을 정지시키도록 하고 있으며 기능 정지에 대해 소비자 선

33) <[http:// www. epic.org/privacy/rfid/sb682_33005.html](http://www.epic.org/privacy/rfid/sb682_33005.html)>

34) <[http:// www.fcw.com/article89391-06-27-05-print](http://www.fcw.com/article89391-06-27-05-print)>

35) 유승화 지음, *유비쿼터스 사회의 RFID*, 전자신문사, 2003년

택권을 명시적으로 규정하고 있다는 점이다.³⁶⁾

하지만, RFID와 관련된 정보의 보호대상을 명확히 하지 않고, RFID를 통한 개인 정보의 수집·이용 등에 관한 내용을 포함하지 않고 있다.

라. Opt Out of ID Chips Act

미국 연방의회에서는 'Opt Out of ID Chips Act'(HR 4673 IH) 법안이 제출되었다. 이 법안에는 RFID를 부착한 소비자에 다음과 같은 사항을 명시해야 된다고 규정되어 있다.³⁷⁾

- RFID 태그 부착과 RFID 위치추적 위험성을 명시한다.
- 제품 구매시 소비자가 RFID 태그를 제거하거나 기능을 상실케하는 권리를 요구할 수 있다.

이 법안은 위의 규정을 명시해야 한다고 규정하고 있어서 구매단계에서 소비자가 RFID를 선택적인 제거를 할 수 있게 하였다. 이는 정보주체로서의 권리를 보호하는 장치를 제공하는 것이다.

마. REAL ID Act of 2005³⁸⁾

리얼 ID 법(REAL ID Act of 2005)은 하원법사위원회 위원장인 제임스 센센브레너(James Sensenbrenner, R-Wisconsin)의 주도로 이루어진 것으로, 테러리스트나 서류를 갖추지 못한 이민자들이 적법한 신분증명서를 취득하거나 미국 전역을 자유롭게 여행하는 것을 더 어렵게 만들기 위해 9/11 조사위원회의 권고에 따라 제정되었다. 또한 이 법안은 신분증명서를 위조하거나 위조된 신분증이 범죄에 사용하는 것을 막기 위한 것이다.

본 법안은 통과가 되었지만, 통과과정에서의 문제점과 반대여론들의 저항 때문에 난항을 겪고 있다. 이 법은 관련기술부분에서 RFID가 언급된 전용의 법은 아니다. 하지만 여론과 관련 운동단체들의 의견에 의하면 RFID 기술이 포함될 가능성이 매

36) 이용필, “유타주 하원의 RFID 알권리 법안”, 한국 정보보호진흥원 전자거래보호 이슈리포트, 2004.3

37) JOHN M. EDEN, WHEN BIG BROTHER PRIVATIZES: COMMERCIAL SURVEILLANCE, THE PRIVACY ACT OF 1974, AND THE FUTURE OF RFID

38) <www.wired.com/article/privacy>

우 높다는 것이다.

이에 대해 많은 시민단체들은 이 법안이 사생활 침해 요소를 지니고 있다고 우려하고 있다. 비록 동 법안에서는 기계 판독식 면허증이라는 단서를 달고 있지만 사용되는 기술의 종류에 대해서는 규정하고 있지 않다. 공무원들이 운전면허를 초기 발급할 때에는 요구하지 않더라도 특정 시기에는 면허증 안에 비접촉 RFID 칩을 내장할 것을 요구할지도 모른다고 말했다. RFID 칩은 마그네틱 선보다 더 많은 정보를 저장할 수 있지만 RFID 리더기만 있으면 면허증 소지자도 모르는 사이에 원거리에서 면허증 안에 내장된 정보를 수집하는 일이 가능하다.

법안의 찬성자들은 단순히 9/11 조사위원회가 결정한 권고안을 이행한 것뿐이라고 밝혔다. 작년 9/11 조사 위원회는 정부가 발행하는 ID의 통제를 더욱 강화해줄 것을 요청했는데, 그 이유는 2001년 9월 11일 발생한 19건의 비행기 납치 사건 중 18건의 테러 공격에서 미국 ID를 사용해 공항 보안대를 통과했기 때문이었다.

이 법을 지지하는 사람들은 법 제정을 통해 테러리스트들의 침입을 막고 불법 이민자들이 정식 서류를 획득하여 미국 내를 자유롭게 이동하지 못하도록 방지해줄 것이라고 주장한다.

그러나 이 법을 반대하는 사람들은 국가 ID카드 및 국가 표준 규격의 데이터베이스를 만든다는 법 내용이 몇 년 전에 처음으로 제시되었을 때 이미 의회에서 거부당한 바 있기 때문에 무효라고 주장하고 있다.

2. 일본

일본은 유비쿼터스 환경에 대해 1980년대부터 사카무라젠 교수를 중심으로 독자적인 상품코드 체계 U-CODE를 개발하여 추진하였다. 또한 신기술정책인 u-japan을 실시하며, 2003년부터 개인정보보호 차원에서 RFID의 문제에 대해서도 준비하였다. 일본은 우리나라와 비슷한 가이드라인 방식을 채택하였다. 가이드라인 방식은 현존의 법 제도를 보완하는 의미에서 새로운 기술진입에 대해 지침, 가이드라인을 제시하는 정도로 대응하고, 이후에 기술적인 발전과 그로인한 역기능 등을 분석하여 모두 포괄하도록 하는 방식이다.

경제산업성과 총무성은 2004년 6월 8일, RFID 프라이버시에 관한 가이드라인인 “전자태그에 대한 프라이버시 보호 가이드라인”을 공동으로 정리하였다. 일본의 최종가이드라인 격인 동가이드라인은 경제산업성이 발표한 가이드라인을 기본으로 총무성의 의견이 추가되는 방식으로 작업되었다. 주로 개인정보를 RFID 태그에 입력할 경우가 추가된 것으로 알려졌다.

아래에서는 일본 경제산업성의 초안과 이후 총무성의 의견이 반영된 가이드라인을 살펴보도록 하겠다.

가. 일본 경제산업성의 초안

일본은 경제산업성이 주도하여 「상품 유통관리의 향상에 관한 연구회」(경제산업성 주최, 국토교통성, 농림수산업성, 후생 노동성이 참가)를 만들어 2003년 12월 22일에 RFID 기술에 관한 프라이버시 보호 가이드라인(안)을 정리하였고 2004년 1월 21일에 이를 발표하였다.

이후에 총무성의 가이드라인 제안과 혼동이 오자 총무성과 협동 작업을 하였다.

초기의 일본 경제산업성 가이드라인의 주요내용을 보면 다음과 같다.

- 대상사업자 정의 : 소비자에게 물품이 교부된 후에도 해당 물품에 RFID 태그를 장착해 두는 경우에는 해당 RFID 태그 및 해당 RFID 태그가 장착된 물품을 취급하는 사업자를 말한다. [제2조]
- 소비자에게 상품인계 후 태그가 남아있는 경우 : RFID 태그가 장착되어 있는 사실, 기억되고 있는 정보의 내용 등을 소비자에게 설명 혹은 게시하거나 또는 상품포장 상에 표시할 필요가 있다. [제3조]
- 소비자의 정보주체로서의 권한 : 소비자는 RFID 태그가 장착된 제품을 구매한 후 RFID 태그의 기능을 활성화시킬지 여부에 대한 선택권을 가지고 있다. [제4조]
- RFID 태그를 비활성화시키는 경우 : 사회적 이익이나 소비자 이익이 손상되는 경우가 있을 수 있다는 정보를 소비자에게 제공할 의무가 있다. [제5조]
- 다른 개인정보와 연결이 되었을 경우: 개인정보 데이터베이스와 RFID 태그의 정보를 연계하여 개인정보화가 되면 개인정보 보호법을 적용할 수 있다. [제6조]
- RFID 태그에 대한 정확한 전달 : RFID 태그의 이용목적, 성질, 그 이점 및 불리점 등에 대해 정보를 제공 한다. [제7조]
- 소비자와의 관계 : 사업자들이 추가적인 고려를 하도록 규정하여 사업자 자율규제 등을 할 수 있다. [제8조]
- 가이드라인의 수정 : 사회정세의 변화, 기술 진보 등에 따라 가이드라인은 수정할 수 있다. [제9조]

일본 경제산업성의 가이드라인에는 물품을 구매한 후의 RFID 태그에 관련한 규정이 있지만 물품을 구매하기 전의 RFID 태그에 관련한 규정은 없다. 이는 매장 안에서는 가이드라인이 적용되지 않는다고 해석할 수 있다.

또한 일본 경제산업성의 가이드라인은 RFID 태그의 판독을 막을 수 있는 구체적인 방안을 제시하고 있다. 예시에서 소개한 방안으로는 패러데이 케이지(Faraday Cage) 방식(알루미늄 막으로 판독기와 RFID 태그와의 통신을 차단하는 방법), Kill 태그 방식(일정구역을 넘어가면 비활성화시키는 방법), 태그자체를 제거하는 방식 등이 있다.

나. 경제산업성과 총무성의 협동에 의한 전자태그(IC태그)에 관한 프라이버시 보호 가이드라인

2004년 1월 경제산업성에서 비슷한 이름의 같은 내용이 담긴 가이드라인을 발표하였고, 총무성에서도 2004년 2월 23일 RFID 개인정보보호 가이드라인의 제정 필요성과 기본내용을 발표하였다. 같은 내용이 다른 이름의 이른바 ‘2중지침’으로 전달되어 혼란을 일으키자 이에 경제산업성과 총무성이 협력하여 2004년 6월 8일 RFID에 관한 프라이버시 보호 가이드라인을 발표하였다.³⁹⁾

다음은 전자태그 관련 프라이버시 보호 가이드라인을 정리한 표이다.⁴⁰⁾

[표 2-1] 전자태그 관련 프라이버시 보호 가이드라인

분류	내용
목적	● 전자태그의 활용 및 소비자 이익 보호의 조화
적용범위	● 소비자 거래에서의 전자태그와 전자태그를 활용하는 사업자
고지·표시	● 전자태그의 장착 사실, 장착 장소, 그 성질 및 보유 정보에 대한 고지 또는 표시
최종 선택권	● 전자태그 독해 방지 방안 고지 또는 표시 - 패러데이 케이지 방식 (알루미늄막으로 가리는 등 통신 차단) - 고유 번호 또는 모든 정보를 소거하는 방식 - 전자태그 자체 탈착 등

39) “일본, IT정책이 표류한다”. 전자신문 2004,4,8

40) 한국전산원, “NCA CIO REPORT”, 2004년 10월 15일(04-13호)

사회적 이익 등 정보제공	● 전자태그 폐지에 따라 상실되는 소비자 이익 또는 사회적 이익에 대한 정보 제공 - 재활용 정보 삭제로 야기되는 환경 문제 - 수리이력 정보 제거에 의한 자동차 안전 문제
개인정보와 전자태그정보의 결합	● 전자태그 정보와 개인정보가 결합하는 경우 개인정보 보호법상의 개인정보로 취급
정보의 수집, 이용 제한 및 정확성 확보	● 전자태그 내 개인정보의 목적 및 내용 대조를 통한 정확성, 최신성 유지 및 오기 방지 ● 전자태그 내 개인정보의 멸실, 훼손, 수정 및 누설 방지
정보 관리자	● 전자태그와 프라이버시 보호 관련 정보의 적절한 관리 및 불만의 신속하고 적절한 처리
소비자에 대한 정보 제공	● 전자태그와 프라이버시 보호에 관한 소비자 교육 실시

위에서 언급한 경제산업성 초안과의 비교를 하면 경제산업성 초안에는 IC 태그에는 ID와 상품의 종류 등을 입력할 뿐, 개인정보는 입력하지 않을 것으로 판단하고 작성하였다. 이러한 경우에는 Access 제어 프로그램, IC 태그의 암호화로 등 태그의 비용이 높아진다는 문제점이 발생할 수 있다. 그러나 총무성은 용도를 고려한다면 개인정보를 입력하는 것도 가능하다고 생각하여 본 가이드라인에 추가하였다.

개인정보에 대한 동의와 관련해서는 “사업자는 이용목적을 본인에게 통지하거나 공표해야 하며 목적 외 사용의 경우에는 본인의 동의를 얻도록 해야 한다”고 규정하고 있다. 이는 경제산업성 초안에 개인정보 취급에 대한 사전동의 조항이 없던 부분을 보완한 조항이기는 하지만 개인정보를 취급하는 경우 사전 통지나 공표하도록 하고 목적 외 사용에 대해서만 사전동의를 받도록 노력할 필요성이 있다고 규정하고 있는 것으로 보아 강제성이 강한 조항은 아닌 것으로 판단된다.

위의 표에서 고지 및 표시부분은 다음의 3가지 방법 중 하나를 선택하도록 되어 있다.

- 사람이 직접 설명한다.
- 점포에 포스터 등으로 게시한다.
- 상품 내지 또는 그 포장 자체에 표기한다.

가이드라인의 내용 중 고지관련에서 포스터의 경우에는 “소비자가 인식할 수 있도록 노력할 필요가 있다.”라는 내용이 들어 있다. 이는 소비자의 눈에 띄기 어려운

작은 게시를 방지하도록 하는 가이드라인이기도 하다.

정보수정과 관련한 조항도 새로이 추가되었는데 주된 내용은 다음과 같다.

- 사업자가 RFID 태그 내의 정보의 정확성을 유지하기 위한 노력이 필요하다.
[제8조]
- 개인정보보호법과 같이 정보의 적정한 관리 및 불평의 적절하고 신속한 처리를 위해 책임을 지는 정보 관리 책임자를 설치하고 연락처를 공표한다. [제9조]

본 가이드라인에는 2005년 4월에 시행되는 개인정보보호법을 준수하는 의무가 정해져 있고 개인정보보호법에 적용되지 않는 경우에 대한 룰도 제시하였다.⁴¹⁾

일본은 본 가이드라인을 ISO표준으로 이끌어 국제적인 표준의 역할을 하도록 노력하고 있다. 이는 일본의 가이드라인을 국제적 표준으로 이끌어, 주도권을 계속 행사하려는 움직임으로 판단된다.⁴²⁾

3. 유럽

EU는 개인정보에 관련된 보호방안을 통합적으로 제시한다. 이러한 EU의 개인정보보호방안은 민간부분, 공공부분, 온라인, 오프라인을 통합적으로 규제하는 방안으로 진행된다. 또한 입법체계의 통일성을 위하여 단일한 개인정보감독기구의 설치를 전제하는 경우가 많다.

가. 입법화

EU는 현재 RFID로 인해 수집되어 지는 개인정보들에 관한 보호를 위해서 존재하는 가이드라인과 방침들을 바탕으로 미국과 일본, CASPIAN의 입법사례에 주의를 기울이고 있는 중이다. 실제로 EU는 2005년 1월 중순부터 ‘Working Document 105’라는 연구그룹을 운영하고 있다.⁴³⁾

‘Working Document 105’는 같은 해 3월31일까지 이메일을 통해서 개별 소비자들

41) 개인정보보호법은 5000명 이상의 개인정보를 사용하는 사업자를 대상으로 하고 있으며, 본 가이드라인에서는 개인정보 건수와는 관계없이 사업자가 지켜야 할 룰을 제시하였다.

42) 정보통신정책연구원, “유비쿼터스 사회의 역기능에 관한 법제도적 기초연구”, 한국전산원, 2004년 12월

43) <<http://www.informationweek.com/story/showArticle.jhtml?articleID=59301363>>

로부터 개인정보보호를 포함한 RFID 전반에 걸친 의견을 수렴 받았다. 이 연구를 통해서 RFID의 잠재적인 시장인 비즈니스, 헬스케어, 의약분야, 물류수송분야에 걸쳐서 RFID의 태그와 리더기와 어플리케이션의 제작자들에게 방향을 제시해 주었다. 실제로 유럽에서는 전 대륙에 걸쳐 소비자를 보호하기 위한 프라이버시 관련법이 널리 적용되고 있다.

예를 들면 각 소매점들은

- RFID 태그가 제품에 부착되어 있다는 사실과 리더기가 설치되어있는가?
- 소매상들이 어떻게 개인정보를 수집하고 제어하는가?
- 이러한 개인정보들이 어떤 목적으로 사용되는가?
- 이러한 데이터들을 누가 제어하는가?
- 어떻게 제품에 달려있는 태그를 제거 시킬 수 있는가?
- 태그정보에 대한 접근허가권은 어떻게 부여되는가?

등에 관한 모든 사항을 소비자에게 공지하여야한다.

하지만 위와 같은 법률 외에 실제로 소비자가 쇼핑을 하게 되면서 발생하게 되는 RFID태그로 인한 위치추적에 관한 법률과 소비자 개인계좌와 연결되어 신용 카드처럼 사용될 수 있는 RFID기술이 접목된 플라스틱 카드 등에 관한 법률은 아직 입법화 되지 않았으며 현재 연구단계이다.

이러한 폭넓은 분야에 대한 법률이 아직 마련되어 있지 않기 때문에 ‘Working Document 105’는 ISO에서 지정한 표준인식프로토콜을 사용하여 데이터를 암호화하고 이를 통해 허가되지 않은 프로토콜은 사용할 수 없도록 하는 방안을 권장하고 있다.

나. 가이드라인

(1) RFID관련 사생활 및 정보 보호 가이드라인

2005년 7월 EU는 RFID 관련 사생활 침해 및 정보유출 가능성을 제기하고 이와 관련된 가이드라인을 발표하였다.⁴⁴⁾

본 가이드라인에서는 RFID를 이용하여 정보를 수집, 가공할 경우, 해당정보에 대한 개인의 동의를 구해야 한다는 것과 개인의 정보수집 및 가공과정에 대한 열람권을 부여해야 한다는 것을 제시하고 있으며 상기 동의 취소 시 RFID를 이용한 정보수집을 즉시 중지할 수 있는 방안모색을 촉구하고 있다.

44) IDC News Service, 2005. 2. 22. 참조

EU는 RFID기술이 정부 및 민간부문에 사용될 경우 정보보호 침해 가능성이 존재함을 지적하면서 EU의 실행기관인 EC(European Commission)는 ‘Article 29 Working Paper’(2005.1.19)를⁴⁵⁾ 통해 RFID와 관련된 사생활 침해 및 정보보호에 관한 안전 검토결과를 밝혔다. 또한 특정인과 관련된 수많은 정보들을 취합, 정리할 수 있는 RFID의 특성 때문에 특별히 RFID와 관련된 사생활 침해 이슈가 제기되고 있다는 것을 밝혔다.

EU에서 발표한 RFID관련 사생활 및 정보 보호 가이드라인은 다음과 같다

- RFID태그가 사용되는 경우 해당 개인의 암묵적 동의를 구하여야 하며 RFID의 부착위치 및 상태 및 RFID를 통해 어떤 정보가 수집, 처리되는지 등의 소위 정보객체에 관한 명확한 정보를 해당 개인에게 제공하여야 함
- RFID를 사용하는 기업 또는 정부는 객체로서의 개인들에게 RFID를 통해 얻게 된 정보의 정확성을 확인할 권리 및 수집, 가공되는 개인정보들에 대한 포괄적인 열람권을 권고
- RFID 생산자 또는 기술개발자들은 개인들의 정보공개 승인 취소의 경우에 신속하게 RFID에 의한 정보수집을 중지할 수 있는 방안을 모색하여야 함

이처럼 EU가 RFID 관련 사생활 보호 및 정보보호에 관한 가이드라인을 발표한 것은 RFID의 시장 전개추이를 고려할 때, 대기업뿐만 아니라 중소기업 또는 개인들까지도 RFID를 사용할 것이라는 전망에 따라 이용자 보호가 시급하다는 판단에 기초하여 발표한 것이다.

(2) 식품추적 관련 가이드라인

2005년 2월 EU는 식품시장 전역에 걸쳐서 식품추적활용에 관한 새로운 가이드라인을 발표하였다.⁴⁶⁾ 이 가이드라인은 2005년 1월1일부터 발효된 식품표준법에 따른 것이다. EU회원국들의 대표자들로 구성된 식품 공급망과 동물보호 상임위원회는 이러한 공통적인 가이드라인이 모든 회원국 사이에 보다 쉽게 적용될 것을 기대하였다.

가이드라인에 명시된 주요 요구사항으로는 식품의 추적, 시장에서의 위험 식품 제거, 수입과 수출에 필요한 책임과 요구에 관한 사항들을 포함하고 있다. 이러한 의

45) EC는 개인정보의 자동처리와 관련된 개인의 보호를 위한 유럽회의 지침(Directive 95/46/EC)의 제29조에 의하여 설립되었다.

46) <<http://www.idtechex.com/products/en/articles/00000221.asp>>

무적인 추적은 식품 및 동물사료, 가축과 모든 종류의 식품 공급망에 예외 없이 적용되어 진다. 이것은 생산부문에서부터 운송, 저장, 분배, 그리고 소매를 통한 소비자에 이르기까지 모든 범위에서의 적용을 의미한다.

본 가이드라인에서는 생산자의 이름, 생산지의 주소, 제품의 특징과 재배 및 출하일 등이 각 단계별 추적시스템에서 등록되어야 하며, 이러한 정보들은 5년간 필요에 의해 보관되어져야 한다고 명시하고 있다.

이러한 가이드라인에 관하여 현재 영국의 테스코, 프랑스의 까르푸, 독일의 메트로 등과 같은 대형소매상들은 RFID 정착을 위해 기술적인 문제해결을 위하여 부단히 노력하고 있다.

(3) 이전의 개인정보관련 가이드라인

1995년 10월 유럽의회와 유럽이사회는 일반적인 개인정보 취급에 대한 규정으로 회원국 국민의 기본권과 자유를 보호하고 개인정보 처리와 관련한 프라이버시권을 보호하여 EU 국가간의 개인정보의 자유로운 유통을 촉진하기 위하여, ‘개인데이터의 처리와 개인데이터의 자유로운 유통에 관련된 개인정보가이드라인’을 발표하였다.⁴⁷⁾

이 가이드라인은 1998년 10월까지 회원국으로 하여금 지침에 적합하게 자국의 프라이버시 법을 개정할 것을 요구하고 있으며, 개인정보의 수집, 관리, 이용활동 등을 조사 및 감독할 수 있는 독립적인 감독기구를 설치하도록 의무화 하고 있다. 또한 이러한 지침을 보호해 주지 않는 국가는 개인자료의 이전을 금지하고 있으므로 회원국과 교섭하고 있는 비회원국 역시 프라이버시법의 개정 및 수정에 변화를 시켜야한다는 요구를 받고 있다. 그 결과 2000년 7월 미국, 스위스, 헝가리가 적절한 수준으로 개인정보를 보호하고 있음을 인정하였다.

1997년 12월에는 1995년에 제정한 가이드라인을 보완하여 개인데이터의 처리와 관련한 기본적인 인권과 자유, 특히 프라이버시권의 균등한 보호수준을 보장하고 EU에서 데이터와 통신설비 및 서비스의 자유로운 이동이 보장되도록 회원국의 규정의 조화를 제공하기 위하여 ‘정보통신부문에서의 개인정보 처리 및 프라이버시 보호에 관한 가이드라인’을 채택하였다.

또한 1999년에는 인터넷에서의 프라이버시 보호를 위한 ‘정보고속도로에서 신상정보의 수집처리와 관련한 개인의 보호를 위한 가이드라인’을 채택하고 있다. 이 가이드라인에서는 이용자가 사이트를 방문하여 요청할 때 데이터를 어떻게 보관, 수집,

47) 한국전산원, “2001한국인터넷백서” 제 4 장 개인정보침해 p329, 2001

처리하는지 이용자에게 알려주는 등의 프라이버시 보호 실무에 관한 선언문을 게시하도록 권고하고 있다.

다. RFID 개인정보보호 관련한 Issues

EU의 Article 29 Data Protection Working Party(유럽회의 지침 제 29조 데이터 보호 실무작업반, 이하 WP로 씀.)에서는 기술적 이슈 중 하나로 RFID를 다루고 있다.⁴⁸⁾

EU 각 나라별로는 프라이버시와 관련된 시민단체들이 활동하고 있고, RFID입법안을 만들 것을 요구하고 있다. 영국에서는 2003년 초부터 소비자 관련 이슈로 인식하고, 2004년 2월 이해관계자 대표회의를 마련하고⁴⁹⁾ ‘calling in the chip?’라는 RFID 관련보고서를 작성하였다.⁵⁰⁾ 이 자료에는 회의에서 나온 6개의 권고사항과 RFID 기술 소개, RFID 기술의 소비자 사용사례, RFID 기술발전과 소비자에 미치는 영향, 소비자에 대한 잠재적 위협, RFID 기술의 편리성이 소비자 위험을 증가하는지 등의 향후 논점 사항 등을 담고 있다.

권고사항에서는 토론 내용에 대해 NCC가 일정한 입장을 표명하는 식으로 표현되어 있다. 법제도적인 측면에서는 현재의 규제가 RFID 응용에 소비자 보호가 적용될 수 있는지에 대한 검토를 요구하고, 다른 규제의 원칙을 가진 다른 나라에서의 사용에 대한 조사를 강력하게 요구하였다. 또한 국제적인 공조의 필요성을 제기하면서 WP에서 유럽지역에 적용될 가이드라인을 제시할 것과 OECD가 국제적인 수준의 해결방안을 내는 것의 중요함을 지적하고 있다.

자율규제에 대해서는 그 동안의 자율규제가 문제점이 있음을 지적하면서 자율 규제로는 한계가 있으므로, 프라이버시 보호차원의 법적인 규제가 필요함을 제기하였다. 한편 영국의 한 시민단체에서는 RFID의 입법과 관련해 두 가지 관점을 제시하고 있다.

첫째는 미국과 같은 신규입법을 하는 방안과, 둘째는 컴퓨터 관련 기존 법들에 의해 수용될 수 없는가 하는 점이다. 두 번째 관점에서 소비자 수준의 RFID태그들과 관련한 RFID 프라이버시 이슈 해결책 중의 가능한 방법은 RFID태그 칩을 컴퓨터로 보는 것이다. 이 경우 영국 컴퓨터 부정 사용법 제 1 장의 ‘무권한 접속

48) <http://europa.eu.int/comm/justice_home/fsj/privacy/docs/rfid/rsa-security-usa_en.pdf>참조

49) 이 자리에서는 얼마나 넓게 기술이 사용될지, 어떻게 사용될지, 소비자에 대한 잠재적인 이익과 위험이 어느 정도인지에 대해 고려하였다. 이를 위한 준비 자료로서 ‘소매상에서의 RFID기술’에 대한 브리핑 자료를 만들었다. <<http://www.ncc.drg.uk/pubs/rfid.pdf>>

50) <http://www.ncc.org.uk/pubs/pdf/calling_in_chips.pdf>

(unauthorised access)'과 '영국 데이터 보호법(UK Data Protection Act)'이 이 시스템에 적용될 수 있다. 데이터보호법 하의 개인데이터(personal data)는 다른 컴퓨터 기록 또는 데이터베이스 시스템에서 참조하는 데 사용될 수 있는 단순 일련번호를 포함한다. 특히 소비자 동의를 포함하고 있는 데이터 보호 원칙이 적용될 필요성이 있다.

또한 WP에서 지적 재산권보호와 관련하여 RFID 개인 정보 보호에 대해 발표하였다. WP는 지적소유권을 가진 사람들의 정당한 이익을 범죄로부터 보호하기 위한 필요성을 제기하면서 개인적인 자료처리에 관해서도 기준을 적용시켜야 한다고 강조하면서 개인정보보호를 위하여 취해진 합법적 기준들이 오히려 개인적인 자료를 침해받을 수 있다는 것에 대하여 우려한다. 이에 대하여 WP는 인터넷 상에서 이루어 질 수 있는 지적 재산권 침해에 관해 2가지 방식의 효과적인 보호책을 제시하였다.

첫 번째는 DRM(Digital Rights Management) 수단의 발달이고, 두 번째는 저작권을 가진 사람과 관련하여 RFID 개인 정보 보호에 대해 발표하였다.

수집되고 처리되는 개인 정보가 실제 지적 재산권을 소유하고 있는 자의 것인지를 구분해 내는 것에 관한 사항이다.

또한 DRM에 관하여 WP는 RFID 태그를 통해 정보를 교환하거나 다운로드하면서 발생하는 합법적인 정보의 이용에 중점을 두고 컴퓨터 플랫폼을 통해서 연관되거나 접근할 수 있는 신뢰성 있는 정보를 가진 산업 프로젝트의 저작권에 대한 원거리 조회의 잠재적인 실용성을 암시하고 있다. 이에 대해 WP는 인터넷을 통한 익명거래와 사용자의 익명성을 방지하는 수단을 갖춘 DRM기술에 대한 반대를 허용할 필요성이 있다고 강조했다.

제2절 주요 국제기구의 가이드라인

가이드라인 보호방안은 개인정보 침해 사례가 급속도로 대두됨에 따라 국가의 중요한 과제로 떠올랐다. RFID 프라이버시 (개인정보) 가이드라인은 각국마다 다른 특성을 보이고 있다. 각국의 개인정보보호 가이드라인은 1980년도에 제정한 OECD의 가이드라인과 UN의 가이드라인을 시점으로 발전되어 온 형태이다. 따라서 본 절에서는 OECD, UN, APEC등 국제기구들의 개인정보보호(프라이버시) 가이드라인에 대해 설명하겠다.

1. OECD의 프라이버시 가이드라인

프라이버시와 관련된 가이드라인을 가장 먼저 제안한 국제기구는 OECD이다. OECD는 1977년 9월 ‘TBDF에 대한 1차 심포지움(the first symposium on Transborder Data Flows)’을 개최하였다. 심포지움에서 OECD기구는 개인정보의 보호에 관한 국가 간의 규제와 정보유통 등에 관하여 논의한 후 1980년 9월 23일에 개인정보보호에 관련된 국제적인 기준으로서의 가이드라인 ‘프라이버시보호 및 개인정보의 국가 간의 유통에 관한 지침(Guidelines on the protection of privacy and transborder flows of personal data, 이하 OECD 가이드라인)’을 채택하였다.⁵¹⁾

OECD 가이드라인은 총 5장으로 구성되었으며, 제1장은 총칙, 제2장은 국내적용상의 기본원칙, 제3장은 국제적 적용상의 기본원칙, 제4장은 국내실시, 제5장은 국제협력으로 구성되어 있다.⁵²⁾

이 가이드라인 중 회원국에게 권고하는 최소한의 규정으로 발표된 국내 적용에 있어서의 개인정보보호의 8개 원칙은 개인정보보호 관련법과 제도 및 지침의 모델이 되어 EU지침을 비롯한 각국 및 민간부문에서도 광범위하게 받아들여지게 되었다.

다음은 OECD 가이드라인의 이사회 권고안과 8원칙에 대해 알아보겠다.

가. 권고안

OECD 이사회는 권고안을 마련하기 전에 회원국들 사이에 다음과 같은 사항을 인정하도록 합의하였다.

[표 2-2] OECD 이사회의 합의안

합의안	
1	국가별로 법률과 정책이 서로 다르다 할지라도 프라이버시와 개인 권리를 보호하는 것과 프라이버시와 개인정보유통과 같은 기본적인면서도 경쟁적인 관계에 있는 가치들을 조정하는 것이 회원국들의 관심사이다.
2	개인정보의 처리자동화 및 국가 간 유통은 새로운 형태의 국가 대 국가관계를 형성한다. 그리고 상호호환성이 있는 규칙 및 원칙의 개발을 필요로 한다.

51) 여기서 개인정보란 해당 개인을 알아볼 수 있는 이름, 주민등록번호 등의 부호, 문자, 음성, 영상 등의 정보 일체와 개인의 생활, 활동, 직무수행에 대한 정보를 의미한다.

52) “주요국의 개인신용정보보호법제”, 법무부, 1999

3	개인정보의 국가 간 유통은 경제 및 사회발전에 기여한다.
4	프라이버시보호 및 개인정보의 국가 간 유통은 경제 및 사회 발전에 기여한다.

이러한 사항을 인정한 후 회원국들 사이에서 불합리적인 장애가 발생되지 않도록 결의하였고, 다음과 같은 내용을 권고하였다.

[표 2-3] OECD의 권고안

권고안	
1	회원국들은 국내에서의 법률제정에 있어 이 권고안을 부록으로 첨가된 가이드라인에서 규정하고 있는 프라이버시보호 및 개인의 권리에 관한 원칙을 고려한다.
2	회원국들은 프라이버시 보호라는 명분하에 개인정보의 국가 간 유통시 장애요인이 발생되지 않도록 노력하며, 그러한 장애요인을 제거하기 위해 노력한다.
3	회원국들은 부록에서 규정하고 있는 가이드라인을 실행하는데 협력한다.
4	회원국들은 이 가이드라인의 적용을 위한 특정한 자문 및 협력절차에 대하여 가능한 빠른 시일 내에 합의를 구축한다.

위와 같은 권고안을 통해 OECD 회원국들은 OECD 가이드라인을 최대한 고려하였다.

나. 가이드라인

가이드라인은 크게 국내적용의 기본 8원칙과 국제적용의 기본 원칙으로 이루어졌다. 다음은 국내적용의 기본 8원칙이다.

[표 2-4] OECD 가이드라인 8원칙⁵³⁾

수집제한의 원칙 (Collection Limitation Principle)	개인정보의 수집은 합법적이고 공정한 절차에 의하고, 가능한 한 정보주체에게 알리거나 동의를 얻은 후에 해야 한다.
---	---

53) “주요국의 개인신용정보보호법제”, 법무부, 1999

정보내용 정확성의 원칙 (Data Quality Principle)	개인정보는 그 이용목적에 부합하는 것이어야 하며, 이용목적에 필요한 범위 내에서 정확하고 완전하며 최신의 것이어야 한다.
목적명확화의 원칙 (Purpose Specification Principle)	개인정보는 수집 시까지 그 수집목적이 명백히 되어야 하며, 그 후의 이용은 수집목적의 실현 또는 수집목적과 양립되어야 하고 목적이 변경될 때마다 명확히 되어야 한다.
이용제한의 원칙 (Use Limitation Principle)	개인정보는 목적명확화의 원칙에 의하여 확인된 목적 이외의 다른 목적을 위하여 개시, 이용, 그 밖의 사용에 제공되어서는 안 된다. 다만 정보주체의 동의가 있거나 법률의 규정에 의한 경우에는 예외이다.
안전보호의 원칙 (Security Safeguards Principle)	개인정보는 분실 또는 불법적인 접근·사용·훼손·변조·개시 등의 위험에 대하여 합리적인 안전조치를 함으로써 보호해야 한다.
공개성의 원칙 (openness Principle)	개인정보의 처리와 관련된 정보처리 장치의 설치·활용과 관련정책은 일반에 공개하여야 한다. 또한 개인정보의 존재·성질·주요 이용목적 및 정보관리자를 식별하고, 그 주소를 명확하게 하기 위한 수단을 쉽게 이용할 수 있어야 한다.
개인참가의 원칙 (Individual Participation Principle)	개인은 자기에 관한 정보의 소재를 확인할 권리를 가지며, 필요한 경우에는 자신에 관한 정보를 합리적인 기간 내에 합리적인 비용과 방법에 의해 알기 쉬운 형태로 통지받을 권리를 가진다. 이러한 권리가 거부된 경우에 개인은 그 이유를 요구하고 거부에 대하여 이의를 제기하거나 정보의 폐기·정정보완을 청구할 권리를 가진다.
책임의 원칙 (Accountability Principle)	정보관리자는 위의 원칙들을 실시하기 위한 조치에 따를 책임이 있다.

다음은 국제적용의 기본원칙이다.

[표 2-5] OECD 가이드라인 국제적용

1	회원국들은 개인정보처리 및 재수출이 다른 회원국들에게 미치는 영향을 고려한다.
---	---

2	회원국들은 회원국을 경유한 유통을 포함하여 개인정보의 국가 간 유통이 장애요소 없이 안전하게 이루어지도록 보장할 수 있는 적절한 모든 조치를 취하여야 한다.
3	회원국들은 자국과 다른 회원국 사이에서 이루어지는 개인정보의 국가 간 유통의 제한을 삼가되, 다른 회원국이 아직 이 가이드라인을 본격적으로 이행하고 있지 않거나 그러한 정보의 재수출이 그 나라의 프라이버시 관련법에 위배되는 경우는 예외로 한다.
4	회원국들은 프라이버시 및 개인의 권리보호라는 명분하에 그러한 보호의무 한도를 넘어 개인정보의 국가 간 유통에 장애요소가 되는 법률, 정책 및 실무의 개발을 피해야 한다.

위의 원칙들은 개인정보를 수집하고 이용할 때 반드시 정보 주체에게 동의를 받아야 하고 동의를 받을 때는 그 정확한 수집과 이용 목적을 명시해야 한다는 점을 강조한다. 이는 개인정보에 대한 권리가 국민에게 있다는 것을 의미한다는 점에서 인권을 중요하게 생각한 것으로 판단된다.

2. UN 가이드라인

OECD 가이드라인이 발표된 후에 회원국을 포함한 많은 국가들에서는 개인정보 보호를 위한 법과 가이드라인, 기구 등을 제정하였다. UN 또한 1990년에 ‘컴퓨터화된 개인정보파일의 규율에 관한 지침(Guidelines for the Regulation of Computerized Personal data files, 1990)’을 채택하였다. 특히 ‘비차별의 원칙’을 두고 불법적이고 임의적인 차별을 유발할 수 있는 데이터(조합이나 단체 가입사항 뿐 아니라 인종, 민족, 종교, 철학적인 정보를 의미)는 수집되어서는 안 된다고 명시하였다.

다음의 표는 가이드라인의 내용이다.

[표 2-6] UN의 가이드라인

합법성과 공정성의 원칙 (Principle of Lawfulness and	개인에 관한 정보는 합법적인 방법으로 수집되고 처리되어야 하며, UN헌장에 명시된
--	---

Fairness)	목적에 위배되어서는 안 된다.
정확성의 원칙 (Principle of Accuracy)	정보를 수집·저장하는 사람 및 이에 대한 책임이 있는 담당자는 정기적으로 개인정보를 점검하여 수록된 정보가 정확한 것인지를 검토하여야 한다.
자기구체화의 원리 (Principle of the Propose Specification)	개인정보를 수집·처리하는 목적은 구체적이고 정당해야 한다. 그러므로 수집·저장되는 모든 개인정보는 구체화된 목적과 관련되어야 하며, 이러한 개인정보는 관련 개인의 동의 없이는 사용되거나 공개되어서는 안 된다. 또한 수집된 개인정보는 구체화된 목적을 위해서 필요한 기간의 한도를 넘어서 저장되어서는 안 된다.
관련개인의 접근 원칙 (Principle of Interested Person Access)	정보가 수집·저장된 관련 개인은 그 정보가 어떻게 처리되며 사용되는 지에 대하여 알권리를 가지고 있다. 또한 정확하지 못한 정보의 삭제권 등 여러 가지의 보호권리들이 관련 개인에게 제공되어야 한다.
비차별의 원칙 (Principle of Nondiscrimination)	개인 관련 정보의 주체는 종교, 인종, 성별이나 정치적 견해 등을 이유로 부당한 차별이나 자의적인 차별을 받아서는 안 된다.
예외결정권한 (Power to make Exceptions)	앞에서 열거한 원칙의 예외가 인정되는 경우로는 국가안전보장, 타인의 자유와 권리의 보호 및 반인류적 범죄를 저지른 범인의 추적과 같이 그 목적과 근거가 국내법의 절차에 따라서 정당하게 제정된 법 규정에 구체화된 경우에 인정할 수 있다.
보안의 원칙 (Principle of Security)	자연재해나 컴퓨터 바이러스 또는 권한 없는 접속 등으로부터 개인정보 파일을 보호하기 위한 적절한 조치들을 취해야 한다.
감독과 재판	모든 국가들은 열거한 원칙의 준수를 보장

(Supervision and Sanctions)	하기 위하여 독립된 감독기관을 설치해야 한다. 또한 이러한 원칙을 위반할 경우에 대비하여 처벌규정과 개인정보보호 규정을 만들어야 한다.
국제정보유통 (Transborder Data Flows)	개인정보가 국제적으로 유통될 시 관련 국가들이 사생활 보호에 관한 충분한 보호대책을 마련하고 있다면 정보는 가능한 한 자유롭게 전달, 처리될 수 있어야 한다.
적용범위 (Filed of application)	이와 같은 원칙들은 모든 공적 및 사적 기관들에 적용되어야 하며 컴퓨터파일 뿐 아니라 수작업파일도 적용대상에 포함된다.

3. APEC

APEC은 다른 국제기구보다는 개인정보 및 프라이버시 보호를 위한 노력이 적었다. 그러나 현재 APEC에서의 Working Group인 ECSG에서 프라이버시 포럼을 연례적으로 개최하면서 프라이버시 보호의 개선을 촉구하고 있다. 다음의 표는 APEC의 프라이버시 관련 내용이다.

[표 2-7] APEC Privacy Principle⁵⁴⁾

원칙	주요내용
침해방지	수집된 개인정보의 오용으로 인한 피해를 막기 위해 개인정보가 이루어져야 한다. 그러한 개인정보가 오용된 경우 야기될 수 있는 피해를 인지하고, 그러한 위험을 피할 수 있도록 조치를 취해야 하고, 그러한 피해의 심각성과 가능성의 정도에 비례하여 시정조치가 이루어져야 한다.
수집제한	개인정보 수집이 제한되어야 하고, 합법적이고 공정한 수단에 의해 수집되어진 정보들은 개인의 동의를 얻지 않은 경우

54) APEC ECSG 2004년 10번째 Draft Version 참조

	목적에 반하여 사용되어서는 안 된다.
이용	개인정보 이용은 수집목적에 부합해 이루어져야 하고, 수집되어진 개인정보는 정보주체의 동의가 있거나, 정보주체의 요청에 의한 재화나 용역을 제공하기 위하여 필요한 경우, 법률에 의한 경우를 제외하고는 목적에 반하여 사용되어서는 안 된다.
동의	정보의 수집·이용·공개 등과 관련하여 정보주체가 선택권을 행사할 수 있도록, 적절하면서도 명확히 이해할 수 있고, 접근가능한 방법이 정보주체에게 주어져야 한다.
고지	개인정보관리자는 다음의 내용을 포함하여 정보주체에게 명료하게 그들의 정책과 실행 행태에 대한 정보를 제공한다. ● 정보가 수집되고 있다는 사실 ● 수집 목적 ● 정보 공유가 가능한 개인이나 조직의 행태 ● 개인 정보 관리자의 신원과 위치, 정보주체가 그들의 개인정보의 처리가 관련해 문의할 수 있는 연락처 ● 정보주체가 그들의 개인정보의 사용 및 유출에 대해 행사할 수 있도록 개인정보관리자가 제공하는 선택 및 수단 ● 정보열람권 및 정보정정권 위의 정보는 개인정보가 수집되어지는 순간이나 그 이전에 명시되어야 하며, 불가피하게 그러지 못했을 경우 가장 빠른 시간 안에 제공해야 한다.
정확성	개인정보는 정확하고 완전하고 최신성을 유지해야 한다.
안전성	개인정보관리자는 보유하고 있는 개인정보의 손실, 허가받지 않은 접근, 파괴, 수정, 혹은 오용을 방지하기 위해 적절한 보안수단을 제공해야 한다. 그러한 보안수단은 발생 가능한 위험의 정도와 비례해 이루어져야 하고, 보유하고 있는 내용은 정기적인 검토와 평가를 받아야 한다.
정보열람권	개인은 정보관리자가 보유하고 있는 자신의 정보의 열람이 가능해야 한다. 정보관리자는 부정확한 정보를 수정하거나 삭제해야 한다. 정보주체는 그러한 정보열람이 비합리적인 비용과 노력을 소요하는 경우나 혹은 법, 보안 및 상업적인

	이윤과 관련한 이유로 인해 유출되어서는 안 되는 경우를 제외하고는 정보열람권을 요구할 수 있다.
책임	정보관리자는 위에서 언급한 원칙을 순응해야 할 책임이 있다. 개인정보가 다른 제 3자나 조직에 이전되었을 경우, 국내적으로나 국제적으로나, 정보관리자는 정보수령자나 조직이 이러한 원칙들에 의거해 정보보호를 할 수 있도록 보장하기 위한 필요한 조치 및 의무를 이행해야 한다.

4. 그 외 관련기관 및 시민단체 현황

가. CASPIAN

CASPIAN(Consumer Against Supermarket Privacy Invasion And Numbering)은 1999년에 캐더린 앨브레히트(Katherine Albrecht)등이 설립한 단체이다. 초기에는 소매점에서 도입하는 카드를 가지게 하여 고객 쇼핑요금을 할인해주는 시스템은 개인구매, 정보에 연계해 축적할 수 있으므로, 사생활 침해에 해당한다고 주장하는 단체였으나 이후에 IC 태그의 사생활 침해 문제까지 확장되었다.



[그림 2-1] CASPIAN의 창시자 캐더린 앨브레히트와 로고

이들은 2003년 6월 11일 'RFID 알권리법안'을 제안하고 2003년 8월 캘리포니아 의원들을 상대로 RFID 프라이버시 위험과 이슈에 대한 설명회를 개최하였다.

위에서 제안한 RFID 알권리법안에 대해 간단하게 언급을 하자면, 다음과 같은 내용으로 이루어졌다.

[표 2-8] CASPIAN 의 알권리 법안 제안 내용

주요 내용	
제 1 장	법안의 이름 규정
제 2 장 ~ 제 5장	음식,약품,화장품,알코올,담배에 RFID 태그를 장착한 경우 이를 고지하는 표기부착을 해야 한다는 내용
제 6 장	소비자의 프라이버시를 보호하기 위해 사업자에게 요구하는 사항

2003년 11월 15일 미국 보스턴에서 미국 메사추세츠 미디어 연구소 등의 주최로 열린 ‘RFID 사생활 워크숍’에서는 AUTO ID, CASPIAN, 벤더 등이 토론을 전개하였다. 이때 KILL태그를 통한 대책에 대한 토론을 전개하였다. 여기서 CASPIAN은 KILL태그 자체로 소비자 행동이력이 기록되는 것을 막을 수 없다고 지적하고 반대를 표명하였다.

그러나 CASPIAN은 SCM 강화를 위한 RFID 도입은 반대가 아니라고 하였다. 이들은 진열대 상품에 달린 IC 태그를 반대하는 것이며, 복제품이나 위조 방지를 위한 IC 태그는 허락하고 있다. 예를 들면, 고액의 의약품, 명품 등의 제품에 RFID 태그를 도입해 위조품을 방지할 수 있을 것이라고 기대하고 있다.

나. EPCglobal

RFID 태그를 이용한 유통, 상품관리 등을 위해 Auto ID를 중심으로 국방성, 북미 지역코드관리기관(UCC: Uniform Code Council)등 여러 업체들이 협력으로 설립한 EPCglobal은 전세계 RFID 상용화와 기술개발을 주도하고 있는 단체이다.

원래 RFID 연구개발이 중심이던 EPCglobal은 현재 EPCglobal 네트워크 구축과 RFID 마케팅을 중점으로 방향을 변화하였다. 현재 EPCglobal은 40개 국가와 100여개 업체가 가입한 세계 최대 규모의 RFID단체이다.



[그림 2-2] EPC Global

EPCglobal은 내부에 공공정책조정 위원회(Public Policy Steering Committee)를 구성하여 RFID 프라이버시에 관한 자발적 가이드라인 (Guidelines on EPC for Consumer Products, 이하 ‘EPC Global 가이드라인’)을 제시하였다. 다음은 EPCglobal 가이드라인의 번역내용이다.

Guidelines on EPC for Consumer Products

Introduction

Electronic Product Code™(EPC)는 소비자 제품의 자동식별을 위하여 Radio Frequency Identification (RFID) 기술을 사용하는 가장 최신의 시스템이다.

RFID는 현재 매우 다양한 목적으로 자동차에서부터 보안 패스 카드에 이르기까지 모든 곳에서 사용되고 있다. 이러한 광범위한 사용범위 중 한 예로 미국의 EZ Pass와 프랑스의 Liber-T 같이 고속도로 톨 게이트 부스를 신속하게 통과할 수 있도록 하는 장치를 들 수 있다.

Benefits

EPC는 공장에서 물류 센터와 도매상에 이르는 공급망 상의 다양한 소비제품들에 사용될 수 있다. EPC가 발전함에 따라 소비자와 기업에게 매우 중대한 이익을 제공할 것이다. 공급망 상에서의 향상된 제품 정보는 제품이 진열대까지 도달하는 시간을 줄여주고 제품의 소비량에 따라 필요로 하는 제품의 양에 관한 정보를 유용하게 이용할 수 있도록 해준다. 유통기간이 지난 제품의 제거가 용이해지고 반송품의 제거도 쉽게 이루어지도록 해준다.

Privacy

EPC가 소비자, 소매상, 공급자 사이에서 상용화되기 위해서는 현재의 기술 수준에서 제기되고 있는 프라이버시 관련 문제를 해결해야한다. 따라서 EPC의 스폰서들은 큰 규모의 EPC 개발에 참여하는 모든 기업에게 다음의 가이드라인을 따르도록 하고 있다.

본 가이드라인은 국내/국제적으로 소비자 보호, 소비자 프라이버시와 이에 관련된 이슈들에 관한 현실적이고 포괄적인 법을 기반으로 모든 기업의 수용을 가능하도록 한다. 이 가이드라인은 산업 사회의 책임과 소비자들에게 정확한 정보를 제공하여 소비자들의 선택을 보장하는 것에 관한 기본 사항이고 앞으로도 기초가 될 것이다.

Evolution

EPC가 새롭게 개발되고 이에 대한 사용이 일어날 때마다 이 가이드라인은 소비자들을

위한 산업의 기초적 책임을 기반으로 지속적으로 발전될 것이다. 기술의 발전, 새로운 장치들과 강화되어진 구매 후 이윤에 관한 EPC의 발전은 EPC 태그의 사용에 있어 소비자와 기업 모두에 더 다양한 선택을 제공하게 될 것이다. EPCglobal의 스폰서들은 EPC 기술과 정책 모두의 책임감 있고 효율적인 개발을 위해 지속적으로 지원과 노력을 기울여야 한다.

Administration

본 가이드라인은 EPCglobal에 의하여 시행되어진다. EPCglobal은 GS1(이전에 EAN)과 GS1 US™(이전의 Uniform Code Council)의 합작 기업이다.

또한 GS1은 소비제품에 사용되고 있는 제품 코드에 관한 표준 규격을 지정하고 유지한다. EPCglobal 역시 이 가이드라인을 업데이트할 책임이 있다. EPC가 폭넓은 지지층을 얻기 위해서는 소비자들이 EPC를 사용에 관한 가치와 이익, 그리고 무결함을 신뢰할 수 있어야 한다. EPC 관계자들은 이러한 대중의 신뢰를 얻고 지속시키도록 노력해야 한다. EPCglobal은 본 가이드라인의 올바른 사용 여부에 관하여 모니터링 해야 하고 가이드라인을 업데이트할 책임을 지닌다.

초기 개발단계부터 EPC는 최신기술이었기 때문에 가이드라인의 보충이나 수정은 장비가 발전되고 사용됨에 따라 이루어지게 될 것이다. 예를 들어 기술의 발전이나 기술의 사용이 기존의 바코드 기술보다 EPC 태그를 제어하거나 소비자의 개인 정보 기록을 용이하게 할 경우 이에 관한 내용을 소비자에게 알리도록 해야 하는 변화가 있어야 하고 가이드라인 자체도 적절하게 바뀌어야 할 것이다.

EPCglobal Guidelines on EPC for Consumer Products

본 가이드라인의 목적은 소비제품에 EPC 기술을 사용함에 있어 책임의 기반을 제공하는 것이다. EPCglobal의 원조 아래 2005년 1월 1일 제정된 이래로 이 가이드라인은 EPC와 관련 장비가 발전하고 소비자 조사가 이루어짐에 따라 지속적으로 발전될 것이다. EPC가 발전되어질 때 그것은 꽤 좋은 새로운 이슈들이 되었다. EPC 관계자들은 이러한 이슈를 해결하고 이에 대하여 관련 정당들과 대화할 수 있도록 한다.

1. Consumer Notice

소비자는 제품이나 포장에서 EPC의 존재를 알리는 경고문을 제공 받게 되고 EPC 기술의 사용 여부에 관한 정보를 제공받게 된다. 이 경고는 제품이나 포장상의 EPC 로고나 식별자의 사용을 통해 이루어진다.

2. Consumer Choice

소비자는 구매하려는 제품에 부착된 EPC 태그들을 제거하거나 현재 또는 미래에 비활성

시킬 수 있는 선택권을 가진다. 대부분의 제품에는 EPC 태그들이 제거가 가능한 포장에 부착되어 있거나 자체적으로 비활성화가 가능한 형태로 되어있다. 기술 분야의 여러 지원자들 사이에서 EPCglobal은 소비자의 폭넓은 선택을 위해 부가적인 효율성, 효과적인 비용, 그리고 보다 신뢰성 있는 대안을 제시해야 한다.

3. Consumer Education

소비자는 EPC와 관련 장비들, 관련 기술 향상에 관한 최신 정보를 쉽게 접할 수 있어야 한다. 소비자 수준에서 EPC 태그를 사용하는 기업은 소비자들이 EPC 로고에 대한 친숙함을 갖게 하고 EPC 기술 자체와 이를 통해 얻을 수 있는 이익에 대한 이해를 돕기 위하여 적절한 노력을 기울여야 한다. 또한 EPCglobal은 기업과 소비자 모두에게 이 가이드라인과 상반되는 EPC 사용에 대한 인식과 해결을 위한 화합의 장이 되어야 한다.

4. Record Use, Retention and Security

EPC는 어떠한 개인 신상 정보도 포함하거나 수집 또는 저장하지 않는다. EPC와 관련된 기존의 바코드 기술의 데이터는 EPCglobal사 주관으로 적절한 법률에 의거해 수집, 사용, 유지, 저장, 보호된다. 기업은 EPC 사용과 관련하여 수집, 사용, 보호되는 모든 개인 신상 정보에 관한 기업의 방침에 대하여 모든 관련 법률에 의거하여 출판해야한다.

위의 가이드라인은 EPCglobal 회원사의 테스트단계에서 적용중이다. 또한 EPCglobal은 기술적으로도 프라이버시를 위한 보안 기술을 계속적으로 연구 중에 있다. 최근 RFID의 2세대 표준기술로 주목 받았던 EPC의 Class 1 Gen 2를 ISO의 정식표준인 '18000-6 타입 C'로 결정하였다. 이는 타입C의 태그가 킬(Kill)과 액세스(Acess) 패스워드⁵⁵⁾가 채용되어 있어 프라이버시 보호와 안전성을 강화하였다는 점에서 주목을 받고 있다.

다. 미국 소비자보호 단체들의 RFID 성명서⁵⁶⁾

2003년 11월 14일 미국의 개인정보보호 단체(CASPIAN, 전자프라이버시정보센터;Electronic Privacy Information Center, EPIC 등 8개 단체)에서 공동으로 발간 하였고, 세계 19단체가 후원을 했으며, 미국 및 세계 개인정보보호 관련 대표자 46명 등이 서명을 하였다.

발표된 성명서는 본문과 2개의 부록으로 구성되어 있다. 본문에는 RFID의 기본적인 소개와 특성과 프라이버시 요인, 권리 등을 설명하고 있다. 부록에는 다음의 내

55) 자세한 내용은 본보고서 “제 5 장 RFID 개인정보보호 관련 기술” 참조

56) 과기부, “2005년도 RFID 기술영향평가 보고서”, 2006년 2월

용이 들어있다.

부록1 : RFID의 기능, 기술 한계로 인한 침해위협이 크지 않다는 주장에 대한 반론

부록2 : 산업계에서 제안한 프라이버시 솔루션에 대한 비판

성명서에서는 개인과 사회에 대한 RFID의 잠재적인 피해를 완화하기 위해 세 가지 프레임워크를 사용해야 한다고 제안하였다. 다음의 표는 제안된 프레임워크 내용이다.

[표 2-9] 제안된 프레임워크 내용

첫 번째 프레임워크	RFID에 대한 공식적인 기술평가를 수행해야 하며, 수행되지 않았을 시에는 RFID 태그를 소비자 제품들에 부착해서는 안 된다.
두 번째 프레임워크	RFID를 적용할 때는 반드시 공정한 정보처리 원칙을 준수해야 하며, 이러한 원칙에 기반한 가이드라인이 RFID의 사회적 합의에 대한 평가를 진행하는 동안 충실히 지켜져야 한다.
세 번째 프레임워크	제품 안에 활동중인 또는 휴면중인 RFID 태그를 보유하는 것을 소비자에게 강요하는 것을 금지하고, RFID의 공지 없이 개인정보가 사용되는 것을 금지하는 내용들이 담겨있다.

성명서의 부록1에서는 프라이버시의 옹호론에 대한 반론을 제시하였는데, 내용은 아래와 같다.

[표 2-10] 성명서 부록1의 내용정리

주장	주장에 대한 반론 내용
“읽기 범위가 소비자 감시를 할 만큼 충분하지 않다.”	주파수 범위가 짧은 것이 기능을 하지 못하게 하는 것이 아니다.
“RFID 리더 장치가 끊임없이	개인을 추적하는 데는 많은 수의 RFID 리더

인간 추적을 할 만큼 광범위하게 퍼져있지 않다.”	기가 필요하지 않다. (예: 고속도로에서는 톨게이트에만 리더기를 설치하면 된다.) 즉, 전략적인 설치를 하면 리더기의 수는 많이 줄어들게 된다.
“제한된 정보만이 태그에 포함되어 있다.”	대부분의 태그는 일련번호만 들어있다는 점은 인정한다. 그러나 개인정보와 연계가 가능하다.
“수동적인 태그는 위성에 의해 추적될 수 없다.”	태그의 기능은 인정하지만 리더기가 위성으로 보낼 수도 있다.
“태그가 고비용이어서 널리 사용되는 데는 장애가 된다.”	기술이 향상되면 가격은 내려간다.

부록2에서는 산업계가 제시한 3가지 해결방안에 대한 반론하고 있다. 다음은 내용 중 KILL태그에 관련된 반론내용이다.

[표 2-11] 부록2에 수록된 KILL태그 반론 내용정리

주장	반론내용
“구매 후 태그를 파괴한다.”	태그들이 휴면중인데 파괴된 것처럼 보일 수도 있다. 이는 언제든지 재활성화될 수 있다.
“RFID의 내용이 전달되지 못하게 하는 차단태그를 사용할 수 있다.”	차단태그는 아직 이론이고, 태그가 안전하다는 오인으로 인해 RFID의 유포를 조장할 수 있다.
“RFID 시스템이 폐쇄적인 시스템으로 사용된다면 추적하는 것이 현실적이지 않다.”	아무리 폐쇄형 시스템으로 하여도 제품수준의 태그를 표준화하려는 강한 인센티브가 있다.

이 성명서는 RFID의 기능이 다양해질수록 그에 대한 책임도 커진다는 내용으로 이루어졌다. 이는 RFID에 대한 사회적 고민이며, 정책적·기술적인 접근이 필요한 프라이버시에 관한 문제는 시장 활성화와 그로인한 부작용을 같이 고려해야 한다는 점을 알려준다.

제 3 장 RFID 개인정보보호 관련 국내동향

제1절 국내의 RFID 가이드라인

우리나라의 RFID 가이드라인은 2004년 11월을 필두로 제정되기 시작하였다. 2004년 11월 1일 함께하는 시민연대에서는 제4차 빅브라더 보고서⁵⁷⁾를 발표하면서 RFID에 관련한 가이드라인 “RFID에서의 프라이버시 보호를 위한 10대 최소 가이드라인 v1.0”⁵⁸⁾을 제안하였다.

또한 2004년 11월 15일 KISA에서 RFID 프라이버시에 관한 공청회를 가졌다. KISA는 이 가이드라인을 한국전산원의 RFID를 이용한 3개 실증실험 등 향후 정부가 추진하는 다양한 RFID 관련 시범사업에 적용하면서 문제점과 대응방안을 계속해서 보완을 하기로 하였었다. 하지만 이에 대해 시민단체는 가이드라인에 대해 부정적인 견해를 밝혔다. 이유는 정부는 “(RFID는) 사물에만 적용할 것을 권고한다”는 입장이고, 시민단체는 “(RFID를)사람에게 적용해서는 안된다는 원칙을 천명하라”고 요구하고 있기 때문이다. 또한 시민단체는 ‘강제성이 있는 법제도 도입’이나 “사람에게 적용하지 않는다.”는 조항은 현실적으로 무리라는 입장으로 가이드라인을 부정적으로 바라보았다.

공청회 이후, 시민단체는 법제화를 요구하였는데, 법제화는 아직 기술이 초기단계에 있기 때문에 무의미하며, 너무 빠른 법제화는 오히려 기술적인 활용성에 제약을 주는 결과를 낳을 수 있기 때문에 신중히 고려를 해야 하는 사항이다.

정보통신부는 2004년 11월 15일 공청회이후 내달 안에 최종안을 발표하려 하였으나, 2005년 5월 26일 공청회를 실시한 후 7월이 되어서야 최종안을 발표하였다. 이렇듯 가이드라인은 공청회를 통해서 발전이 되어 왔으며, 각계의 의견을 수렴하면서 조금씩 진화되어 왔다.

본 절에서는 2005년 7월 7일 발표한 RFID 가이드라인을 중심으로 그 외의 가이드라인⁵⁹⁾과 비교·분석하며 개선방향에 대해 논의하겠다.

57) 조지오웰의 '1984'라는 소설은 정보독점을 통한 새로운 사회지배권력, 혹은 그러한 사회체제를 '빅 브라더(Big Brother)'라 일컫고 있다. 감시란 관리와 통제를 목적으로 개인 정보를 수집하는 일련의 행위를 말한다.

58) 보고서에 첨부되어 있는 [부록 1] RFID에서의 프라이버시 보호를 위한 10대 최소 가이드라인 v1.0참조

59) 그 외의 가이드라인에는 일본의 가이드라인도 포함된다.

1. 국내의 RFID 가이드라인 비교

현재까지 RFID 가이드라인은 2004년 11월을 시작으로 함께하는 시민연대의 가이드라인, KISA의 RFID프라이버시보호가이드라인, 정보통신부와 KISA(정통부 산하 기관)가 공동으로 제안한 RFID 프라이버시보호 가이드라인이 있다. 정보통신부가 발표한 가이드라인(이하 정통부 RFID 가이드라인)은 KISA의 가이드라인을 모태로 하고 있다.

정보통신부에서는 RFID 프라이버시 가이드라인에 대한 해설서를 발간하였는데, 이전의 가이드라인에 비해 상세한 내용을 담고 있어 가이드라인 이해에 많은 도움을 준다.

[표 3-1] 제안된 프라이버시 보호 가이드라인

제안자	함께하는 시민연대	KISA ⁶⁰⁾	KISA
가이드라인명	RFID에서의 프라이버시 보호를 위한 10대 최소 가이드라인 v1.0	RFID 프라이버시 보호 가이드라인 (안)	RFID 프라이버시 보호 가이드라인 (최종안)
날짜	2004.11.1	2004.11.15	2005.07.07

정통부 RFID 가이드라인은 초안에 비해 많은 조항이 개선되고 추가되어 졌다. 발표 후 ‘함께하는 시민연대’는 긍정적인 반응을 보였지만 개선되지 않은 몇몇의 문제점이 있다고 반응하였다. 가이드라인은 제1장에서 언급한대로 기술에 발전에 따라 지속적으로 개선되어야 하는 규범이다. 이는 다시말해서 균형적인 시각으로 가이드라인을 작성하여야 새로운 기술이 정착을 할 수 있는 것을 의미한다.

본 절에서는 정통부 RFID 가이드라인⁶¹⁾을 바탕으로 개선점 및 이전(2004년 11월 발표안)과 다른 점에 대하여 연구하였다.

60) KISA 가이드라인은 본 보고서에 첨부되어 있는 [부록 3] 참고

61) 본 보고서에 첨부되어 있는 [부록 2] 참고

가. 시스템 정의 추가

제2조(정의)의 2항

2. ‘RFID 시스템’이라 함은 대상이 되는 사물 등에 RFID 태그를 부착하고 전파를 사용하여 해당 사물 등의 식별 정보 및 주변 환경 정보를 인식하여 각 사물 등의 정보를 수집·저장·가공 및 활용하는 시스템을 말한다.⁶²⁾

제2조 2항은 RFID 시스템에 관련한 정의로서 2004년에 발표한 가이드라인에는 없었던 내용이다. 이는 이후에 공청회를 통하여 추가가 되었다.

나. 적용범위

제3조(적용범위)

이 가이드라인은 RFID 태그에 개인정보를 기록하여 당해 개인정보를 수집하거나 RFID를 통하여 수집한 물품정보와 개인정보를 연계하는 등 RFID 시스템을 이용하여 개인 프라이버시를 침해할 수 있는 경우에 적용한다. 다만, 개인정보와 프라이버시 침해 위험 없이 물품정보를 수집하여 이용하는 경우에는 적용하지 아니한다.⁶³⁾

제3조 적용범위는 이전보다 개선된 방향으로 작성이 되었다. 하지만 위 3조의 내용 중 “다만, 개인정보와 프라이버시 침해 위험 없이 물품정보를 수집하여 이용하는 경우에는 적용하지 아니한다.”는 광범위한 내용으로 해석될 수 있다. 따라서 본항의 내용에서 시민연대에서 제시한 바와 같이 추적거리, 장소, 시간에 제한이 없는 RFID 추적시스템은 원칙적으로 금한다는 내용을 포함하여 이용자의 불안을 해소시켜야 할 필요가 있다.⁶⁴⁾

62) 2005년 7월에 발표한 “KISA RFID 프라이버시보호 가이드라인” 중

63) 2005년 7월에 발표한 “KISA RFID 프라이버시보호 가이드라인” 중

64) 이러한 내용은 일본의 전자태그에 관한 프라이버시 보호 가이드라인에도 포함이 되어 있는 사항이다.

다. 개인정보에 관련한 고지

제4조(개인정보의 기록, 수집 및 연계)

②RFID 취급사업자는 제1항 규정에 의한 동의를 얻고자 하는 경우에는 당해 이용자에게 미리 개인정보의 기록목적 및 이용목적 등을 고지하여야 한다.⁶⁵⁾

본 항은 해설서에 의하면 각종 정보에 대한 고지를 하는 것으로 해설이 되어있다. 해설서에서 표현된 구체적인 정보 중 반드시 고지를 해야 될 부분은 가이드라인에서 구체적으로 표현해야 된다고 판단된다.

라. 이용자의 권리보장

제6조(RFID 태그의 물품정보 등과 개인정보의 연계) RFID 취급사업자는 RFID 태그의 물품정보 등과 개인정보를 연계하는 경우에는 미리 그 사실을 당해 이용자에게 통지하거나 쉽게 알아볼 수 있는 방법으로 표시하여야 한다.

제15조(개인정보 이용·제공·파기 등) 이 가이드라인에 정한 사항 외의 개인정보의 이용·제공·파기 및 이용자의 권리보호 등 개인정보 보호와 관련한 사항은 정보통신망 이용촉진 및 정보보호 등에 관한 법령 및 지침의 개인정보보호 원칙에 따른다.⁶⁶⁾

2005년 7월에 발표한 가이드라인에서는 이용자의 권리에 대한 보장부문은 약한 것으로 판단된다. 제6조와 제15조의 이용자의 권리보장은 해설서에서 15조의 자세한 해설내용으로 포함되어 있다. 하지만 2004년 11월에 발표한 내용에는 포함되었지만 본 가이드라인에서는 표현되지 않았던 다음과 같은 내용이 가이드라인의 조또는 항으로서 포함이 되어 명시를 해야 할 필요가 있다고 판단된다.

제9조(소비자의 개인정보 열람 및 정정요구 등) 소비자는 RFID 태그와 관련된 자신의 정보에 대하여 열람, 정정 및 보완을 요구할 수 있으며, 사업자는 소비자 권리보호를 위하여 개인정보처리와 관련된 RFID 시스템의 설치, 활용 및 관련 정책을 공개하여야 한다.⁶⁷⁾

65) 2005년 7월에 발표한 “KISA RFID 프라이버시보호 가이드라인” 중

66) 2005년 7월에 발표한 “KISA RFID 프라이버시보호 가이드라인” 중

단순히 통지나 고지를 하는 것으로 이용자의 권리를 보장하는 것도 좋은 방법이기도 하지만 이용자가 확인 또는 자신의 정보를 수정·삭제할 수 있는 권리를 가이드라인에 명시하여 권리주체로서 보호를 받을 수 있도록 해야 한다. 또한 시민연대에서 제안한 가이드라인 내용 중 배상에 관련한 내용처럼 프라이버시 침해와 관련하여 배상기준을 마련해야 한다는 내용이 포함될 필요도 있다.

6. (배상의 원칙) RFID 시스템을 도입하는 주체(기업, 공공기관 등)는 프라이버시 침해와 관한 배상 기준을 마련해야 한다.⁶⁸⁾

권리보장과 피해보상은 반드시 이용자의 권리에 대한 기본적인 내용⁶⁹⁾이므로 개선되어야 할 필요가 있다고 판단된다.⁷⁰⁾

2. 소결

가이드라인방식은 초반에 언급한 바와 같이 기술의 발전에 따라 개선되어가는 규범이다. 하지만 개선이 너무 늦어지면 피해를 당한 후에 개선을 하는 식의 방향으로 진행될 수 있다. KISA의 가이드라인은 개인정보보호를 위한 가이드라인이므로 공청회, 분석 등을 통해 지속적인 개선을 해야 된다고 판단된다.

제2절 개인정보보호 법률 현황

1. 개인정보의 의미와 보호

우리나라에서 개인정보의 법률적 정의는 “생존하는 개인에 관한 정보로서 당해 정보에 포함되어 있는 성명·주민등록번호 등의 사항에 의하여 당해 개인을 식별할 수 있는 정보”이다.⁷¹⁾ 현대는 개인정보의 수집·처리가 일반화 되고 있는 상황, 개

67) 2004년 11월에 발표한 “KISA 프라이버시보호 가이드라인” 중, 본 보고서의 [부록 2]

68) 함께하는 시민연대에서 발표한 “RFID 프라이버시 가이드라인”

69) OECD의 개인정보보호에 관련한 가이드라인에도 명시되어 있는 부문이다.

70) 일본의 가이드라인에서는 이용자의 권리보장으로 “제8조(소비자의 행동) 사업자는, 본 가이드라인의 기본적 생각에 덧붙여, 그 위에 스스로 사업실태에 응하는 소비자와의 관계를 고려하여, 전자태그의 취급에 대해 사업자단체의 사업장에 있어서의 검토 등을 포함하여, 적절한 대응을 취하는 것이 바람직하다.” 라고 명시되어 있다.

인정보 자체가 유통의 대상으로 범주화되고 있는 상황 등 개인정보와 관련된 일련의 변화들이 다발적으로 이뤄지고 있다. 이러한 상황에서 공동체의 존립과 합리적 유지를 위한 국가가 헌법과 법률이 정하는 바에 따라 필요한 개인정보를 수집하고 관리하는 것은 당연하며 그 개인정보는 단순한 사적정보 이상의 사회적·법적 의미를 가진다.

따라서 개인정보보호는 개인의 정체성을 확보하고 공동체의 민주적이고 합리적 운영을 위한 전제가 되는 가치이지만 그 보호범위는 선형적이고 절대적으로 확정되어 있는 것이 아니라 헌법의 한계 내에서 민주적 정치과정을 통해 결정되는 유동적인 것이다.⁷²⁾

오늘날 정보통신기술의 발달로 국가기관뿐 아니라 민간사업자도 개인정보의 수집과 관리가 가능해지면서 이에 따른 개인정보 침해 가능성이 문제화 되고 있다. 여기서 말하는 개인정보는 국가기관과 민간사업자가 자신들의 사업상 목적과 필요에 따라 분석하고 추출한 정보이다. 따라서 국가나 민간사업자의 입장에서 개인정보는 경제적 측면에서 대중을 통제하는 방법으로 활용되고 있는 것이고 정보주체인 개인은 평등한 서비스를 향유한다는 측면에서 이익을 얻는 것이다.⁷³⁾

정보통신기술의 발달로 가능해진 네트워크의 보편화로 맞춤형 행정서비스의 제공, 사회 인프라의 지능화 등이 이루어졌으나 주변의 모든 사물 안에 컴퓨터 기능을 부착하여 개인을 감독하고 관리하는 것이 가능해지면서 개인정보의 침해 위험성이 커지고 있다. 자신이 모르는 사이 자신의 정보가 수집되고 누적된다는 사실, 입력이 잘못된 정보를 쉽게 발견하고 수정하기 힘들다는 사실, 개인정보가 네트워크를 통해 널리 유통되고 확대·재생산될 수 있다는 사실, 피해를 입은 개인정보는 원상회복이 불가능하다는 사실에서 개인정보의 침해는 심각한 문제라는 것을 확인할 수 있다.

이러한 상황에서 개인정보보호는 중대한 관심사로써 부각되고 개인정보 침해를 재제할 수 있는 관련 법률의 중요성이 대두된다. 현재 우리나라의 개인정보보호 관련 법률 체계를 살펴보면 [표 3-2]와 같다. 표에서 알 수 있듯이 개인정보보호 관련 법률은 개인정보를 사용하는 주체인 공공부문(국가기관)과 민간부문(민간사업자)에 따라 구분되어진다. 따라서 공공부문의 개인정보와 민간부문의 개인정보는 관리주체에 있어서 큰 차별을 갖고 법적 근거에 있어서도 차이를 갖는다. 공공부문의 개인정보는 수집단계로부터 각종 행정법규의 정확한 법적 근거에 의하여야 하는

71) “공공기관의 개인정보보호에 관한 법률” 제2조 제2호.

72) 김종철, “전자정부와 개인정보보호의 조화 - 이념적 측면을 중심으로”, 개인정보보호 정책토론회 자료집(2004. 4. 21), 정부혁신지방분권위원회.

73) 황인호, “개인정보보호제도에서의 규제에 관한 연구”, 건국대학교 박사학위논문(2001).

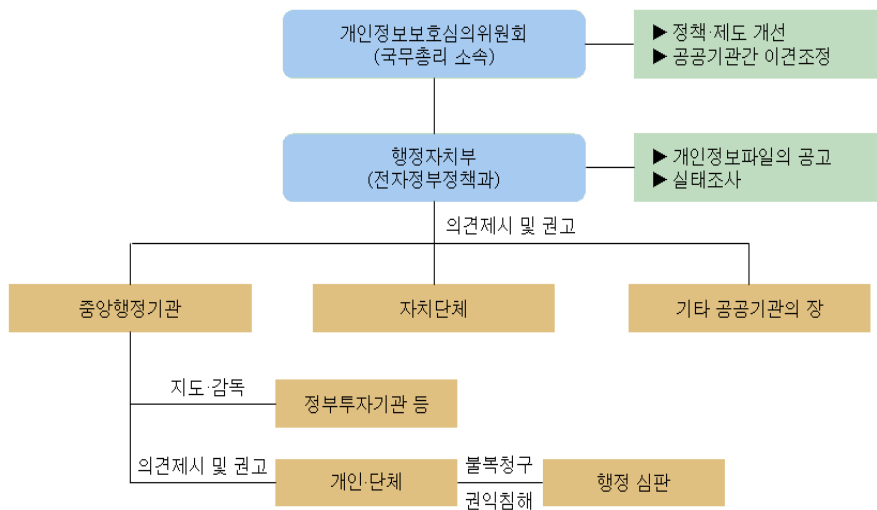
정보이고 민간부문의 개인정보는 원칙적으로 이해관계자간의 계약에 의하여 수집되고 관리되는 정보이다.

[표 3-2] 우리나라 개인정보보호 관련 법률 체계

구 분	헌 법	
	공공부문	민간부문
일반법	공공기관의 개인정보보호에 관한 법률	정보통신망 이용촉진 및 정보보호 등에 관한 법률
특별법	전자화 촉진에 관한 법률	신용정보의 이용 및 보호에 관한 법률
	주민등록법, 호적법, 도로교통법, 자동차관리법령, 국세기본법, 예금자보호법	보험업법령, 의료법, 전자거래기본법, 전자상거래 관련 소비자 보호 법률, 응급의료에 관한 법률
공 통	국가인권위원회법, 전자서명법, 정보화촉진기본법, 정보통신기반보호법, 보건의료기본법, 사회보장기본법, 약사법, 정신보건법, 통신비밀보호법, 금융실명거래및비밀보장에관한법률 등	

2. 공공부문에서의 개인정보보호에 관한 법률

공공기관이 보유하고 있는 개인정보에 관한 법률로 “공공기관의 개인정보보호에 관한 법률”과 “공공기관의 정보공개에 관한 법률”의 내용을 중심으로 알아보도록 한다. 여기에는 개인정보의 정의, 수집, 유지, 사용, 보호에 관한 내용이 포함된다. [그림 3-1]은 우리나라 개인정보보호와 관련하여 공공부문에서의 체계를 나타내고 있다.



[그림 3-1] 공공부문에서의 개인정보보호 체계

가. 목적

공공기관의 개인정보보호에 관한 법률은 공공기관에서 컴퓨터로 처리되는 정보를 보호하기 위하여 그에 따른 지침을 정함으로서 공공업무의 수행과 업무의 공정성과 투명성을 유지하며, 개인정보의 유출을 막음으로서 국민 개개인의 권리와 이익을 보호해준다는 것을 목적(제 1 조)으로 하고 있다.

공공업무의 수행이란 개인정보를 이용 및 취급하여 공공업무를 수행한다는 것이며, 국민 개개인의 권리와 이익의 보호는 정보를 컴퓨터로 처리함에 정보주체가 보호받아야할 권리와 이익을 뜻한다. 또한 넓은 범위로 개인정보가 정보주체의 동의 없이 공개되지 않을 것, 자신의 정보가 어떻게 관리 및 유지되고 있는지를 알권리, 불확실한 정보로 인해 정보주체가 피해 받지 않을 권리 등이 있으며 위 법률이 적용되는 범위는 국가행정기관, 지방자치기관, 기타 공공기관 중 대통령령에 정의된 기관을 의미한다.

나. 개인정보수집제한

정보주체의 동의가 있거나 사상이나 이념, 신앙과 같은 인권침해의 소지가 존재하는 개인정보의 수집은 아니 된다(제 4 조). 또한 개인의 기본권을 침해 할 수 있는 내용의 정보 수집 역시 제한되어 있다. 그리고 개인정보의 유출의 소지가 있는 행동을 수집단계부터 제한하여 개인정보 유출을 사전에 예방하고 있다.

다. 개인정보파일의 보유범위 · 사전 통보

공공기관은 기관의 업무수행을 위해 각 기관의 필요범위 내에서 개인정보를 소지 및 보관이 가능하다(제 5 조). 공공기관에서 개인정보를 이용하고자 하는 경우 중앙행정기관의 장은 ① 개인정보파일의 명칭, ② 개인정보파일의 보유목적, ③ 보유기관의 명칭, ④ 개인정보파일의 기록되는 개인 및 항목의 범위, ⑤ 개인정보파일을 보관하는 기관의 명칭 ⑥ 개인정보파일의 열람예정시기, ⑦ 열람이 제한되는 개인정보파일의 범위 및 그 사유, ⑧ 기타 대통령령이 정하는 사항(제 6조 1항 각호)을 행정자치부장관에게 통보하고, 기타 공공기관의 장은 관계중앙행정기관에 통보하여야 하며, 이를 다시 행정자치부장관에서 제출하여야 한다.

다만 공개 시 공공기관의 업무에 지장을 주거나 개인의 기본권 침해소지가 적은 개인정보파일은 ① 국가의 안전 및 외교상의 비밀 기타 국익에 중대한 영향을 미치는 개인정보파일, ② 범죄의 수사, 공소의 제기 및 유지, 형의 집행, 교정처분, 보안처분과 출입국관리에 관한 개인정보파일, ③ 조세범처벌법에 의한 조세범칙조사 및 관세법에 관한 개인정보파일, ④ 컴퓨터의 시험운행을 위하여 사용되는 개인정보파일, ⑤ 1년 내에 삭제 및 처리되는 개인정보파일, ⑥ 보유기관의 내부적 업무처리만을 위하여 이용되는 개인정보파일, ⑦ 대통령령이 정하는 일정한 수 이내에 정보주체를 대상으로 하는 개인정보파일, ⑧ 기타 이에 준하는 개인정보파일로서 대통령령에 준하는 개인정보파일 같은 개인정보파일(제 6조 2항 각호)은 사전 통보에서 제외된다.

라. 개인정보의 안전성·정확성 확보

공공기관의 장은 개인정보를 이용함에 있어서 개인정보가 분실 변조 훼손 도난 유출 되지 않아야 하며, 이를 보호하도록 필요한 조치를 강구하여 안정성을 확보해야 한다. 공공기관으로부터 개인정보를 위임받은 자도 위와 같은 필요한 조치를 강구하여야 한다(제 9 조). 공공기관의 장은 정보처리의 정확성을 위해서 최신의 정보를 확보하여야 하며, 이를 위해 정보주체로부터 개인정보를 수집하는 것을 기본원칙으로 하여야 한다.

마. 처리정보의 이용·제공의 제한

정보를 보유하고 있는 기관의 장은 다른 법률에 의해 보유기관의 내부에서 이용하거나 보유기관 외 제3자에게 제공하는 경우를 제외하고는 개인정보파일의 보유목적 외의 목적으로 정보를 이용하거나 다른 기관에 제공해서는 아니 된다(제 10조 1항). 그러나 정보주체 혹은 제3자의 권리와 이익을 침해할 우려가 있다고 인정되는 경우를 제외하고 ① 정보주체의 동의가 있거나 정보주체에게 제공되는 경우, ② 다른 법률에서 정하는 소관업무를 수행하기 위해 당해 처리정보를 이용하는 경우, ③ 국제협정의 이행을 위해 외국정부 혹은 국제기구에 제공하는 경우, ④ 학술연구 및 통계작성을 위한 목적으로 정보주체 개개인이 식별 불가능한 형태로 제공하는 경우, ⑤ 정보주체 또는 법정대리인이 의사표시를 할 수 없는 경우이거나 주소불명 등으로 동의를 할 수 없는 경우로서 정보주체가 외에 제공되는 정보가 정보주체에게 이익이 된다고 인정되는 경우, ⑥ 범죄의 수사나 공소제기 및 유지에 필요한 경우, ⑦ 법원의 재판업무수행을 위하여 필요한 경우, ⑧ 기타 대통령령이 정하는 특별한 사유가 있는 경우에는 개인정보파일의 보유목적 외에 처리정보를 이용하거나 다른 기관의 장에게 제공할 수 있다(제 10조 2항).

또한 개인정보의 제공에 따른 관리책임은 보유기관에 있으며, 타 기관에 제공시 이용목적에 필요한 최소한의 내용으로 하여 제한하여야 한다. 제공기관의 동의 없이 다른 기관으로 재제공은 아니 된다.

바. 개인정보 취급자의 의무

개인정보의 처리를 행하는 공공기관의 직원이나 직원 이었던 자 또는 공공기관으로부터 개인정보의 처리업무를 위탁받아 그에 관한 업무에 종사했던 자 또는 종사하였던 자는 업무수행 상 알게 된 개인정보를 유출 및 가공, 처리하거나 타인의 이용에 제공하는 등 부당한 목적을 위하여 사용해서는 아니 된다(제 11 조). 이러한 규정에 반하여 개인정보를 누설하거나 권한 없이 정보를 처리하거나 타인의 이용에 제공하는 등 부당한 목적에 사용 시에 3년 이하의 징역 또는 1천만원 이하의 벌금에 처한다(제 23 조). 수작업으로 처리한 일반문서는 동법에 적용받지 아니하고 형법 및 개별법의 적용을 받는다.

사. 열람권

정보주체는 개인정보파일대장에 기재된 범위 안에서 서면으로 본인에 관한 처리정보의 열람(문서의 사본의 수령포함)을 보유기관의 장에게 청구할 수 있다. 이러한 경우 보유기관의 장은 열람청구를 받은 때 열람제외 사유에 포함되지 않는 한 청구서를 받은 날로부터 15일 이내에 청구인에게 당해 처리정보를 열람할 수 있도록 하여야 한다. 15일 이내에 열람을 하게 할 수 없는 정당한 사유가 있는 경우에는 청구인에게 그 사유를 통보하고 열람을 연기할 수 있으며, 그 사유가 소멸한 때에는 지체 없이 열람하게 하여야 한다(제 12 조).

그러나 청구인이 처리정보를 열람하는 것이 ① 조세의 부과징수 또는 환급에 관한 업무, ② 교육법에 의한 학교성적의 평가 또는 입학자의 선발에 관한 업무, ③ 학력기능 및 채용에 관한 시험, 자격의 심사, 보상금급부금의 산정 평가 또는 판단에 관한 업무, ④ 다른 법률에 의한 감사 및 조사에 관한 업무, ⑤ 기타 대통령령이 정하는 업무와 같은 경우 당해 업무의 수행에 중대한 지장을 초래하는 때에는 제한할 수 있다. 또한 개인의 생명신체를 해하거나 개인의 재산과 이익을 부당하게 침해하는 경우도 열람이 제한된다(제 13 조).

아. 정정권

정보주체는 보유기관의 장에게 서면으로 당해 처리정보의 정정을 청구할 수 있다. 보유기관의 장은 청구를 받은 때에 다른 법률에 특별한 절차가 규정 있지 않은 경우 이를 조사하여 필요한 조치를 취한 후 그 결과를 청구인에게 통보하여야 한다. 이때 보유기관의 장은 조사를 함에 필요한 자료를 청구인으로 하여금 정정청구사항의 확인에 필요한 증빙자료를 제출하게 할 수 있다(제 14조).

자. 권리구제

열람 및 정정청구에 대하여 공공기관의 장이 행한 처분 또는 부작위로 인하여 권리나 이익의 침해를 받은 자는 행정심판법이 정하는 바에 따라 행정심판을 청구할 수 있다(제 15 조).

차. 문제 및 보완⁷⁴⁾

공공기관의 개인정보보호에 관한 법률의 주체기관의 부재가 가장 큰 문제점이다. 현재 공공기관 중에서 개인정보 보호의 총괄기관이 존재하지 않는다. 다만 공공기관이라는 막연한 범위가 존재하며, 개인정보의 효율적이며 체계적인 관리를 위해서 공공기관의 정보처리를 통제하는 통제기관의 필요한 실정이다. 이러한 통제기관의 설치 시 청구와 열람, 소송 및 구제 등 행정업무의 효율성이 증대할 것이다.

제정된 법의 적용범위가 매우 한정적이다. 공공기관에서 컴퓨터로 처리되는 개인정보만을 대상으로 하고 있으며, 수작업에 의한 문서는 형법이나 개별법에 적용을 받게 된다. 정보의 처리 및 가공과정에서 발생한 개인의 권리와 이익을 침해할 경우 처벌규정이 마련되어 있으나 정보수집단계에서 침해한 경우의 처벌규정은 마련되지 않았다. 이와 같이 제정된 법을 정보수집단계에서부터 처리 및 가공과정까지 적용 대상 및 처벌규정을 확대해야 한다.

제정된 법의 많은 사항을 대통령에 의해 하위법령으로 위임함으로서 정보주체들은 정보가 어떠한 공공기관에서 수집, 처리, 가공되는지 파악이 힘든 실정이다.

현재 개인정보보호에 관한 법률은 공공부문과 민간부문으로 나누어져 있다. 그러나 공공부문과 민간부문이라는 명확한 구별을 할 수 있는 지침이 없는 실정이다. 제정된 법을 수정하여 통합법을 제정할 필요성이 제기되고 있다.

각 공공기관에서 개인정보파일을 공유하고자 하는 경우 정보주체에게 고지의무가 규정되지 않았다. 즉 정보주체가 자신의 개인정보가 이용되고 있는지 알 수 없는 실정이다. 또한 열람권을 제한하는 법의 적용범위가 구체적이지 않다. 따라서 공공기관은 정보주체에게 개인정보의 수집단계에서부터 처리 및 가공, 폐기 등 공공기관으로의 전달 및 위임 시 정보주체에게 고지를 의무화하는 법 제정이 필요하다⁷⁵⁾.

카. 공공부문 개인정보보호 기구

(1) 행정자치부

행정자치부의 개인정보보호 기구로서의 역할에 대한 법적 근거는 다음에서 찾을 수 있다. 행정자치부장관은 이 법의 시행을 위하여 필요하다고 인정되는 경우에는 공공기관의 장에 대하여 개인정보의 처리에 관한 자료의 제출을 요구할 수 있으며

74) 김일환, “개인정보보호법의 개정필요성과 내용에 관한 연구”, 공법연구 제26집 제2호, 한국공법학회(1998).

75) 엄태석, “개인정보보호에 관한 입법론적 고찰” 경희대학교 석사학위논문, 2002

소속공무원으로 하여금 실태조사를 하게 할 수 있다(공공기관의 개인정보보호에 관한 법률 제 18 조). 또한 이 법의 목적을 달성하기 위하여 필요하다고 인정되는 경우에는 공공기관의 장에게 개인정보의 보호에 관하여 의견을 제시하거나 권고를 할 수 있다(제 19 조).

따라서 행정자치부는 공공기관이 보유하고 있는 개인정보에 대하여 공공기관의 접수 및 공고와 의견제시 및 권고의 기능을 수행한다.

(2) 개인정보보호심의위원회

공공기관이 보유하고 있는 개인정보 중 컴퓨터에 의하여 처리되는 정보의 보호에 관한 사항을 심의하기 위하여 국무총리소속하에 개인정보보호심의위원회를 두고 있다. 이 위원회는 ① 개인정보보호에 관한 정책 및 제도개선에 관한 사항, ② 처리정보의 이용 및 제공에 대한 공공기관간의 의견조정에 관한 사항, ③ 기타 대통령이 정하는 사항을 심의한다(제 20 조).

(3) 국민고충처리위원회

민원사무처리에 관한 법률에 근거를 두고 행정기관의 민원사무와 관련된 일반 사항들을 심의하는 역할을 한다. 주요 기능으로는 민원사항의 안내 및 상담, 고충민원의 조사와 처리, 위법·부당한 처분 등에 대한 시정조치의 권고, 행정제도 및 운영의 개선에 대한 권고 등을 들 수 있다.

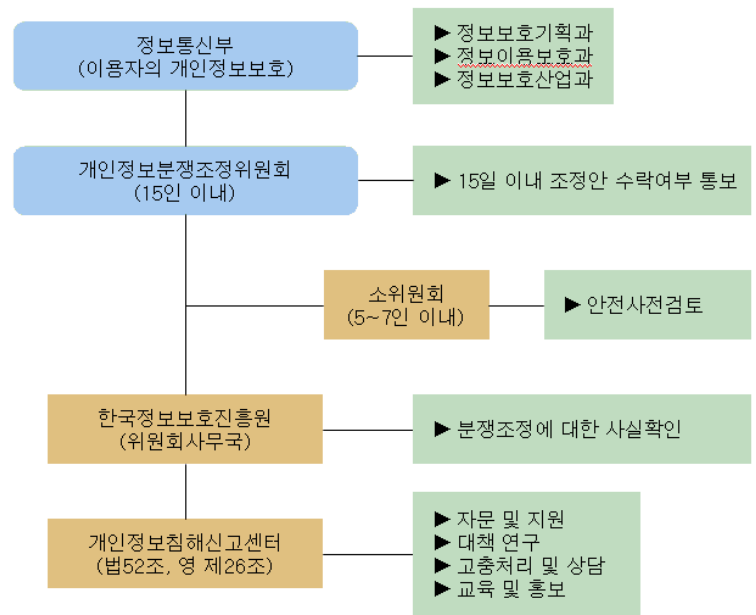
(4) 국가인권위원회

인권침해와 관련한 모든 사항들에 대하여 국가인권위원회법을 근거로 심의하는 기구이다. 법령·제도·정책·관행의 조사연구, 개선권고 및 의견표명, 침해구제, 지침의 제시 및 권고 등의 기능을 수행한다.

3. 민간부문에서의 개인정보보호에 관한 법률

민간사업자가 보유하고 있는 개인정보에 관한 법률로 “정보통신망이용촉진및정보보호등에관한법률”과 “전자서명법법률”, “통신비밀보관법”, “전자거래기본법”, “신용정보의 이용 및 보관에 관한 법률”, “금융실명제 및 비밀보장에 관한 법률”, “의료

법”에 개인정보보호를 위한 규정들이 산재되어 있지만 확장되어 가는 정보통신망상의 개인정보보호를 위해 제정된 「정보통신망이용촉진및정보보호등에관한법률」을 중심으로 알아보도록 한다. [그림 3-2]는 우리나라 개인정보보호와 관련하여 민간부문에서의 체계를 나타내고 있다.



[그림 3-2] 민간부문에서의 개인정보보호 체계

가. 목적 및 적용범위

정보통신망의 이용을 촉진하고 정보통신서비스를 이용하는 자의 개인 정보를 보호함과 아울러 정보통신망을 건전하고 안전하게 이용할 수 있는 환경을 조성함으로써 국민생활의 향상과 공공복리의 증진에 이바지함을 목적으로 한다.(제 1 조)

이 법에서 ‘개인정보’라 함은 생존하는 개인에 관한 정보로서 당해 개인을 알아볼 수 있는 부호, 문자, 음성, 성향 및 영상 등의 정보를 말한다⁷⁶⁾ 규정하여 개인을 알 수 있는 방법을 폭넓게 규정하고 있다.

공공기관과는 다르게 민간부문의 정보통신망은 정보통신부가 담당하며 정보통신서비스제공자 뿐만 아니라 정보통신서비스제공자외의 자로서 정보를 다루는 자 중 대통령령이 정하는 자⁷⁷⁾가 개인정보를 수집, 제공하는 경우에 적용되며, 수탁자 역시

76) 당해정보만으로는 특정 개인을 알아 볼 수 없는 경우에는 다른 정보와 결합하여 알아볼 수 있는 것을 포함, 제 2조 1항 6호

77) 시행령 제 28조(정보통신서비스제공자의 범위) 법 제 58조 제1항 전단에서 ‘대통령령이 정하는 자’라 함은 다음 각호의 1에 해당하는 자를 말한다. 1. 관광진흥법 제3조제1항의 규정에 의한 여

적용된다.

나. 정보통신서비스제공자의 의무

정보통신서비스제공자는 개인정보를 수집하는 경우 당해 이용자의 동의를 얻어야 한다. 다만 ① 정보통신서비스 이용계약의 이행에 필요한 경우, ②정보통신서비스 제공에 따른 요금정산을 위하여 필요한 경우, ③ 이 법 또는 다른 법률에 특별한 규정이 있는 경우(제 22 조 1항)를 제외하고는 당해 이용자에게 고지 및 명시(제 22 조 2항)해야 하고 정보 주체의 동의가 있거나 다른 법률에 수집대상 개인 정보가 명시되어 있는 경우 외에는 사상, 신념, 과거의 병력 등 개인의 권리, 이익 및 사생활을 현저하게 침해할 우려가 있는 개인정보를 수집하여서는 안 되며(제 23 조 1항), 필요한 최소한의 정보 외에 개인정보를 제공하지 않는다는 이유로 당해 서비스의 제공을 거부하여서는 아니된다.(제 23 조 2항)

정보통신서비스제공자로부터 이용자의 개인정보를 제공받은 자는 당해 이용자의 동의가 다른 법률에 특별한 규정이 있는 경우를 제외하고는 정보통신서비스이용약관에 명시한 범위를 넘어 이용하거나 제 3자에게 제공하여서는 안되고,(제 24 조 1항) 개인정보를 제공받은 목적 외의 용도로 사용하여서도 아니된다.(제 24 조 2항)

정보통신서비스제공자등은 이용자의 개인정보 취급자를 최소화하고(제 24 조 3항) 취급자는 직무상 알게 되었던 개인정보를 훼손 침해 또는 누설하여서는 아니된다.(제 24 조 4항) 또한 정보통신서비스제공자등은 이용자의 개인정보를 보호하고 개인정보와 관련한 이용자의 고충을 처리하기 위하여 개인정보관리책임자를 지정하여야 하며(제27조 1항) 정보의 취급에 있어 안전성 확보를 해야 하고(제28조), 정보를 제공받은 목적을 달성하였을 시 폐기해야한다.

다. 이용자의 권리

이용자는 정보통신서비스제공자등에 대하여 언제든지 정보수집에 대한 동의를 철회할 수 있으며(제 30 조 1항), 철회할 경우 수집된 정보를 파기하는 조치를 받을 수 있는(제 30 조 3항) 동의권 및 동의철회권과 개인정보를 제3자에게 제공한 내역을 요구할 수 있고, 자신의 개인정보에 오류가 있는 경우 그 정정을 요구할 수

행업 또는 호텔업을 행하는 자 2. 항공법 제2조제26항의 규정에 의한 항공운송사업을 행하는자 3. 학원의 설립·운영하는 자 4. 그 밖에 재화 또는 용역을 제공하면서 회원제 또는 그와 유사한 형태로 개인정보를 수집하는 사업자로서 관계중앙행정기관의 장과 협의하여 정보통신부령으로 정하는 자.

있다.(제 30 조 2항),

정보통신서비스제공자등에게 자신의 개인정보에 대한 열람 또는 개인정보를 이용하거나 제3자에게 제공한 내역을 요구할 수 있고, 정정요구를 받으면 필요한 조치를 취하고(제 30 조 4항) 조치할 때까지 개인정보이용을 이용하거나 제공하지 못하는(제 30 조 5항) 열람 및 정정청구권이 있다.

또한 정보통신서비스제공자가 만 14세 미만 아동으로부터 개인정보를 수집할 때 법정 대리인의 동의를 얻어야 하며 위와 동일한 철회 및 정정청구권을 포함하는 14세 미만 아동의 권리보호가 있다.

라. 개인정보분쟁조정위원회

개인정보침해로 인한 피해에 대한 구제와 분쟁을 신속·간편하게 해결할 수 있는 제도를 마련하여 ‘개인정보분쟁조정위원회’를 설립하고, 그 조정 결과에 대하여 민법상의 화해와 같은 효력을 부여하고 있으나 사후적 피해구제 및 통제이며, 정보보호를 위한 포괄적 관리기구가 아니다.

마. 법률상 문제점과 보완

현재 대부분의 정보가 컴퓨터에 의하여 관리되는 점을 감안할 때 ‘정보통신망이용촉진및정보보호등에관한법률’을 보완하였으나 민간부분의 정보통신망에서의 개인정보보호와 컴퓨터로 처리하는 개인정보보호에 관한 일반법안과의 차이를 무시하고 있다.

또한 수범대상을 영리목적으로 개인정보를 처리하는 자로 규정하고 있다.(제 2 조 4호) 따라서 공공기관의 영리목적의 회원제 서비스의 가입자의 개인정보와 비영리 부문에서 수익목적의 개인정보 처리를 규율 대상으로 하는지 불분명하다.

우리나라의 개인정보보호법은 침해위험성, 민감도에 따라 구분하지 않고 특별법 및 개별 법률에서 각각의 필요에 따라 규율하고 있는데 이 경우 적용 범위가 한정적이어서 법률의 보호를 못 받는 경우가 많다. 또한 국제기구의 요구하는 정도를 충족시키지 못한다.

그러나 정보통신의 발전을 위해서는 개개의 권리중 중요하지 않은 부분은 보호의 대상에서 제외될 가능성이 높은 반면 개인정보보호에 중점을 둔다면 정보통신의 발전이 저해될 수 있다.

또한 사상, 신념, 과거의 병력 등 개인의 권리, 이익 및 사생활을 현저하게 침해할

우려가 있는 개인정보 등의 민감한 정보는 정보주체의 사전 동의가 필요하지만 그 외에는 해당 개인 정보의 처리에 대하여 인지할 수 있을 정도로 설정한다고 해도 정보주체의 정보자기결정권을 침해할 가능성이 존재한다.

갈수록 증가하는 개인정보관련 분쟁을 해결하기 위하여 ‘개인정보분쟁위원회’를 두고 있고, 이 위원회의 업무를 보조하기 위하여 산하에 ‘보호진흥원’이라는 사무국을 설치하고 있으나 유럽 각국의 개인정보 전담기구⁷⁸⁾에 비해 그 역할이 미치지 못하고 있다. 개인정보보호전담기구는 빠르게 변화하는 정보환경에 효율적으로 대처할 수 있는 준사법적·준입법적 권한을 가진 공정거래 위원회와 같은 개인정보전담기구를 설치하여 행정입법, 행정사법 및 행정행위에 관한 권한을 관장하도록 하여야 할 것이다. 이러한 통합적 독립기구를 통해 보다 효율적으로 개인정보 보호가 이루어짐으로써 소비자 등의 피해에 대한 사전 예방 및 사후구제책을 확보할 수 있을 것이다.⁷⁹⁾

바. 민간부분 개인 정보보호 기구

(1) 정보통신부

정보통신망이용촉진및정보보호등에관한법률을 근거로 정보통신서비스 전반에 걸친 개인정보보호 역할을 담당한다. 주요기능으로는 법률 제·개정 및 기준제정, 시정 권고 및 명령, 과태료 부과 등을 들 수 있다.

(2) 개인정보분쟁조정위원회

정보통신부와 같은 법률 근거와 관할 범위를 가지고 분쟁조정 신청·접수, 사실조사 및 청문, 합의권고, 분쟁조정, 위법사실통보 등의 기능을 담당한다.

(3) 개인정보침해신고센터

정보통신부와 같은 법률 근거와 관할 범위를 가지고 상담 및 고충처리, 교육 및

78) 영국은 개인정보보호원(Data Protection Commissioner), 독일은 연방개인정보보호관(Bundesbeauftragte für den Datenschutz)과 감독관청(Aufsichtsbehörde), 프랑스의 정보자유국가위원회(CNIL:the National Commission on Informatic and Freedom)등 독립적인 개인정보보호전담 규제기구를 두고 있다.

79) 김철완, 이민영, “인터넷 개인정보보호에 관한 법제도 연구”, 「정책연구」 제00-10호, 2000, 218-219쪽 참조

홍보, 기술적 자문 등의 기능을 담당한다.

(4) 금감위 금융감독원

신용정보이용 및 보호에 관한 법률에 근거를 두고 금융거래 전반에 걸친 심의 역할을 담당한다. 주요기능으로는 상담 및 피해구제, 시정권고 및 명령, 기준제정 등을 들 수 있다.

(5) 전자거래분쟁조정위원회

전자거래기본법을 근거로 하여 전자거래 전반에 걸친 개인정보보호 역할을 수행한다. 주요기능으로는 상담 및 피해구제를 들 수 있다.

(6) 소비자보호원 & 소비자단체

소비자보호법을 근거로 소비자거래에 있어 개인정보보호 역할을 담당한다. 주요기능으로는 상담, 피해구제, 합의권고 등을 들 수 있다.

제 4 장 RFID 개인정보 침해사례

제1절 RFID 개인정보보호 사례

이 장에서는 RFID를 도입한 국내외 사례들 중 프라이버시의 논란이 있는 사례에 대해서 설명하고자 한다. RFID 태그 내에는 기본적으로 상품의 코드정보만 들어가므로 RFID 태그를 사용함에 있어서 무조건 프라이버시가 발생할 것이라고 생각하는 것은 위험하다. 여기에서는 RFID를 이용한 유통, 물류업체의 사례와 공급망(supply chain) 관리에 사용한 예, 그리고 국가나 인명을 위해 사용된 사례 등 여러 국가의 다양한 사례에 대해서 말하고자 한다. 나아가 이러한 사례를 통해서 개인정보보호에 대한 우려사항과 긍정적인 이용에 모습에 대해서도 알아보하고자 한다.

사례번호	CASE 1
사례명	쇼핑마트 관련 프라이버시 사례
사례내용	국내에서는 삼성 테스코 홈플러스에서 RFID를 장착한 쇼핑카트를 개발했다. 테스코는 영국 테스코에서 2개매장에서 시범운영한 뒤 2004년 RFID를 쇼핑카트에 붙이는 시범사례를 진행하는 중이다. 삼성홈플러스의 시범사례는 현재 2차 년도까지 진행이 되었다. 시범사례를 진행 중 매장 측이 고객의 움직임과 장바구니를 낱낱이 엿본다는 점에서 사생활 침해 논란이 일어날 수 있을 거라 예상된다. 해외에서는 미국의 월마트가 올 1월부터 RFID를 100여개 매장에 깔았고, 알버트슨도 100대 협력업체들이 RFID 태그를 전 제품에 부착해 운영중이다. 세계적인 유통업체 월마트는 100개 상품 공급업체에 RFID 태그에 기반을 둔 EPC 코드 도입과 관련한 공식 문서를 발송했다. 이 문서에는 2005년 1월부터 100개 업체에 상품 박스와 팔레트에 RFID 태그를 반드시 부착해야 한다는 공지와 함께 이와 관련한 구체적인 EPC 사양이 제시돼 있다. 이와 별도로 37개 업체는 자발적으로 EPC를 사용하겠다고 월마트에 통보함에 따라 내년부터 월마트의 137개 거래업체가 RFID 시스템을 이용하게 된다.

	나아가 월마트는 내후년 1월부터 모든 업체에 RFID 태그 부착을 의무화할 것이라고 공언했다. 월마트는 이미 미국 전역의 7개 매장을 중심으로“Verisign Zone”이라는 일종의 테스트베드를 구축하고 상용화를 위한 만반의 준비를 마쳤다 하지만 월마트가 자사에서 판매하는 모든 상품에 RFID 태그를 부착한 경우 이를 구입한 소비자의 성향이나 위치 같은 극히 개인적 인 사안들이 유출될 가능성이 있기 때문에 미국의 소비자단체는 개인 프라이버시 침해를 우려해 월마트의 RFID 사용의 전면철회를 요구하고 있는 상황이다. 관련업종 기업체들은 경영효율을 극대화할 수 있다는 점에서 RFID 도입에 적극성을 띠고 있다. 고객분석이 신속 정확하게 이뤄지는 데다 상품 및 재고관리를 편리하게 할 수 있기 때문이다. 소비자 입장에선 반길 이유가 없다. 개인정보가 실시간으로 노출되기 때문이다. 이름,나이,생년월일(회원카드를 갖고 있을 경우)은 물론이고 어떤 물건을 언제 어디서 샀는지까지 공개되는 셈이다. 월마트의 경우 RFID 태그가 부착된 상품을 구입한 소비자의 성향이나 위치 같은 개인적 인 사안들이 유출될 가능성이 있기 때문에 미국의 소비자단체는 개인 프라이버시 침해를 우려해 월마트의 RFID 사용의 전면철회를 요구하고 있는 상황이다.
참조문헌	국민일보,["구매패턴 파악"“소비자 인권 침해”...장보기 감시 ‘전자태그’논란], 2005-07-28

사례번호	CASE 2
사례명	미국의 RFID 여권 관련
사례내용	미국 정부가 내년 10월부터 모든 자국 여권에 개인 신상 정보를 담은 전파식별(RFID) 칩을 탑재할 것이라고 발표했다고 씨넷(CNET)이 25일(현지시간) 보도했다. 씨넷에 따르면 미국 정부가 여권에 탑재할 RFID 칩의 용량은 64KB로 여기에는 여권 소지자의 이름·국적·성별·생일·출생지

	· 디지털사진 등의 정보를 담게 된다. 아울러 정부는 궁극적으로 지문이나 홍채와 같은 정보들을 추가하는 것도 심사숙고하고 있는 것으로 알려졌다. 현재 RFID 여권은 개인정보 유출 위험에 대한 우려로 인해 반대 여론이 높아져 가고 있는 상황이다. 올해 미 국무부가 접수한 RFID칩 내장 여권 계획에 대한 2335건의 의견 중 98.5%가 부정적인 의견들이었으며 이들은 보안과 프라이버시 문제를 지적한 것으로 나타났다. 미 국무부는 이러한 우려에 대해 RFID 여권은 개인정보를 추적하는 데는 사용하지 않을 것이며 출입국시 정부기관이 여권소지자의 신원을 확인하는데만 사용할 것이라고 밝혔다. 또 '안티스키밍'(antiskimming) 장비를 도입, 누군가 멀리서 은밀히 개인정보를 탈취하는 행위에 대한 위협을 완화시킬 것이라고 설명했다. 그러나 프라이버시를 옹호하는 단체들은 이제 막 시작 단계에 접어든 안티스키밍 장비가 이러한 위협을 얼마나 효과적으로 방지할 수 있을 지에 대해서는 의문을 표시하고 있다. 또 이번 결정은 향후 법적인 문제로까지 비화될 수 있어 미국 정부의 향후 행보가 순탄치 않을 것으로 보인다고 씨넷은 전했다. 이에대한 항의가 많아지자 미국무부는 RFID에서의 근접식별방식으로 선호하게 될 것 같다. 또한 국토안보부(Homeland Security)에서 곧 생겨날 패스(People Access Security Service) 라고 불리는 카드들은 2008년 1월 1일부터 시작되는 연방정부의 요구조항의 일환으로, 이 법 조항은 멕시코나 캐나다에서 미국으로 들어오는 사람이면 누구든지 여권이나, 여행 서류를 지참해야 할 것을 요구하고 있다. 국토안보부는 이 앞의 서류가 근접 판독이 가능한 지갑 사이즈의 카드 형태를 취하게 될 것이라고 내다봤다. 또 이 카드는 일정 거리에서도 읽혀져, 자동으로 카드 소지자의 사진과 또 다른 생체 정보를 정부 기관 컴퓨터의 스크린에 보여줄 것이라고 했다. 국토 안보부는 지난 9월 정부의 조달 공지에서, RFID 기능이 들어간 개인 식별 카드가 국경을 건널 때 사용될 것이며 "인식 가능 범위는 최소 25피
--	--

	트로 확장될 것"이라고 했다. RFID 프라이버시 보호단체들은 "정부는 ID 카드가 다음과 같은 기기를 포함하는 환경하에서 읽혀질 수 있도록 요구하고 있는데, 그 기기들은 주머니, 핸드백, 지갑, 여행자의 옷 속이나 몸 어딘가에 휴대 될 수 있는 것들이다. 여행자들은 기기에 의해 읽히기 위해 그 어떠한 행동도 하지 않아도 되는데, 즉 수동적으로, 자동으로 읽힌다는 뜻이다." 라고 하여 프라이버시 침해에 대한 논란이 예상된다. 현재 여권에 관련된 RFID 보호방법으로는 표면에서는 마일라라는 뒤풍의 회사가 개발한 절연체와 기능적으로 암호화 방식과 안티스키밍 방식 두 가지를 정부가 제안하였는데, 암호화방식은 일반적으로 인터넷뱅킹, 신용카드 정보보안에서 사용하는 암호화 방식과 거의 동일한 방식이다. 안티스키밍 방식과 암호화방식은 이것은 여권이 완전히 혹은 거의 닫혀 있을 때에는 정보를 빼내는 것이 극히 어려운 것으로 알려져 있다. 하지만 프라이버시 관련 단체는 안티스키밍 방식은 초기단계인데 고성능의 리더기를 상대로 보호를 제대로 해줄 지 의문이라는 반응을 보이고 있다.
참조문헌	이홍석 기자, “미국 내년 RFID 여권 도입”, 디지털 타임스, 2005-10-27일 ZDNet Korea, “RFID 여권, 안전성 의문 「알고는 못 쓴다?」”, 2006-04-20

사례번호	CASE 3
사례명	RFID를 기술이 도입 된 티켓 사례
사례내용	독일 월드컵 입장권 290만장에 RFID 칩을 장착할 계획이라고 인포월드가 FIFA 월드컵 조직위원회를 인용 보도했다. RFID 칩이 장착한 티켓은 홀리건이나 테러를 방지하기 위하여 도입하였다. RFID 칩을 통해 티켓의 진위여부와 실명제를 도입하여 암표 등의 부정적인 판매 및 입장을 막을 수 있을거라 예상된다.

	하지만 RFID 도입에 따라 프라이버시가 논란이 되었는데, 독일의 프라이버시 옹호 그룹인 포버드의 레나 탄젠스 대변인은 "RFID 칩이 내장된 입장권을 구입하기 위해서는 주소, 전화번호, 생년월일, 여권 번호 같은 개인 정보에 대해 답해야 한다"면서 "축구 경기를 구경하려는 팬들에게 왜 이렇게 많은 개인 정보를 요구하는지 이해할 수가 없다"고 주장했다.
참조문헌	이홍석 기자, 디지털 타임스, 2005-10-27일

사례번호	CASE 4
사례명	피해자 신원파악 관련 사례
사례내용	RFID는 현재 다양한 분야에서 실험이 되고 있다. 개인 신원을 확인하는 방식으로도 다양한 사례가 발표되고 있다. 본 사례에서는 신원확인 사례를 다루어 보았다. 본 RFID는 유통, 물류와는 전혀 상관없는 100% 신원확인을 위한 RFID 사례이므로 유통, 물류에서의 개인정보사례와 혼동하는 오류를 범하지 않기 바란다. 미국 연방재난관리청(FEMA) 산하 재난사망자처리팀(DMORT)과 미시시피주 해리스 카운티의 건강 관련 관리들은 사망자 신원 파악 작업을 앞당기기 위해 시체에 RFID 칩을 심고 있다.

RFID 태그는 배리칩사의 제품이 사용된 것으로 확인되었다.



RFID 반대론자들은 사람들에게 RFID 칩을 심는 것을 인권과 프라이버시 침해 가능성이 있다고 주장하고 있다. 일부 기독교 단체들은 그들의 신앙에 반한다고 인체에 RFID 칩을 심는 것을 강력 비난하고 있다.

플로리다 팜 비치에 있는 ADS(Applied Digital Solutions)가 현금 지급기나 신용카드를 사용해야 할 경우 RFID 칩을 피부 밑에 이식해 자신의 신분을 확인할 수 있는 방법을 고안해냈다. 칩 이식 수술은 국부마취와 함께 시술되며, 12X2.1mm RFID 태그를 팔에 있는 피부에 삽입하는 것이다.

또한 마스터카드의 페이패스라는 RFID 기술을 테스트하고 있다. 이는 외형은 다른 신용카드와 비슷하지만 겉에 RFID 태그가 부착돼 있어서 자석 막대를 통해 스캔되지 않고 응답기를 통해 신원 정보를 인식하도록 구성돼 있다.

이와 관련해 전자 사생활 정보센터인 EPIC(Electronic Privacy Information Center)의 변호사인 크리스 후프네이글은 RFID 태그를 이식할 경우 다른 문제가 야기될 수 있다고 지적했다. 그는 "은행 카드가 손상된 경우에는 발행자에게 전화만 하면 된다. 하지만 카드를 이식했을 경우엔 의사를 불러야 한다"고 말하면서 "개인이 통제할 수 있는 카드에서 통제할 수 없는 카드로 바뀐다는 것은

	말이 안된다"고 덧붙였다.
참조문헌	김익현기자, “카트리나 피해자 신원파악에 RFID 사용“, 아이뉴스 24, 2005-9-19

사례번호	CASE 5
사례명	도서관에서 RFID 사례
사례내용	2004년 미국 샌프란시스코에서는 공립 도서관에 RFID를 도입하려는 계획이 발표되었다. 이 계획은 도서관의 모든 서적에 RFID를 부착해서 책의 출납을 쉽게 확인하려는 계획이었다. 도서관들은 정보 기관들의 감시로부터 이용자들의 독서 습관에 관한 정보를 보호하기 위해 노력해왔는데, RFID는 책의 출납, 현재위치, 사람의 위치(책을 보유한 사람의 위치를 의미) 등 도서관의 전통을 약화시킬 것이라는 우려가 있었다. 이에 EFF(전자프런티어재단), ACLU(미국시민자유연맹) 등의 시민권/정보 단체들이 이 계획에 예산을 배정하지 말라고 여러 차례에 걸쳐 예산감독위원회에 탄원했으나, 결국 회의를 한 차례 연기하면서까지 가결시켰다. 또한 서울 은평구립 도서관도 13.56MHz에서 작동하는 RFID 시스템을 도입해 출납 관리 등에 사용하고 있는데, 개인정보보호 관련 단체는 도서관의 개인취향 등의 정보가 유출될 수 있는 문제에 대해 우려를 표하고 있다. 은평구립 도서관
참조문헌	임홍규 기자, “RFID로 인한 개인 정보 유출 논란” 빅브라더 보고서 사례인용, 2004.12.08

--	--

사례번호	CASE 6
사례명	의류 사업과 관련한 RFID 프라이버시 사례
사례내용	2003년 베네통은 재고 및 유통의 효율성을 높이기 위해 RFID 시스템을 도입하였다. 베네통의 사례는 프라이버시 사례 중 대표적인 사례로 유명하다. 베네통 측은 RFID 칩을 옷 속에 장착하면 상자를 한번에 스캔하여 모든 데이터를 전송받는 장점을 가지고 있다고 설명하였다. 하지만 이러한 실험은 사생활을 침해할 수 있다는 이유로 난항을 겪었다. 실험에 도입된 RFID칩은 필립스에서 제조한 것으로 알려졌다. 필립스는 이에 대해 인식범위가 1.5m이내이기 때문에 창고나 건물밖에 나가면 측정이 불가능해진다고 수차례 강조하였다. 베네통의 RFID 계획 발표 직후 미국의 소비자 사생활 보호 단체 캐스피언(CASPIAN)은 베네통을 비난하며 전 세계적인 불매 운동에 돌입해, 베네통이 RFID 관련 계획을 취소할 때까지 회사의 제품을 사지 말 것을 소비자에게 권했다. 이러한 소비자 단체의 저항에 의해 베네통은 “RFID 계획을 실행에 옮기기 전에 개인의 사생활에 관한 잠재적인 위험성을 충분히 고려할 것”이라며 논란에 대해 언급하였다. 하지만 이후 베네통에 대하여 불신운동이 일어나자 베네통은 “현재 옷에는 RFID 태그가 부착되지 않았다”는 홍보를 하였다. 베네통의 실험결과를 살펴보면 RFID 기술도입을 통해 주문의 정확성 향상 및 인건비 감소를 가져왔으며 한 상점을 대상으로 RFID를 적용한 결과 매장관리효율성이 증가해5% 이상의 판매상승 효과

	과를 가져온 것으로 밝혀졌다. 또한 2004년 시카고에서 열린 Frontline Expo에서 Checkpoint의 대표자는 현재 모 의류 브랜드 회사가 2005년까지 모든 의류에 RFID 장비를 부착하기 위한 계획을 수립하였다고 밝혔다. Checkpoint의 대표는 이 의류 브랜드가 무엇인지 밝히지 않았으나 매우 잘 알려진 브랜드라고 밝혔고 EPC RFID 칩을 사용한다고 했다. 추정되는 의류 브랜드로는 Calvin Klein, Champion, Aberchrombie & Fitch의 3사를 들 수 있다. 이와 관련하여 CASPIAN의 설립자인 Katherine Albrecht는 모든 의류에 RFID Tag를 적용시키는 것은 매우 악질적인 행위라고 언급하면서 현재 시장에서 진행 중인 RFID 관련 시위들을 결코 간과해서는 안 된다고 입장을 밝혔다.
참조문헌	http://www.spychips.com/press-releases/checkpoint.html For Immediate Release - September 23, 2004

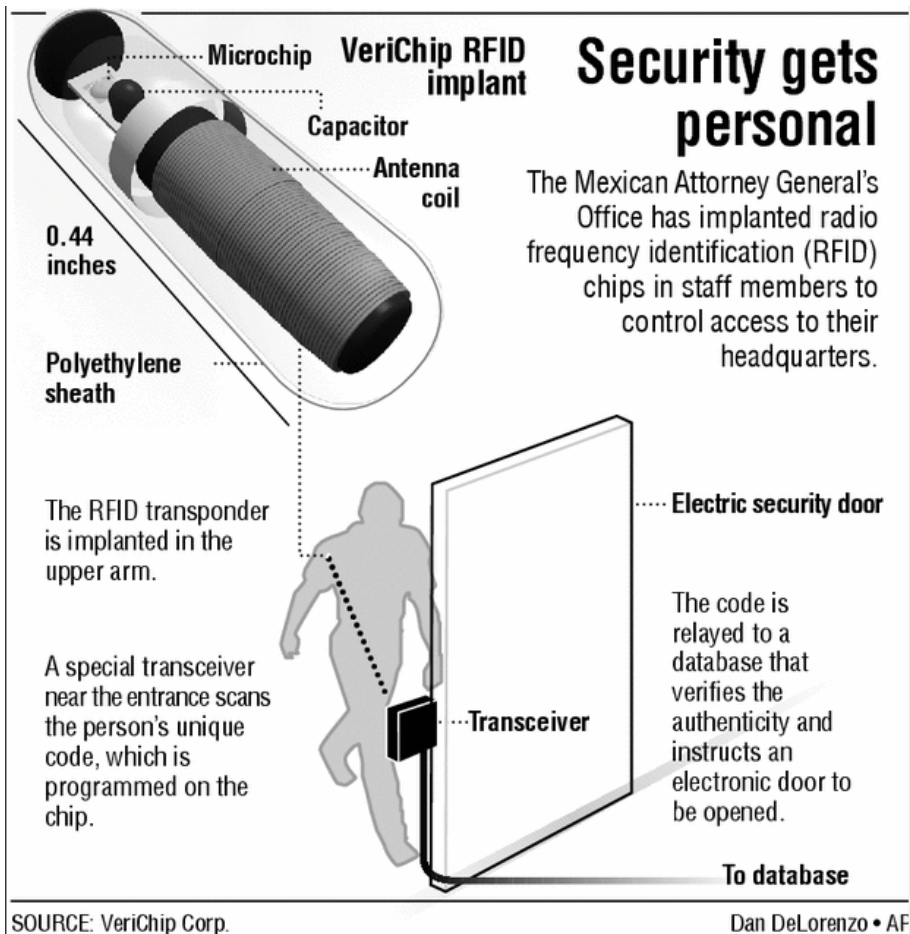
사례번호	CASE 7
사례명	카지노 칩에 내장된 RFID 칩
사례내용	다양한 분야에 도입되기 시작한 RFID는 카지노에서의 사용도 이루어졌다. 이는 카지노 칩에 RFID 칩을 적용시키는 것으로 가짜 칩을 통한 불법 도박을 사전에 방지할 수 있다. 기사의 예는 다음과 같다. 카지노장에서 \$100,000의 현금을 가지고 블랙잭 딜러들을 상대로 도박에 돌입했다고 하자. 만약 매 번 도박에서 이기게 된다면 카지노 칩을 안전하게 보관하기 위해서 자신의 주머니에 몇 개 정도 집어넣는 경우도 생기게 된다. 이 후 행운은 사라지고 한 푼도 획득하지 못하게 된다고 하자. 눈앞에서 돈을 모두 탕진하고 하루 치 도박 돈을 모두 잃었다고 카지노업자에게 말한다. 하지만 관계자들에 의해 주머니에 있는 칩이 발견되면 이는 불법 칩인지에 대한 여부확인과 함께 의심을 살 수 있다. 하지만 RFID태그가 심어

	져 있으므로 칩은 정당한 칩으로 확인을 자동적으로 받게 될 것이고, 계속 게임을 할 수 있다. 카지노에서는 1950년 이후 줄 곧 도박자들을 감시해 왔다. 하지만 기술의 발전을 통해 몇몇 도박꾼들의 습성과 버릇을 기록할 수 있게 되었다. 이전까지는 대부분의 기록이 추측을 통해서 이루어졌다. 그러나 RFID 칩의 도입으로 신뢰성 있는 정보를 수집할 수 있게 되었고 따라서 카지노에 가장 큰 이익을 남겨주는 고객에게 가장 큰 보답을 할 수 있게 되었다. 또한 수집된 정보를 통해 도박중독에 관련한 데이터를 얻을 수 있다. 하지만 이러한 개인의 돈을 가지고 하는 도박정보는 개개인의 정보로서 인식될 수 있으며, 이에 대한 프라이버시 문제는 계속 논란이 될 것이다.
참조문헌	Financial Times Released - April 8, 2005

사례번호	CASE 8
사례명	직장내의 ID 관련 사례
사례내용	한 민간 보안업체가 사람의 몸에 전파 식별(RFID·Radio Frequent Identification) 장치를 심어 신분을 확인하는 시험에 들어가 ‘사생활 침해’ 논란이 있었다. 미국 오하이오 주의 시티워처닷컴은 직원 2명의 오른팔 윗부분에 RFID 기능을 하는 전자칩을 이식해 시험 중이라고 밝혔다. 관공서 등 출입통제구역에서 드나들 때 판독장치가 전자칩을 지닌 사람을 확인할 수 있는지 알아보는 시험이다. 이번에 이식된 RFID칩의 크기는 길이 1.2cm, 너비 2mm. 주사기를 사용해 간단히 팔 상박부의 피부 밑에 이식되는데 수명은 약 20년 정도라고 한다. RFID 칩에는 전파송신장치가 내장돼 있어 판독기가 직접 접촉하지 않고도 그 정보를 읽을 수 있다.

	RFID 칩을 팔에 이식한 손 다크스 시티워치 최고경영자(CEO)는 “이 전자칩은 카드판독기와 유사한 장치를 통해서만 인식될 수 있는 일종의 ID카드”라며 “멀리까지 전파를 발사해 자기 위치를 알리는 인공위성자동위치추정시스템(GPS) 칩이 아니기 때문에 마누라는 내가 어디 있는지 알 수 없다”고 말했다. 옹호론자들은 강제 이식이 아닌 한 별문제가 아니라는 생각이지만 비판론자들은 칩 이식 자체가 자신도 모르는 사이에 위치 추적 등에 노출되는 결과로 이어질 수 있다고 지적하고 있다.
참조문헌	[동아일보] 2006-02-14 ‘사람몸에 바코드’ 현실로 다가오나

사례번호	CASE 9
사례명	멕시코의 공무원 인체 전자칩 사례
사례내용	멕시코정부는 공무원의 입출입 및 이동경로를 파악할 수 있는 RFID 기술을 이용한 전자칩을 인체에 이식하려는 계획을 발표해 논란이 일고 있다. 현재 멕시코는 법무장관과 160명의 직원들 몸속에 전자칩을 내장하는 작업을 진행 중에 있다. 이번에 사용된 RFID 칩은 베리칩으로 미국 플로리다 팜비치에 있는 어플라이드 디지털 솔루션의 자회사가 만든 것인데 크기는 길이 12mm, 너비 2.1mm 정도의 쌀알만한 크기로서 주사기를 사용해 간단히 팔의 피부 밑에 이식할 수 있다. 베리칩은 실리콘 메모리와 무선 송수신 장치로 구성돼 있어 스캐너로 칩에 저장된 정보를 판독해 외부로 전송할 수 있다. 최근에 베리칩은 FDA의 승인을 받아 RFID 칩이 이식되는 것에 대한 안정성문제를 해결했다.



멕시코공무원에 이식될 베리칩

위의 전자칩을 몸체에 인식하게 되면 RFID 리더기가 장착되어 있는 구역에 출입하면 그 지역내의 이동경로와 출입시간 및 퇴청시간등이 자동으로 기록되며 경우에 따라서는 칩이 이식된 사람의 활동 패턴까지 분석이 가능해지게 된다. 따라서 인체에 이식된 베리칩은 개인의 위치추적을 통한 개인통제 및 개인 정보의 외부 유출로 인한 사생활 침해가 가능해져 적지 않은 논란이 예상된다.

참조문헌	news.com, “Privacy advocates call for RFID regulation”, 2003.8.18.
------	--

사례번호	CASE 10
사례명	RFID 칩을 이용한 어린이 보호사례
사례내용	일본 오사카 지역의 학교들이 어린이 보호를 위해 RFID를 사용하기로 했다. 오사카 교육당국자들은 초등학생들을 보호하기 위해 가방, 이름표, 옷 등에 RFID를 부착하기로 하고 학교 정문을 비롯 주요지역에 리더기를 설치해 어린이들의 움직임을 추적함으로써 보호한다는 것이다. 하지만 사생활 침해 논란도 만만치 않게 일고 있는 상태다. 일본의 어린이보호를 위한 RFID사용은 사생활침해 문제가 발생될 수 있는 점과 아울러 RFID를 통한 어린이보호라는 긍정적인 결과가 동시에 발생한다는 점에서 논란이 발생할 수 있다 판단된다. 하지만 이러한 정보는 아무상관도 없는 직원 또는 부서가 열람을 하는 등의 문제가 발생되지 않도록 주의를 해야할 필요가 있다.
참조문헌	http://ittrend.egloos.com/1559089

제2절 개인정보보호관련 사례

본 절은 1절에서와 마찬가지로 RFID 개인정보보호 관련 사례이다. 하지만 1절에서의 개인정보보호 논란에 관련된 사례정리와는 달리 사전에 보호를 하는 과정, 기업의 노력, 실험을 통한 사용자의 개인정보보호 사례 등 여러 사항에 대한 자세한 내용을 언급하고자 한다.

1. RFID를 이용한 INTEROP의 방문객 관리⁸⁰⁾

80)문인주, 이정석 지음, *ICE그 활용가이드*, 북두출판사, 2004년

가. 서론

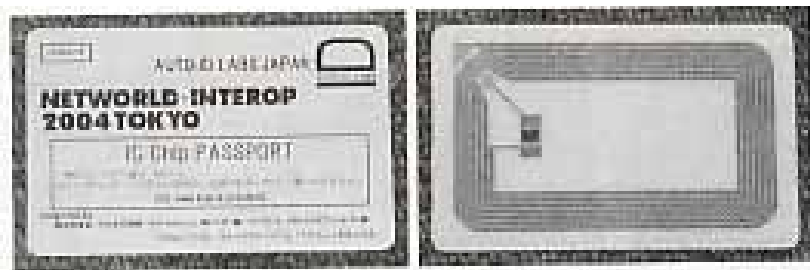
Auto-ID LAB JAPAN은 2004년 6월 30일부터 7월 2일에 개최한 'NetWorld+Interop 2004 Tokyo'에서 RFID 로 입장한 사람을 관리하는 실증 실험을 실시했다. 개최한 박람회에는 약 15만명의 관람객이 입장하여 관련사례로는 세계 최대 규모이다. 본 실험은 Interop 2004의 주최자인 미디어라이브 재팬과 공동으로 실시하였다.

나. 개인정보보호를 위해 가이드라인 준수

IC 태그는 전시회 방문객이 목에 거는 입장객 배지에 넣어, 전시관의 입구에 설치한 게이트형 리더로 인식한다. 개인정보보호를 위해 경제산업성과 총무성이 작성한 '전자태그에 관한 프라이버시 보호가이드라인'을 준수하며 개인정보보호 대책에 주의를 하였다.

프라이버시 가이드라인에서는 태그를 사용하는 사업자에 2가지를 요구하고 있다.

- 태그가 부착되어 있다는 사실과 그 기록내용을 사용자가 인식할 수 있도록 할 것
- 태그가 읽히는 것을 사용자가 원치 않을 경우, 인식하지 못하도록 하는 방법을 사용자에게 제시할 것



[그림 4-1] 'NetWorld+Interop 2004 Tokyo'의 IC 태그

따라서 주최측은 태그의 존재에 관련한 모든 사항을 방문객의 접수처에서 간판을 세워 태그가 들어있다는 것과 태그의 정보는 EPC ID 만이 보존되어 있음을 알렸다. 태그에도 앞면과 뒷면에 태그명시와 태그가 보이도록 만들었으며, 리더와 라이터가 설치되어 있는 장소에는 간판을 설치하였다.

다. TAG 무효화방법

IC 태그를 무효화하는 방법에 대해서는, 우선 회장의 출구에 설치한 리더와 라이터로 IC를 제거하는 방법을 제시했다. 태그 제조시 새겨진 Unique ID는 리더와 라이터로는 제거할 수 없다. 제거되는 것은 태그의 메모리 영역에 입력된 방문자 관리 ID 뿐이다. 태그 인식자체를 거부하는 사용자에게는 배지에 태그를 빼내어 버리는 방법을 제시하였다.

입장객 관리에는 태그와 바코드를 병용하여 같은 ID를 기록해 두었다. 입장할 때에는 바코드를 먼저 인식한 후 리더기를 통해 태그가 인식을 하는 방식으로 하였다. 이로서 사용자가 태그를 버려도 문제가 되지 않았다. 이러한 바코드와 태그의 연동은 이후에 인식률에 대한 검증차원으로도 좋은 방법이 되었다.

라. 개인정보에 관련한 내용

IC 태그와 바코드에 저장한 ID는 방문객의 개인정보와 연관지어, 주최자인 미디어라이브가 지금까지의 이벤트에서와 마찬가지로 엄중하게 관리했다. 회장에서는 IC 태그를 사용한 ‘스탬프 라리’라고 하는 애플리케이션을 사용했는데, ID를 관리하는 시스템에서는 개인정보를 기록하지 않도록 했다. 또한 시스템을 AUTO ID LAB JAPAN이 운영하고 미디어라이브의 시스템과는 별도의 시스템으로 구분함으로써 안정성을 높였다.

2. 마루에쓰사의 유통물류 사례⁸¹⁾

가. 서론

마루에쓰사는 유통물류의 개선을 위해 RFID 실험을 2단계에 나누어 진행시켰다.

1단계 실험은 2003년 9월 24일부터 2일간 진행을 하였다. 1단계의 실험은 케이스의 재질이나 케이스에 넣은 상품, 보관장소의 온도차에 의해 읽혀들이는 거리에 차이가 있는가를 조사했다. 그 결과 금속대응의 태그라면 읽힐 수 있지만 리더기를 수 cm까지 가까이 할 필요가 있는 것으로 조사되었다. 이는 RFID의 수행능력에 관

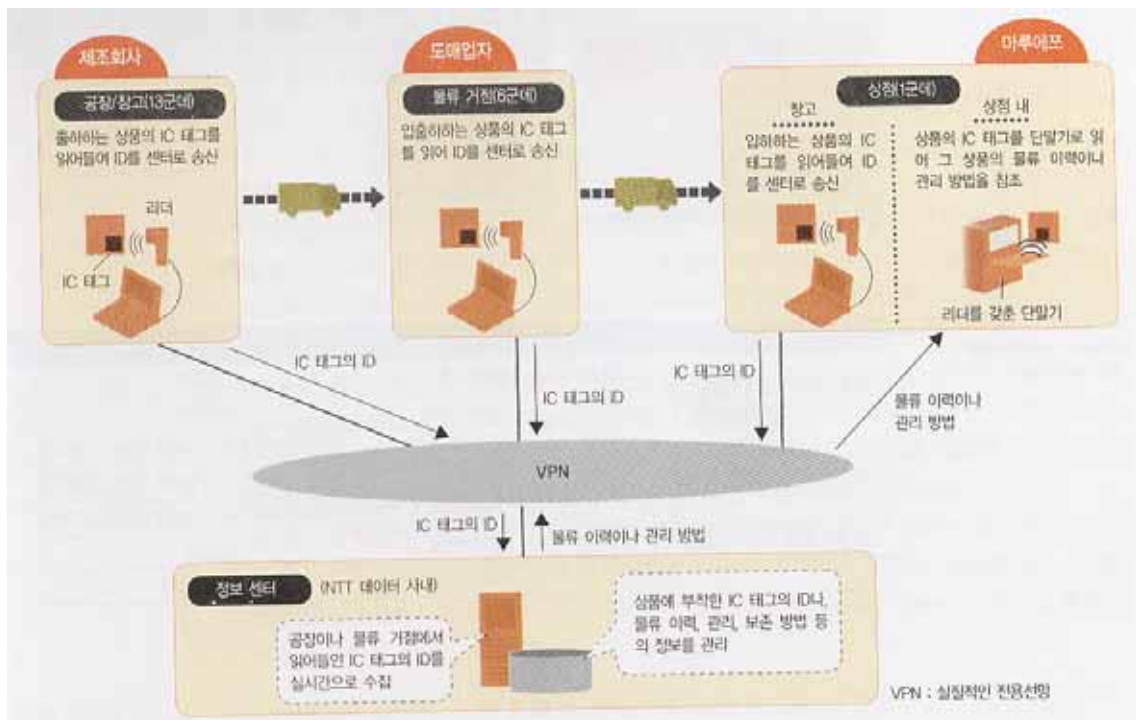
81) 일경 BP RFID 기술편집부, *유통물류 RFID*, 성안당

련한 실험으로 1단계의 실험에서는 개인정보에 관련한 내용이 전혀 없었다.

1단계의 실험 후 마루에즈 사는 2단계 실험을 실시하였다. 2단계 실험은 2003년 10월 6일부터 11월 23일까지의 실험은 식품메이커 공장과 창고 13군데, 도매업자의 물류창고 6군데, 마루에즈의 상점 1군데로 확대했다. 아이템은 야채, 정육 30품목과 가공식품 77품목 합계 107품목에 태그를 붙여 상품의 물류이력을 관리하는 실험을 실시하였다.

나. 실험과정

실험의 과정은 아래의 그림과 같다.



[그림 4-2] 마루에즈사의 2단계 실험 구성도

- 식품메이커는 출하시에 각각의 상품에 태그를 부착하고, ID를 읽어 들인다.
- 읽어 들인 ID는 NTT 사내에 설치된 서버로 실시간 전송된다. 단, 맥주와 같이 생산라인으로부터 상자포장까지 자동화된 제품의 경우에는 상점, 도매업자의 물류거점에서 상자에 태그를 붙인다.
- 도매업자는 식품메이커로부터 상품이 입하되면 상자에 상품의 태그를 각각 읽어들인다. 이 정보는 정보센터의 서버로 보내져 도매업자의 입하데이터로서

관리된다. 출하시에는 같은 방법으로 상품의 태그를 읽어들이고 출하데이터로서 관리를 한다.

- 마루에쓰의 상점에 상품이 도착하면 상점의 종업원이 상품의 태그를 읽어들이고 입하처리한다.

마루에쓰 상점내에는 리더의 기능을 갖춘 단말기를 설치한다. 고객이 단말기가 설치된 장소에 태그가 붙은 상품을 두면 모니터에 관련 정보(상품의 물류이력, 생산지, 조리방법 등)들이 나타난다. 식품메이커와 도매업자, 마루에쓰는 PC를 통해 정보센터의 서버에 접속하고 물류이력이나 판매 상황을 확인할 수 있다.



[그림 4-3] 2단계 실험의 IC 태그

제2단계에서는 대, 중, 소 3종류 크기의 태그를 준비하고 상품패키지의 크기에 따라 나누어 사용하였고 사용한 태그의 수는 4만개가 넘었다.

다. 사생활 침해에 대비한 실험방법과 결과

마루에쓰는 제2단계 실험을 수행할 때 알루미늄으로 되어있는 보냉용 봉투 100장을 계산대 근처에 준비하고 있었다. 소비자로부터의 사생활침해에 관련된 클레임을 걱정하였기 때문이다. 보관용 봉투에 태그가 붙은 상품을 넣으면 태그의 ID를 읽을 수가 없다. 그러나 실험에서의 결과는 보관용 봉투가 1장도 사용되지 않았다. 사생활 침해가 우려된다는 클레임도 없었다. 오히려 소비자는 태그를 적극적으로 활용하고 있었다. 실험 중 단말기를 통한 정보제공 서비스를 이용한 소비자는 다양한 요리내용을 추가해 달라는 요청을 하라는 요청이 잇따를 정도로 호의적인 사용태도를 보였다. 특히 상품의 생산지, 농약, 생산환경, 유효기간 등 안전에 관련된 정보의 요구는 높았다.⁸²⁾

3. 일본의 IC 카드 운전면허 실험사례

가. 서론

2002년 경찰청에서는 6월 시행의 개정 도로교통법에 의해 운전면허증의 기재사항이 전자적 방법으로 기록할 수 있게 되었다. 이후 2004년도에는 점차적으로 운전면허증을 비접촉식 IC 카드로 전환한다는 방침을 세웠다. 이러한 시스템을 운영하려는 의도는 본인 확인 수속을 간소화하려는 목적으로 만들어지는 것이며, 내장되는 태그는 8킬로바이트의 용량에 얼굴사진과 주소 등의 정보를 입력한다. 통신 주파수는 13.56MHz이다.



[그림 4-4] 일본경찰청의 IC 태그 운전면허증

나. 사용목적

RFID 시스템을 도입하려는 목적은 다음과 같다.

- 운전면허증의 위조방지이다. RFID 태그를 통해 위조를 구분해내기 위해서이다. 최근 수년동안 PC 등을 사용해 정교하게 운전면허증을 위조한 사례가 증가하고 있다.
- 경찰업무의 효율화이다. 교통위반 티켓이나 면허갱신 사무의 시간단축을 목표

82) 이는 태그의 정보를 긍정적으로 사용하였고, 사전에 사생활 침해에 대한 대비와 교육이 있었기 때문에 소비자들이 호의적으로 반응하였다고 판단된다.

로 한다.

위의 2가지 목적을 위해 일본 경찰청은 RFID 기술을 도입하기로 결정하였다.

다. 개인정보보호 방법

신분증의 정보를 입력한 태그이기 때문에 사생활 침해의 위험이 생길 수도 있다. 따라서 경찰청은 다음과 같은 방법을 취했다. 먼저 개인정보보호를 위한 기구를 구성하였다. 기록한 정보를 읽어 들이는 권한은 면허 보유자와 공안위원회가 가지며 공안위원회만이 정보를 기록할 수 있다. 구체적으로 4자리 숫자로 구성된 2종류의 PIN(Personal Identification Number)을 사용한다. 면허보유자는 운전면허증을 신분증명에 사용할 때는 PIN을 입력한다. 입력행위는 개인정보를 읽어 들이는 것을 허용하는 의사표시가 된다.

2종류의 PIN을 준비하는 이유는 ‘일반 데이터’와 ‘본적과 사진’ 2종류로 데이터를 나누었기 때문이다. 특히 본적은 외부에 표시하지 않기를 원하는 사용자들을 위해 내부메모리에만 입력을 한다.⁸³⁾

4. 의약 유통 물류 관련 사례

가. 서론

33개주에 있는 4087개의 지점과 11만 명의 노동자가 근무하는 CVS(의약품회사)는 미국 안에 존재하는 모든 의약 처방에서 10.6%의 비중을 차지하고 있다.



[그림 4-5] CVS 로고

CVS는 RFID 기술을 이끌고 있다. 이 회사는 2001년 후반기에 MIT의 Auto-ID-Center와 접촉하기 시작했고 2002년 5월에 Center에 가입했다. CVS는 또한 제약 산업에 있어 RFID 개발을 처음 시도한 Jump Start 프로젝트를 이끌어오

83) 외부에서 제3자가 리더기를 통해 읽는 경우는 13.56MHz에서는 확률적으로 적으며 PIN을 통해 야 되기 때문에 거의 불가능하다.

고 있다. Jump Start 프로젝트는 RFID 기술을 공장으로부터 약국까지 제약 과정을 추적하는 프로젝트이다. 이러한 프로젝트를 하는 이유는 단지 구매고객에 대한 서비스를 위해서가 아니라 RFID 도입을 통하여 회사의 기초 라인에서부터 최종 소비자까지의 안전을 위해서이다.

에이즈 치료제인 AZT를 복용하고 있다는 사실은 환자가 에이즈에 감염되었다는 사실과 동일하다. 이는 지극히 프라이버시적인 정보로서 보호가 되어야 한다. 따라서 CVS는 소비자들의 사생활을 보장하기 위하여 CVS 의약품 종류들과 관련 되는 물품들은 처방 쓰레기들로부터 따로 분리되었다. 프린트된 것들, 빈 유리병, 남은 병, 그리고 남은 쓰레기들은 검푸른 투명한 백에 넣어져서 HIPAA의 동의를 얻은 곳에서 특별한 쓰레기들만 다루어지는 분배 센터로 회수되었다.

또한 이전의 시스템에 경우 500개의 알약 병은 1000달러의 가치를 지닌 채 3년에서 4년 동안의 유통기한을 지닌 채 유통되었다. 게다가 제조업들은 전 세계 도처에 구매되었고 운송되어졌다. 그 결과 도매업자들과 다른 중개자들은 제조 약을 예상되어진 경매 가격이 아닌 국제 환율 변동가와 이자 비율의 변동을 고려하였다. 그리고 그 결과 공급자들과 CPG의 운송업자들은 비교적으로 후하게 세일을 하고 제조업의 움직임을 숨겼다. 즉 가격을 높이기 위해 도매 후의 추적이 불가능하게 만들었다.

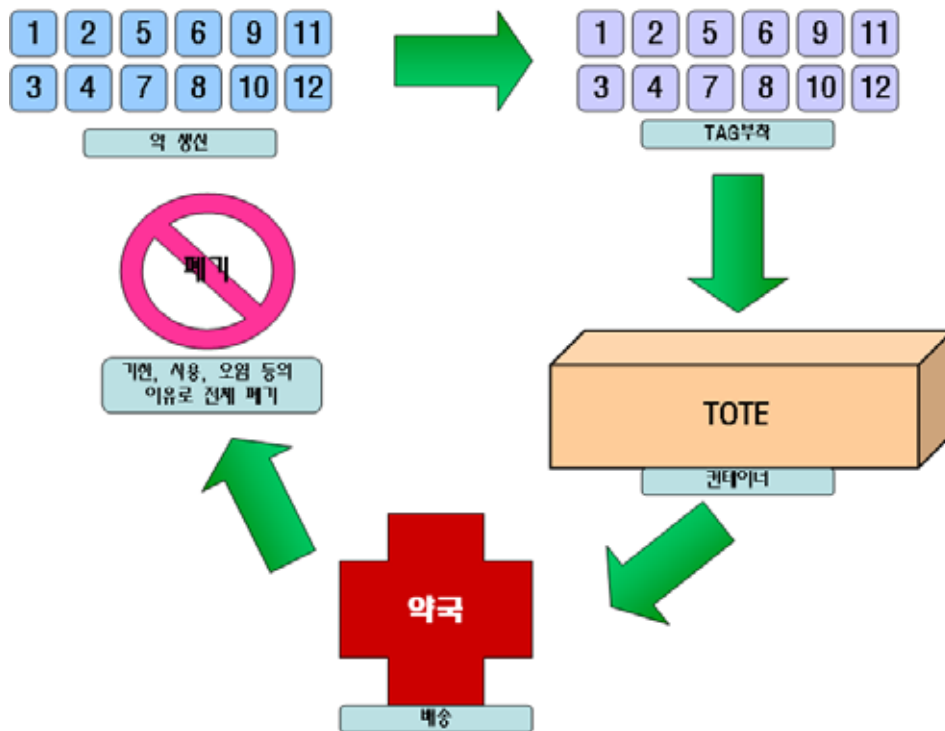
이는 테러리스트들이 1982년에 불순했던 Tylenol과 같은 방식을 제약업계에 시도하지 않을까 염려하게 만드는 것과 같다.

나. Project jump Start

소비자들의 재화의 움직임을 추적하기 위한 RFID의 사용 표준 모델의 장점 중 한 가지는 조제 산업의 시스템이 적용하기에는 어렵기 때문이다. 그래서 Jump Start는 의약 산업에서 추적할 수 있는 RFID의 개발을 완전하게 테스트하기 위하여 모든 공급 사슬을 중지한 채 만들어졌다.

Jump Start는 10개의 선택되어진 약들에 대한 EPC의 전체 규모의 시험으로서 계획되어졌다.⁸⁴⁾ 실험에서 제약사들은 제조 시점의 EPC 태그를 전자 추적 장치로써 우선적으로 전환하는 경향을 보였다. 그 항목들은 표준적인 경우와 각각에 그 것으로 태그가 주어진 경우로 분류되어졌다. 따라서 그 경우에 72개의 병 안에 73개의 태그를 가지고 있다.

84) [그림 4-2] Project Jump Start 구성도 참고



[그림 4-6] Project Jump Start 구성도

배송되는 약품이 검사될 때 생산자의 컴퓨터는 EPC코드뿐만 아니라 각각의 병의 만료된 기간까지 포함될 것이다. 이런 상품은 수레에 옮겨 담겨지고 그리고 배달센터(D,C)로 보내지게 될 것이다. 이 상품이 배달센터로 도착했을 때 이것은 다시 식별된다.

여기에서 컴퓨터는 제조업자가 가지고 있을 때와 같은 72개의 병으로 되어있는 상품인지 검사할 것이다. 만약에 그것이 아니라면 그 상품은 변경될 것으로 판단되고 그리고 되돌려 보내질 것이다. 만약에 모두 괜찮다면 그 상품은 배달 센터 안에 남겨지게 될 것이고 목록에 남겨지며 특정한 약국에 꼭 재보급 될 것이다. 이 시점에서 그 상품은 열려지고 특정한 숫자의 병에 포장된 tote 라고 불리는 플라스틱 컨테이너 안에 포장 된다. tote 칸은 12개의 병으로 고정되어 있습니다. 각각 약국은 의례적으로 일주일에 5-8개의 tote를 받게 된다.

그 tote는 배달센터(DC)를 떠나면서 식별 받게 될 것이고 트럭에 놓이게 된다. 그것은 약국에 들어갈 때 다시 식별될 것이다. 그리고 컴퓨터는 그 상품이 플러스, 마이너스, 또는 교체가 있는지 검증하게 된다. 컴퓨터는 또한 이전에 놓인 제품을 찾게 된다. 예를 들면 같은 EPC태그는 여러 위치를 보여주게 된다.

병은 약국의 선반에 위치하게 될 것이고 그 내용물은 개인의 처방의 약병에 담겨서 일주일 또는 한달동안 거쳐서 천천히 분배된다. 그 병이 비었을 때 그것은 쓰레기

로 흐르고 그리고 EPC 태그는 확실히 폐쇄될 것이다.

다. 개인정보보호 대책

현재 Jump Start는 의약품코드 정보가 들어있는 경우이다. 이는 개인정보와는 기본적으로 관계가 없다. 물론 의사의 처방전이 연계되면 개인정보화가 될 가능성은 존재한다.

그래서 CVS는 개인정보보호를 위하여 다음과 같은 준비를 하였다.

프라이버시 가이드라인은 아직 완성되지 않고 있고, 소비자에 대한 프라이버시 교육이 이루어지지 않고 있다. 또한 CVS의 지침에는 KILL태그가 없기 때문에 제거 가능한 태그에 대한 접근을 시도하려 했다.

모든 약병에는 조그마한 flag가 있다. 만약 소비자들이 선택을 하면 flag를 통해 태그를 떼어낼 수 있다고 통지를 할 계획을 수립하였다. 또한 FDA와 약내의 RF에 관한 효능을 조사하여 승인을 얻어 시스템의 안정성과 신뢰성을 높일 수 있도록 했다.

5. P&G의 유통물류 사례

가. 서론

광고 분야 세계최대 기업 중 하나인 Procter & Gamble과 같은 일부 기업은 인터넷을 “New Media” 채널이라고 한다. 일부 소비자 기업들은 “큰 손”이라고 부르기도 한다. “무엇을 하고 무엇을 사는지 모두 알고 있다.”라는 식의 개인 프로파일에 대한 요구는 이미 1990년대부터 시작된 개념이다. 2000년 미국에서 진행된 연구에 따르면 소비자의 95%는 어떤 식으로든 자신의 개인정보가 오용될 가능성에 대해 우려를 나타냈다. 오늘날 미국 소비자의 71%는 몇 년 전보다 오늘날의 개인정보보호에 관련된 관심이 증가했다고 인식하고 있는 것으로 나타났다. 다시 말하자면 “개인정보관련 문제”는 사라진 것이 아니라 새로 소개되는 모든 신기술들은 공정한 정보의 이용과 건전한 개인정보 원칙을 준수해야 한다는 것을 의미한다. Procter & Gamble의 인터넷 마케팅 관련 경험은 소비자의 신뢰를 증대시키는 표본으로써 개인의 정보와 프라이버시를 존중하면서 지속적으로 수익을 보장하고 뛰어난 마케팅을 이루어낼 수 있는 예가 된다. 본 사례에서는 RFID의 공급망 적용에 있어서 이러한 원칙들을 어떻게 적용할 수 있는지에 대하여 알아보도록 한다.

나. P&G의 프라이버시 정책

P&G의 프라이버시 원칙은 한 국가의 개인 프라이버시 법률에 국한된 것이 아니라 OECD가 제정한 원칙, EU의 데이터보호 정책, 미국 소비국/EU Safe Harbor 프라이버시 원칙 등과 같이 국제적으로 적용될 수 있는 프라이버시 원칙에 입각한 것이다. P&G의 원칙들은 다음과 같다.

- 우리는 개인의 정보를 우리의 정보처럼 보호한다.
 - 보안 통제와 데이터를 관리하는 가이드라인은 지속적으로 수정되고 평가되며 감독된다.
 - 우리는 P&G에 위임된 개인정보를 교환, 판매, 누락시키지 않는다.
- 우리는 소비자들에게 다음의 사항에 관하여 정보를 제공한다.
 - 개인 데이터의 사용과 결과적 이익에 관한 내용
 - P&G와 보다 자세한 의사소통을 위한 방법
 - P&G에 제공한 개인 데이터 사용의 금지와 수정에 관한 방법

성공적인 기업은 소비자 프라이버시의 보호가 단지 법을 준수한다는 개념 이상이라는 것을 알고 있다. 이것은 오래전부터 알려진 가장 일반적인 좋은 사업의 예이다.⁸⁵⁾ 2백만 명이 넘는 학부모들이 설문을 통하여 이름, 주소, 자녀의 나이, 가계 수익 등 개인정보에 관하여 P&G에 대한 신뢰를 보였다. 따라서 P&G는 이들에게 미취학자녀, 취학자녀, 임신 개월 수 등을 고려하여 맞춤 뉴스레터를 제공하였다. 뉴스레터에는 전문가들로부터 아이들의 게임과 활동에 관한 조언과 기술들을 문답 형식으로 담고 있다. 온라인상에서는 개인정보들의 보안, 개인정보 수정을 위해 취할 수 있는 방법, 뉴스레터 수신 거부 등에 관련된 내용들을 제공하고 있다.

다. P&G의 Supply Chain RFID 적용

P&G는 RFID 기술을 공급망에 적용하기 위한 노력을 기울이는 선두기업들 중 하나였다. 소비제품산업의 공급망은 제작자와 공급자 사이의 제품 흐름으로 구성되어 있다. 이런 흐름은 제작자의 warehouse와 distribution center사이, distribution

85) P&G의 예는 1996년 출범한 Pampers Parenting 웹사이트와 뉴스레터에서 발췌하였다.

center와 소매상의 warehouse사이, 그리고 개별적 소매상에서 선반의 제품을 구입하게 되는 소비자 사이의 교환이 모두 포함된다.

수년간, 컴퓨터 시스템과 전자 데이터 네트워크는 공급망상의 제품들의 추적을 가능하게 하였다. 하지만 언제나 추적과 관련된 균형이 이루어지는 것은 아니다. 제품의 도난, 불량, 파괴, 부정확한 개수 파악 등이 존재하기 때문이다. 따라서 이런 모든 내용을 체크한다는 것은 많은 시간과 자원을 필요로 하게 되지만 단 하나의 경우도 빠뜨려서는 안 되는 중요한 사항들이다. 과거 바코드 사용의 도래는 공급망에 있어서 효율성의 증대를 가져다주었다.

하지만 바코드와 인식기의 여러 장점들에도 불구하고 공급망에 있어서 부족한 부분은 여전히 존재한다. 바코드는 반드시 물리적으로 볼 수 있어야 하고 스캐닝이 가능하여야 하기 때문이다. 설사 컨베이어 벨트가 자동 스캐너나 직원의 실수로 제품 스캔이 이루어지지 못하는 상황이 발생되지 않더라도 정밀함은 떨어진다. 분실된 제품이나 물리적 스캔을 통해 추적당하는 경우 고부가 가치의 소비자 서비스를 제공하는 방법 등으로 이를 보완할 수 있다.

EPC와 결합된 RFID 기술은 기존의 바코드를 속도와 정밀함에 있어 한 단계 올려놓았다. 인식을 위해 장비까지의 라인이 필요한 바코드와는 다르게 RFID 기술은 라디오 주파수를 통해 정보의 detect, read, transmit가 동시에 여러 EPC를 대상으로 이루어진다. 만약 하루 동안 대략 8-12% 발생되는 재고량 부족 제품을 원하는 소비자들이 있을 경우 소비자의 실망은 증가될 것이고, 이로인해 P&G의 매출은 떨어지게 될 것이다. P&G는 소매상들로부터 소비자들의 요구를 즉시 인식하지 못하기 때문에 65일 이상의 개발, 매년 \$3 billion의 투자를 유지하고 있다. 따라서 공급망에 불필요한 비용을 추가로 지출하고 있는 셈이다. 이러한 이유로 P&G는 MIT Auto-ID Center가 EPC 네트워크를 제안하였을 때부터 이 기술에 뛰어든 것이다.

P&G는 Auto-ID Center의 초기 후원자였기에 마케팅부의 Kevin Ashton을 책임자로 임명하는 등 기술과 관련된 방침 마련에 노력하였다. Auto-ID Center는 2000년부터 이와 관련된 사안을 논의하였고 2001년 P&G 조사 기구를 이용하여 온라인 연구도 시행하였으며 2002년에는 더 광범위한 분야의 연구를 시행하였다. 연구 결과에 따르면 70%의 소비자가 프라이버시와 관련된 기술에 관심을 보였고 건강과 안전, 환경이 그 뒤를 이었다. 이 연구를 통해 얻은 가장 핵심적인 결론은 Auto-ID Center에 방침과 관련한 독립적인 전문가가 필요하다는 것이었고 이에 따라 2002년 Independent Policy Advisory Council이 설립되었다. 첫 회의는 2002년 가을에 개최되었다. 이와 함께 EPC 기술의 발전은 MIT Auto-ID Center의 “come out of the lab”의 관점으로 진행되었고 실제적인 유연성과 이익을 시험할

수 있는 환경(the field)을 중심으로 하였다.

P&G에서는 현재 EPC와 관련한 제품과 케이스들에 가장 높은 관심을 기울이고 있다. EPC 프로그램의 두 가지 기본 요소는 pallets와 wired dock doors이다.

첫 번째 시험은 독일의 Metro Future Store와 함께 이루어진 것으로 현재도 진행 중에 있다. 이 스토어에서는 소비자들에게 널리 알려진 여러 가지 최신 기술들을 사용하고 있다. 현재 검증을 통한 pallets, 케이스 등을 포함하여 기술적 이익과 결점에 대한 정보를 확보하고 있다. 또한 실제로 펜틴 샴푸 통에 부착된 EPC Tag와 같이 쉽게 인식할 수 있는 Tag를 부착한 제품들이 존재하고 있다. Tag는 제품 구매 후 탈착되어 사용하지 못하게 되며 “smart chips”에 관한 정보를 진열대에서 확인할 수 있다. Metro 사는 최근 RFID 사용에 대한 시험을 통해서 프로세스의 효율성을 기존의 12%에서 17%까지 증대시켰다. 분실과 도난은 18%에서 11%로 줄어들었고 물품 동원력도 9%에서 14%로 증대되었다. 하지만 이러한 데이터들이 RFID 시스템의 완벽성을 나타내주는 것은 결코 아니다.

또 다른 시험은 오클라호마 주 Wal-Mart Store의 Max Factor Lipfinity Lipstick을 통해 2003년 봄 4개월에 걸쳐 이루어졌다. Tag가 부착된 제품들은 P&G를 떠나는 때와 공급망의 각 지점에서 read 되었다. International Paper에 의해 제작된 Intellishelf는 RFID/EPC를 통해 6개의 진열대에 사용되고 Max Factor Lipfinity Lipstick의 39종 모두를 수용하고 있다. 이 진열대는 컴퓨터 소프트웨어 시스템과 연결되어 웹사이트와 휴대용 컴퓨터(PDA)를 통해 Wal-Mart와 P&G측에 다음의 때에 정보를 제공한다.

- 진열대의 수용량이 다 찼거나 거의 다 찼을 경우 이에 대한 정보를 제공할 때
- 제품이 잘못 배치되었을 경우 이를 수정하기 위한 정보를 제공할 때
- 도난의 증후가 발견될 경우 도난이 이루어지기 전에 이에 대해 대응할 때

시험의 결과는 Metro에서 보고한 것과 비슷하게 나타났다. Tagging pallets와 cases가 Item-Level의 경우보다 더 신뢰성 있고 정밀하였다. 또한 Tag의 가격과 진열대 Reader 때문에 Item-Level Tagging은 그 발전 기간이 길고 유연성을 확보하는데 다소 시간이 걸릴 것으로 나타났다. 이런 Item-Level에 관한 시험 결과에 따라서 pallet와 case의 Tagging에 초점을 맞춰 기술, 수익의 정의, 방침 등과 관련된 Item-Level Tagging에 대한 연구를 지속하여야 한다.

P&G와 Wal-Mart는 이런 시험에 관련해서 정확하지 않은 기사를 접하게 되었다. 이 기사에서 빠진 부분은 다음과 같다.

- EPC Tag는 lipstick 포장 안쪽에 부착되어 있기 때문에 포장을 제거하면 Tag 역시 제거할 수 있다.
- Wal-Mart는 시험이 이루어지는 4개월 동안 진열대에 “전기 제품 시스템”이라고 표기하였고 소비자들로부터 어떠한 의문점이나 의견을 수렴하지 않았다.
- P&G와 Wal-Mart 모두 Tag의 Reading과 관련한 물리적 관찰을 위해서 사무실과 연결된 Web 카메라를 설치하여 진열대를 감시하였다. 따라서 카메라 시야 안에 들어온 소비자들은 그 뒷모습이 포착되었다. 또한 카메라 시야 앞에서 돌아섰을 경우 신분 노출이 가능하였다.
- Store 바닥을 포함하여 계산대 등에는 더 이상 EPC Reader가 설치되어 있지 않다.

이 기사는 위의 사실이 언급되지 않은 채 널리 퍼지게 되었고 결국 Wal-Mart와 P&G 제품을 상대로 소비자들의 항소가 이루어졌다. 하지만 예상보다는 적은 숫자인 P&G는 RFID/EPC과 관련하여 50건 미만의 소비자 불만만이 접수되었다.

앞에서 언급하였듯이 Auto-ID Center 연구의 경우와 같이 P&G는 소비자의 프라이버시와 관련하여 선두 역할을 담당한다. 이것은 다음의 두 가지를 통해서 이루어질 수 있다.

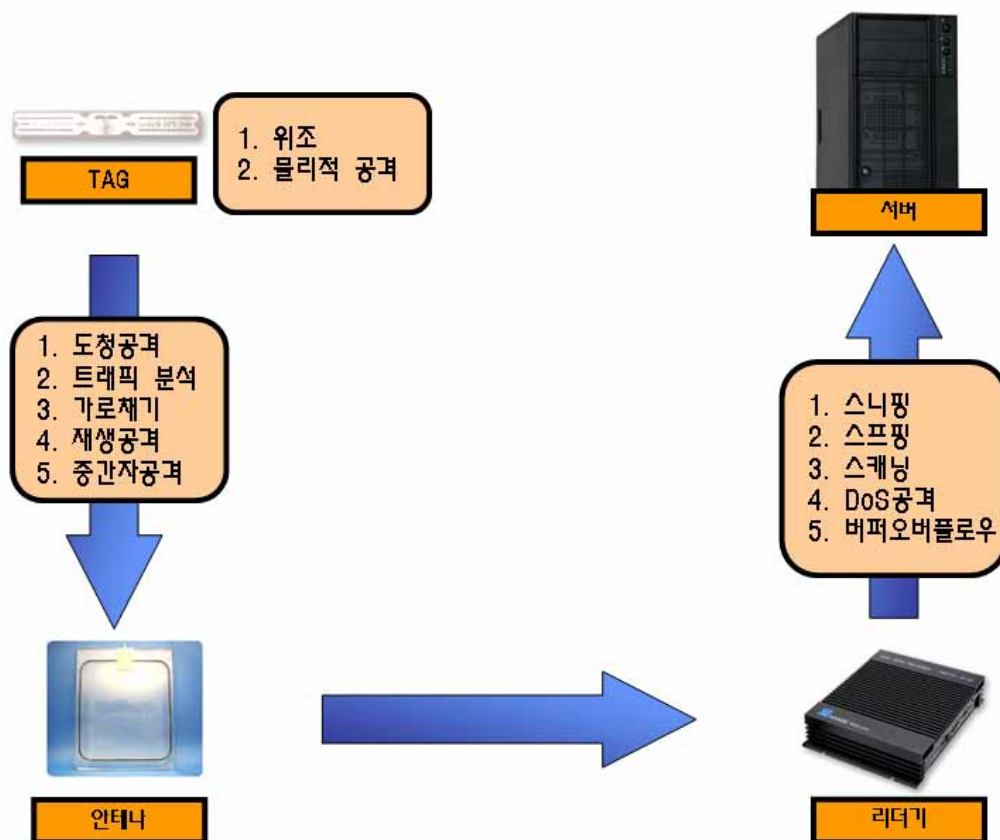
- 내부적으로 다른 기업들의 모델로써의 역할을 담당한다.
- 외부적으로 EPCGlobal Public Policy Steering Committee를 통한다.

이처럼 P&G는 EPC Global 의 가이드라인을 정확히 준수함으로써 소비자들의 개인정보보호를 위해 노력을 하고 있다.

제 5 장 RFID 개인정보보호 관련 기술

제1절 침해기술

본 절에서는 RFID 시스템의 구성요소에서 침해를 유발하는 공격기술에 대해 조사하여 정리하였다. 다음의 그림은 구성요소에서 발생하는 기술을 정리한 그림으로 보고서의 내용과 더불어 참조하길 바란다.



[그림 5-1] RFID 시스템에서의 침해기술

1. 도청공격

RFID 시스템은 바코드시스템과 달리, 효율성을 높이기 위해 수 미터 범위 내에서 리더와 태그 간에 통신이 가능하도록 되어있는 라디오방식이기 때문에 누구든지 태그에 접근하여 태그의 출력 값을 얻을 수 있어, 인가되지 않은 리더가 적절한 접근제어기능이 없는 태그에 접근하여 프라이버시를 침해하는 보안의 문제점을 갖는

다.

도청공격의 형태로는 공격자가 리더를 갖고 태그를 스캐닝하는 적극적 공격과, 리더와 태그 간 통신을 RF 수신하는 수동적 공격이 있다.

이에 대해 자세히 말하면, 적극적 공격이란 공격자가 리더를 가지고 각 태그를 직접 읽어 들여 정보를 유출하는 것을 말하고, 수동적 공격이란 공격자가 리더의 전파를 들을 수 있는 곳에서 태그로부터의 응답을 직접 듣지 못하더라도 이 정보를 수집하여 어떤 태그가 존재하는지, 혹은 그 이상의 정보를 알아낼 수 있다. 수동적 공격의 경우 거리에 따라 도청의 가능성이 좌우되는 데 원거리에서 도청을 시도할 경우, 리더가 태그에게 보내는 질의는 도청이 가능하지만, 질의에 대한 태그의 응답은 약한 신호 때문에 도청하기 어렵다.

일반적으로 Tree Walking 알고리즘에서는, 매 단계마다 모든 상태와 명령을 공중에 전송한다. 하지만 특정한 경우에는 통신에 필요한 정보의 양이 증가될 수 있다. 비트를 태그들로부터 수집하여 첫 번째 비트에 0으로 시작하는 태그와 1로 시작하는 태그가 존재하고 리더는 0으로 시작하는 태그들에 대하여 2번째 자리에 대한 응답을 지시하고, 0으로 시작하는 태그들 중 두 번째 자리가 0인 태그와 1인 태그 모두 있을 경우, 이와 같은 작업을 반복 수행한다.

만약 3개의 태그가 모두 0으로 시작한다면 첫 번째 비트에 대한 리더의 질의에 대해 모든 태그가 0으로 응답을 하게 되면 충돌(Collision)이 일어나지 않으므로, 리더는 모든 태그가 0으로 시작한다는 것을 알고 있으며, 이 경우 다음 단계에서 0으로 시작하는 태그만 응답하라는 명령이 아닌, 기존의 단계에서 충돌이 없었다는 것만을 알려주는 메시지를 이용하면 도청자는 현재의 단계에서 결정된 비트가 0인지 1인지 판단할 수 없다.

하지만 이럴 경우 해당 순서의 비트는 알 수 없지만, 그 이후에 존재하는 비트들 중에 충돌이 일어나는 경우에는 역시 도청자가 다음과 같이 정보를 축적해 나갈 수 있다.

태그가 전송하는 ID 정보의 비트 타이밍과 리더가 전송하는 랜덤 ID정보의 비트 타이밍이 동기화 되어 있다고 가정할 경우, 일치하지 않는 비트 값들은 충돌이 발생하게 된다. 태그의 실제 ID를 '1010100'이라 하면 리더가 랜덤하게 발생시킨 ID는 '0101010'이다. 두 ID가 동시에 전송시 백워드 채널의 가청 범위에 있는 장치들이 수신하게 되는 ID는 'XXXXXX0'이 된다. 여기에서 'X'는 충돌이 발생하여 '0' 또는 '1'에 대한 정확한 인식을 할 수 없게 된 비트를 나타낸다. 이러한 신호를 제 3자가 도청하였을 경우, 이 충돌이 발생한 비트를 정확히 재생해 내는 것은 확률적으로 어렵다.

2. 트래픽분석

리더와 태그 간 통신 중 트래픽 분석을 통한 위협이 존재한다. 공격자가 어떤 특정 지역 내지 특정 태그에서 리더와 태그간의 트래픽 분석에 의한 통계 기반의 식별 정보를 추적할 수 있다면, 공격자는 그 지역에서 어느 정도의 트래픽이 존재하는지, 어느 정도의 물품이 존재하고, 빠져나가는지에 대해서 알 수 있다.

현재 Tag ID 정보와 이전 ID 정보를 알고 있는 공격자는 가상의 Tag로 위장하는 공격이 가능하며 Tag ID 정보를 알고 있는 공격자는 상대적으로 추측이 용이한 LST 정보를 추측할 수 있다. 태그의 내용이 보호되고 있다 하더라도, 예측되는 태그의 응답 값은 태그와 태그 소유자의 신원(Identity)을 연결시킬 수 있는 정보를 제공해 주기 때문에 태그가 유일한 식별정보를 노출하지 않는다 하더라도 태그의 응답 값에 대한 분석을 통해 태그를 소지한 사용자를 추적할 수 있다. 무선 트래픽 상에서 비밀성을 보호하는 것이라면, 태그 자체가 가지고 있는 정보에 대한 비밀성도 중요하다. 태그를 잃어버리거나 도난당했을 때, 태그 속에 저장된 정보는 암호화 되지 않고 저장될 것이기 때문에 적절한 리소스를 갖는 공격자는 저장된 정보를 열람하고 유출시킬 수 있기 때문이다.

이러한 트래픽의 분석 방법에는 실시간 트래픽 분석 방법과 일괄처리 트래픽 분석 방법이 있다.

실시간 트래픽 분석은 패킷 하나를 캡처 할 때마다 바로 분석하여 트래픽 정보를 업데이트 하는 방법이다. 실시간으로 누적되어 증가하는 네트워크 트래픽 정보를 확인하기 좋고 패킷 헤더정보를 저장하는 것이 아니라 분석된 트래픽 정보를 저장하는 것이 특징이다.

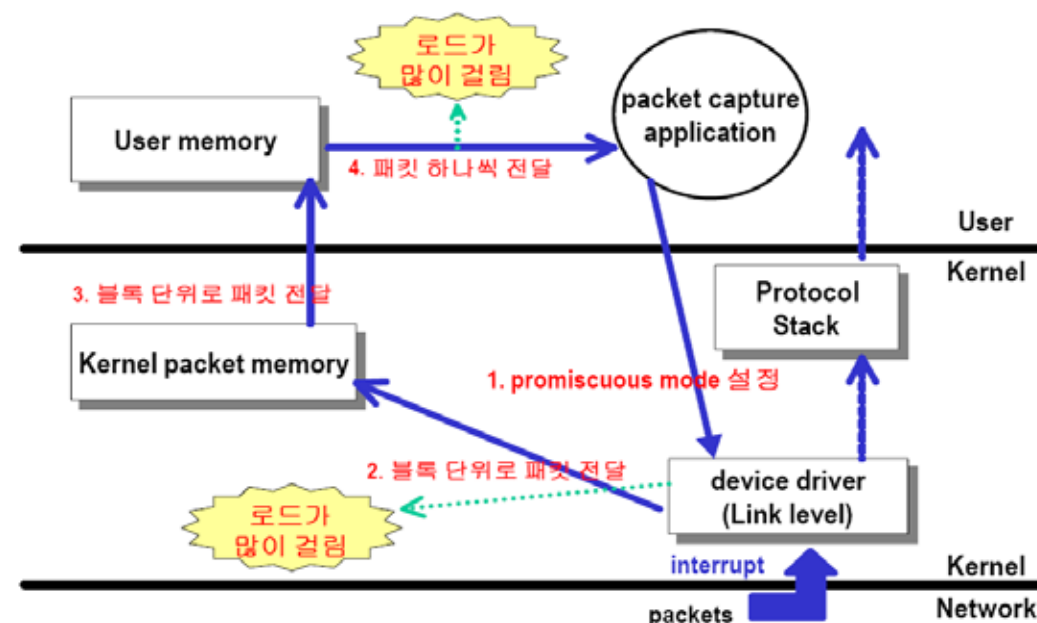
실시간 트래픽 분석 방법은 패킷을 캡처한 뒤 바로 분석하므로 사용자가 요청한 시간의 트래픽 정보를 바로 확인 할 수 있는 장점과 분석 정보만 저장하므로 저장 공간이 절약된다는 장점이 있다. 그러나 한 패킷을 처리하는 데 CPU 로드가 증가하여 대용량 트래픽 분석 시 패킷 손실이 많고 정해진 규칙대로만 분석 할 수 있어 분석에 제한이 있는 단점이 있다.

반면 일괄처리 트래픽 분석 방법은 시간 간격 별로 증가 혹은 감소를 반복하는 네트워크 트래픽을 시간 간격으로 확인하기 좋으며 트래픽 정보도 저장 할 수 있으나 패킷의 헤더 정보를 일정한 시간 동안 반드시 저장해야 분석 할 수 있다는 특징이 있다.

두 가지 방법의 큰 차이는 트래픽 저장과 분석시점에 있다. 실시간 트래픽 분석 방법은 패킷 캡처 후 바로 분석하는데 패킷 캡처 어플리케이션이 패킷을 하나씩 처

리하므로 CPU 로드가 증가 할수록 커널 메모리에서 사용자 메모리로 블록 단위로 복사되는 패킷을 모두 처리하기 힘들어서 메모리가 부족해지면 패킷 캡처 어플리케이션이 처리하지 못한 사용자 메모리의 패킷들은 버려지게 된다. 이런 문제로 발생하는 패킷 손실은 대용량 트래픽에서 더욱 심각한 문제를 발생한다.

반면 일괄처리 트래픽 분석 방법은 패킷 하나를 캡처 할 때마다 패킷의 헤더 정보를 저장해 놓으므로 분석에 제한이 없는 장점이 있다. 필요한 패킷의 헤더 정보를 시간 축과 함께 저장해 놓으면 패킷을 하나 발생시킨 호스트의 특정 시간대의 서비스까지도 정확하게 분석 할 수 있으며, 패킷 캡처 시간이 짧아 대용량 트래픽의 패킷 캡처 시에 실시간 트래픽 분석 방법보다 패킷 손실이 적다. 그러나 패킷별로 헤더 정보를 계속 저장해야 하므로 저장 공간이 늘어나는 단점이 있다.



[그림 5-2] 패킷 캡처 원리 및 패킷 손실⁸⁶⁾

트래픽 분석 기술(Traffic Analysis Techniques)은 프로토콜 인식(Protocol Identification) 후 공격트래픽인지 아닌지 판별하는데 사용되는 다중 분석 기술로써, 효과적인 IPS는 프로토콜 분석(Protocol Analysis)⁸⁷⁾, RFC 컴플라이언스 체크(Compliance Checking)⁸⁸⁾, TCP 리셈블리(Reassembly)⁸⁹⁾, 플로우 어셈블리/시물레

86) <http://dpnm.postech.ac.kr/thesis/01/soonhwa/powerpoint.pdf>

87) 알려진/알려지지 않은 위협을 방어하기 위해 사용되는 핵심 기술

88) 프로토콜 승인(Protocol Validation) 혹은 프로토콜 어노말리 기술, 트래픽이 RFC 표준을 준수하지 않는 경우 보안 이벤트 생성, 애플리케이션 프로토콜의 RFC 표준을 준수하지 않는 응용프로토콜에 의해서 다수의 폴스 포지티브/네거티브 가능성 존재, 따라서 이 기술 단독으로는 거의 쓰이지 않고 다른 기술들과 결합해 사용.

89) IPS를 우회공격하기 위해 공격 패킷 프래그멘테이션(Fragmentation)하는 경우에 대응하기 위한 기

이션(Flow Assembly/Simulation)⁹⁰⁾, 통계 경계 분석(Statistical Threshold Analysis)⁹¹⁾, 패턴 매칭(Pattern Matching)⁹²⁾의 기법을 조합하여 주로 판별한다.

3. 스니핑(Sniffing), 스캐닝(Scanning), 스푸핑(Spoofing) 공격

네트워크상에서는 데이터 패킷들이 전송될 때 TCP/IP 프로토콜 특성상 정확히 한 호스트를 향해서만 전송되지 않고 동일한 서브네트워크에 속해는 호스트들에게 모두 전송이 된다. 이 때, 각 호스트들은 패킷들이 자신을 목적지로 전달된 것인지 확인을 하고 만약 자신을 목적지로 된 패킷이라면 이 패킷을 받아들이게 된다. 그러나 다른 호스트를 목적지로 전달된 패킷도 네트워크 장치에서 볼 수가 있다. 이렇게 네트워크상에서 전달되는 모든 패킷들을 감시하는 것을 스니핑(Sniffing)이라고 부른다.

스캐닝(Scanning)은 상대방의 네트워크에 어떤 종류의 컴퓨터들이 있고, OS의 버전과 네트워크 데몬들의 목록을 알아내는 것이다. 이는 보통 침입을 위한 전단계로 볼 수 있다.

IP 스푸핑(Spoofing)은 IP를 속여서 공격하는 기법이다. 상대방 호스트에게 자신이 다른 컴퓨터인 것처럼 속이는 방법으로 공격자가 자신의 IP주소를 변조하여 데이터를 보내고 상대방 호스트가 응답을 보내는 시간을 예측한 후 응답을 받지 못하였음에도 응답을 받은 것처럼 데이터를 계속 전송하여, 접근제어를 뚫는 방법이다.

일반 사용자의 태그를 스푸핑한 공격자는 자동화된 체크아웃 혹은 보안 시스템을 속일 수 있으며, 스푸핑된 데이터로 값싼 물품과 비싼 물품을 교체할 수 있다.

공격방법으로는 IP 스푸핑⁹³⁾, APR 스푸핑⁹⁴⁾, E-mail 스푸핑⁹⁵⁾, DNS 스푸핑⁹⁶⁾

술, 즉 쪼개진 공격패킷을 결합한 후 트래픽 내 공격 트래픽 탐지시 사용

90) TCP어셈블리와 유사하나 커넥션 테이블을 유지하여 트래픽 플로우를 판별가능한 기술. 이 또한 폴스 알람을 제거하고 IPS 우회공격을 탐지하는 데 효과적인 기법.

91) 네트워크 어노말리를 탐지/방어하기 위한 분석기법. 통계 어노말리(Statistical Anomaly) 혹은 경계 분석(Threshold Analysis)이라고 불리기도 함. 일반적으로 보호 대상 네트워크를 일정시간 동안 모니터링 후 정상 트래픽의 통계를 기본값으로 설정, 이 기본값을 초과하는, 즉 경계(Threshold) 값을 넘었을 경우 이를 비정상 트래픽이라 간주한다. 이는 정상적인 트래픽으로부터 상당한 차이를 보이는 트래픽의 경우 효과적이거나 이 기법만으로 판단하기에는 무리가 있어 다른 분석기법과 함께 사용된다.

92) 공격탐지 시 가장 많이 사용되는 분석기법이나 가장 많은 문제점을 내포하는 기술, 레귤러 익스프레션 매칭(Regular expressin matching), 패킷 그레핑(Packet-grepping), 블라인드 패턴 매칭(Blind Pattern Matching)이라 불리기도 함. 네트워크 트래픽내에서 'grep'과 같은 명령어를 사용해 특정 유해 패턴을 검색하는 방법

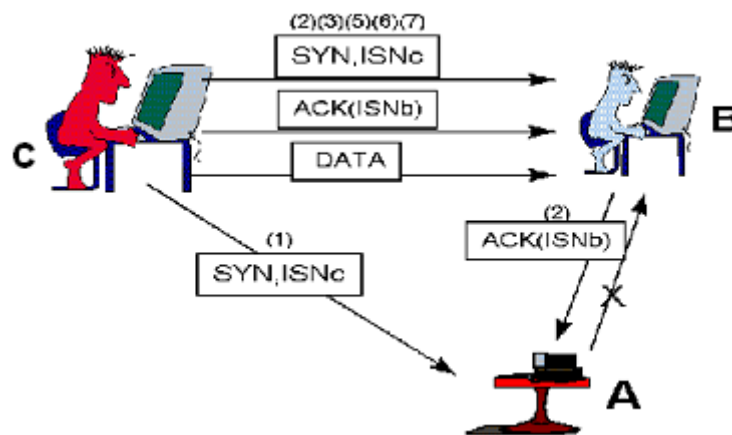
93) IP 스푸핑은 말 그대로 IP 정보를 속여서 다른 시스템을 공격하는 것이다. IP 스푸핑을 통해 서비스 거부 공격(TCP Syn flooding, UDP flooding, ICMP flooding)을 수행할 수도 있으며, 공격대상 컴퓨터와 서버 사이의 연결된 세션에 대해서 세션 끊기도 가능하다.

94) 공격 대상 컴퓨터와 서버 사이의 트래픽을 해커 자신의 컴퓨터로 우회시킬 수 있다. 우회된 트래픽으로부터 해커는 패스워드 정보 등 유용한 정보를 마음껏 획득할 수 있다.

95) 이메일 발송시 송신자의 주소를 위조하는 것이다. 요즘 들어서 극성인 대량의 스팸 메일과 바이

이 있고 현재 알려진 TCP/IP 프로토콜의 약점을 이용한 IP 스푸핑 방법에는 다음과 같은 것들이 있다.

- 순서제어번호 추측(Sequence number guessing)
- 반(Half)접속 시도 공격(SYN flooding)
- 접속가로채기(Connection hijacking)
- RST를 이용한 접속 끊기(Connection killing by RST)
- FIN을 이용한 접속 끊기(Connection killing by FIN)
- SYN/RST패킷 생성공격(SYN/RST generation)
- 네트워크 데몬 정지(killing the INETD)
- TCP 윈도우 위장(TCP window spoofing)



[그림 5-3] IP 스푸핑⁹⁷⁾

러스 감염 메일은 송신자의 주소가 아예 존재하지 않는 이메일 주소를 사용한다. 또한 이메일을 발송한 메일 서버 또한 직접적인 메일 발송 서버가 아닌 중계 서버이므로 메일을 발송한 자를 추적하기란 쉽지 않다.

96) DNS 프로토콜은 인터넷 연결 시 도메인 주소를 실제 IP 주소로 대응시켜 주는 프로토콜이다. 인터넷 연결 시 사용하는 DNS 서버가 IP 주소를 찾아달라는 요청을 받았을 때, 자기 자신의 도메인이 아닌 주소에 대해서는 보다 상위 단의 DNS 서버로부터 재귀적(recursive)인 방식으로 IP 주소를 찾아 알려준다. 만약 해커가 어떤 도메인의 DNS 컴퓨터를 장악하여 통제하고 있다면 최종적으로 얻어진 IP 주소는 원래 사용자가 찾아가고자 하였던 홈페이지가 아닌 다른 홈페이지로 연결되게 된다. 이는 요청을 발송했던 DNS와 응답을 주는 DNS 사이의 트래픽을 해커가 스니퍼링 함으로써 Query ID라는 값을 통해 해커의 사이트 IP를 최종 응답으로 넘겨주도록 하는 것이다. 사용자가 쇼핑몰을 이용하고자 하였다면 해커에 의해 조작된 홈페이지 내에서 자신의 아이디와 비밀번호, 신용카드 정보를 기입함으로써 개인 정보를 탈취당할 수 있다. 위와 같은 스푸핑 공격들은 실제로 인터넷 상의 톨로써 공개가 되어 있으며 여러 가지 다른 복합적인 공격과 같이 사용될 수 있다.

97) 1. C는 A로 자신의 IP주소를 위장하여 SYN를 보내 접속요청을 한다.

2. 요청에 대한 응답으로 A가 C에 대한 ACK와 함께 자신의 SYN을 전송하지만 C가 이에 대해 ACK를 보내지 않으면 A는 자신이 보낸 ACK에 대한 C의 응답을 기다리게 된다.

어떤 시스템(클라이언트)이 서비스를 제공하는 시스템(서버)에 TCP 연결을 시도할 때, 클라이언트와 서버는 다음과 같이 일련의 메시지들을 교환한다. 먼저 클라이언트 시스템은 서버에 SYN 메시지를 보내며, 서버는 SYN-ACK 메시지를 클라이언트에 전송함으로써 접수된 SYN 메시지에 대해 확인한다. 클라이언트는 다시 ACK 메시지를 전송함으로써 접속 설정을 완료한다. 이렇게 함으로써 클라이언트와 서버 사이의 접속이 열리게 되고, 클라이언트와 서버 사이에 서비스에 고유한 자료들을 교환할 수 있게 된다. 이러한 접속방법은 모든 TCP 연결에 대해 적용된다.

공격의 가능성은 바로 서버가 클라이언트에 확인 메시지(ACK-SYN)를 보낸 후 클라이언트로부터 다시 확인 메시지(ACK)를 받기 이전의 시점에서 발생한다. 이 상태가 바로 ‘반만 열린’ 연결이라고 불린다. 서버는 모든 진행 중인 연결에 대한 정보를 저장하기 위해 시스템 메모리에 자료구조를 구축하며 이 자료구조는 그 크기가 제한되어 있다. 따라서 계속하여 반만 열린 연결을 생성함으로써 이 자료구조를 넘치게 할 수 있다.

반만 열린 연결은 IP 속이기를 이용하면 손쉽게 생성할 수 있다. 공격자 시스템에서 피 공격 서버에 적법하게 보이지만 실제로는 ACK-SYN에 대해 응답할 수 없는 클라이언트를 참조하는 SYN 메시지를 발송한다. 따라서 피 공격 서버는 최종 SYN 메시지를 받을 수 없게 된다. 마침내 피 공격 서버 측의 "반만 열린" 연결을 위한 자료 구조가 가득 차게 되고 이 자료 구조가 비워질 때까지 피 공격 서버는 새로운 연결 요구에 대해 응답할 수 없게 된다. 일반적으로 반만 열린 연결에 대해서는 타임아웃 값이 설정되어 있어 일정 시간이 경과하면 자동적으로 취소되게 되므로 새로운 연결에 대해 응답할 수 있게 된다. 그러나 이와 같은 복구에 소요되는 시간보다 빠르게 공격자 시스템이 반복적으로 거짓 IP 패킷을 전송할 수 있다.

대부분의 경우, 이러한 공격의 피해 시스템은 새로운 네트워크 연결 요청을 받아들이는데 곤란을 겪게 되며 서비스제공 능력의 저하를 가져온다. 그러나 기존의 외부로부터의 연결이나, 외부로의 새로운 접속 요청 전송에는 영향을 받지 않는다. 그

-
3. 이 과정을 연속적으로 반복하면 A는 외부의 접속요청에 응답할 수 없는 오버플로우 상태가 된다.
 4. 이후, C는 B로 정상적인 접속을 시도하여 순서제어번호의 변화를 패킷 모니터링을 이용하여 관측한다.
 5. 순서제어번호의 변화를 관찰하여 추측한 순서제어번호를 이용하여 C는 자신의 IP주소를 A로 가장한후 B에 접속요청(SYN)을 보낸다.
 6. B는 수신된 SYN 패킷이 A에서 온 것으로 인식, A에게 ACK와 새로운 SYN를 보내지만 이미 A는 외부와 통신 불능상태이므로 응답을 할 수 없게 된다.
 7. C는 자신의 IP 주소를 A주소로 위장하여 추측된 순서제어번호를 이용해 B가 A로 보낸 SYN/ACK에 대한 ACK를 B에 보낸다.
 8. C와 B 불법적 접속이 이루어지고, B와 A는 연결되어 있는 것으로 착각한다.

거나 특별한 경우, 시스템의 메모리가 고갈되거나, 파괴되거나, 또는 작동불가능하게 될 수도 있다.

현재의 IP 프로토콜 기술로는 IP 속임 패킷을 제거하는 것이 불가능하므로 현재로서는 이 문제에 대한 완전한 해결책이 없는 상태이다. 그러나 관리하고 있는 네트워크로 유입되거나 이로부터 유출되는 IP 속임 패킷을 감소시킬 수 있는 방법이 있다. 즉, 라우터를 적절히 구성함으로써 공격당할 가능성을 줄이거나, 해당 사이트내의 시스템이 공격의 근원이 될 수 있는 가능성을 감소시킬 수는 있다.⁹⁸⁾

4. 서비스거부(DoS, Denial of Service) 공격

서비스 거부(DoS) 공격이란 공격자가 여러 대의 장비 또는 시스템을 이용해 표적 시스템이 처리하지 못할 정도의 엄청난 데이터를 집중적으로 전송함으로써, 표적 시스템의 정상적인 기능을 방해하는 것을 말한다.

DoS의 주요 공격 대상은 시각적인 서비스를 하는 웹서버나 라우터, 네트워크 같은 기반 시설이다. 서비스 거부 공격은 보안을 유지하는 데 있어서 가장 중요한 기밀성(Confidentialness), 무결성(Integrity), 가용성(Availability) 중 가용성 측면을 노린 것이다.

DoS 공격의 유형은 공격자의 위치에 따라 내부에서의 공격과 외부에서의 공격으로 나눌 수 있고, 공격대상의 형태에 따라, 특정 네트워크에서 허용하는 대역폭을

98) SimpleTagAuth 기법에 대한 스푸핑(Spoofing) 공격은 Gen2 규격 비호환인 태그와 리더가 PIN-test 명령을 통해 전송하는 모든 PIN에 대해서 태그 자신이 가지고 있는 값과 일치한다고 응답하여 리더를 속일 수 있다.

이는 BasicTagAuth 기법을 통해 해결될 수 있지만 BasicTagAuth 기법 또한 도청 공격이 가능하다. 이는 공격자가 특정 태그의 EPC 코드를 획득한 후, 정당한 리더를 도청하면서 허위로 생성된 패스워드 집합을 얻어낼 수 있다. 공격자는 도청 공격을 통해 획득한 패스워드 집합을 복제 태그에 대해서 테스트함으로써 해당 태그에 적합한 Kill 패스워드 값을 알아낼 수 있다.

또, EnhancedTagAuth 기법에 대한 도청 공격도 가능하다. 태그-리더 간의 상호 인증을 위해 해당 태그의 Kill 및 Access 패스워드가 평문의 형태로 공격자에게 노출되기 때문에 공격자는 쉽게 Kill 및 Access 패스워드를 획득할 수 있으며, 이를 통해 태그를 완벽하게 복제하거나 악의적으로 태그의 동작을 정지(Kill)할 수 있기 때문이다.

또한, 획득한 Access 패스워드를 통해 태그의 메모리 बैं크에 접근하여 임의로 EPC, TID 등을 수정함으로써 RFID 시스템의 장애를 초래할 수 있다.

현재 나와 있는 해킹 방지 기법들은 Kill 및 Access 패스워드 값들을 공격자가 쉽게 획득할 수 있어 더욱 심각한 태그 복제 문제를 야기할 수 있다. 태그가 보유하고 있는 패스워드 값을 검증하기 위해 사용되는 PIN-test 명령 역시 Gen2 규격에서 명시하고 있는 다른 명령들과 유사한 형태의 명령이기 때문에, 공격자는 리더가 보내는 PIN-test 명령을 도청함으로써 명령과 함께 전달되는 패스워드 값을 획득할 수 있다. 또한 완벽하지 않은 상호 인증 기법으로 인해 중간자 공격 및 서비스 거부 공격에 무방비한 상태이다.

모두 소모시키는 방법, 공격 대상(victim) 시스템의 자원(CPU, Memory등)을 고갈시키는 방법, 공격 대상의 시스템 상에서 동작하는 Application등 프로그래밍 오류에 대한 공격으로 서비스를 거부하게 하는 방법들이 있다.⁹⁹⁾

내부에서의 공격은 CPU, 메모리, 디스크 등의 시스템 자원에 대한 공격으로 시스템을 독점하여 과소비함으로써 서비스를 거부하도록 하는 방법이 대부분을 차지하고 있고, 외부에서의 공격은 위와 같이 여러 가지 형태의 공격방법을 띄고 있으나 네트워크와 시스템에 대한 공격이 주를 이룬다.

네트워크 트래픽을 증가시키면 실제로 시스템의 사용에는 문제가 없지만 이 시스템이 사용자에게 네트워크 서비스를 제대로 수행하지 못하게 된다.

다음은 몇 가지 DoS공격의 형태이다.

가. 버퍼 오버플로우 공격

가장 흔한 형태의 DoS 공격은 당초 프로그래머가 예측 설계했던 데이터 버퍼 용량보다 더 많은 양의 트래픽을 보내는 것이다. 공격자는 표적 시스템의 약점을 미리 잘 숙지하고 있다가 이를 악용하거나 또는 효과가 나타날 때까지 공격을 계속할 수 있다. 프로그램 또는 시스템 버퍼 특성에 기반을 둔 공격들로는 대역폭 소비(Bandwidth Consumption)를 들 수 있는데 이는 특정 네트워크로 모든 활용 가능한 대역폭을 소모하는 것으로 원격으로 네트워크 트래픽을 포화시키는 일반적인 공격이다.

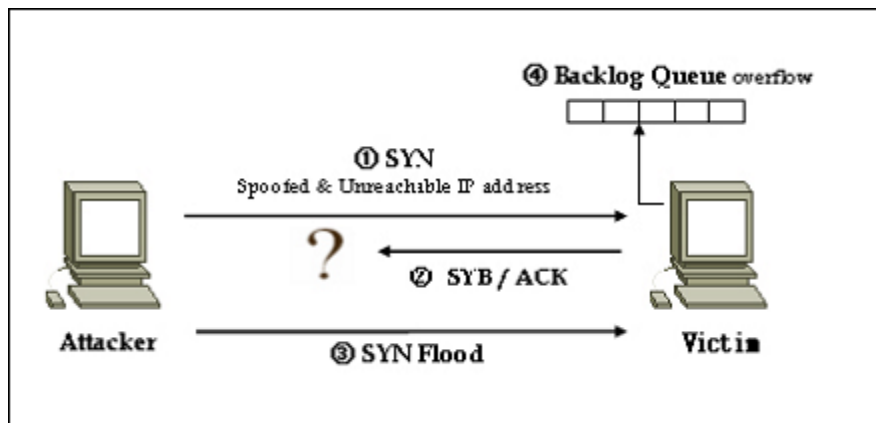
나. SYN Flooding

네트워크상의 TCP 클라이언트와 서버 사이에 세션이 개시될 때, 그 세션을 확립하는 핸드셰이킹을 신속히 처리하기 위해 매우 작은 버퍼가 존재한다. 세션 확립용 패킷에는 메시지 교환의 순서를 인식시키기 위한 SYN 필드가 포함된다. 공격자는 다수의 접속 요청을 매우 빠르게 보낸 다음, 상대의 응신에 답하지 않고 침묵한다. 이 공격은 첫 번째 패킷이 버퍼에 그냥 남아있게 함으로써 다른 정당한 접속 요구들이 더 이상 수용되지 못하게 만드는 것이다. 아무런 응답 없이 일정 시간이 경과하면 버퍼에 남아있는 패킷은 결국 버려지게 되지만, 많은 양의 가짜 접속 요청으로 인해 정당한 접속 요구 세션이 확립되기 어려운 요인이 된다.

99) 정철현, 변대용, “트래픽 분석을 통한 서비스 거부공격 추적”
<http://www.certcc.or.kr/paper/tr2003/030115-DoS.pdf>, 2003.1.

SYN Flooding 공격은 특정 시스템에 대한 불법적인 권한을 얻는 적극적인 방법이 아니라, 네트워크와 시스템의 자원을 공격 대상으로 하는 공격방법의 하나이다. 즉, SYN Flooding은 TCP의 연결 과정인 Three-way handshaking을 이용하여 공격자(Attacker)가 대상시스템(Victim)에 source IP address를 스푸핑하여 SYN 패킷을 특정 포트에 전송하게 되면 이 포트의 대기 큐 (Backlog Queue)를 가득 차게 하여 이 포트에 들어오는 연결요청을 큐가 빌 때까지 무시하도록 하는 방법이다. 이때 source IP주소에 들어갈 임의의 호스트를 찾아야 하는데, 이 호스트는 Unreachable 호스트여야 한다. 이러한 호스트는 간단히 ping을 이용해서 찾아낼 수 있다. 사용할 포트 번호는 널리 알려진 port scan방법을 이용해 대상 포트를 찾을 수 있다.¹⁰⁰⁾

먼저 공격자는 unreachable한 호스트의 IP주소로 스푸핑하여 계속하여 연결요청(SYN/ACK) 패킷을 보내게 되면 대상 시스템은 unreachable 호스트에게 ACK를 받을 때까지 이러한 연결 상태를 큐에 계속해서 저장하게 된다. 시간이 지나면 큐는 overflow가 발생하게 되고, 이후에 큐로 들어오는 연결요청은 거부하게 되는 것이다. [그림 5-3]은 SYN Flooding의 개념도 이다.



[그림 5-4] SYN Flooding에 의한 DoS 공격

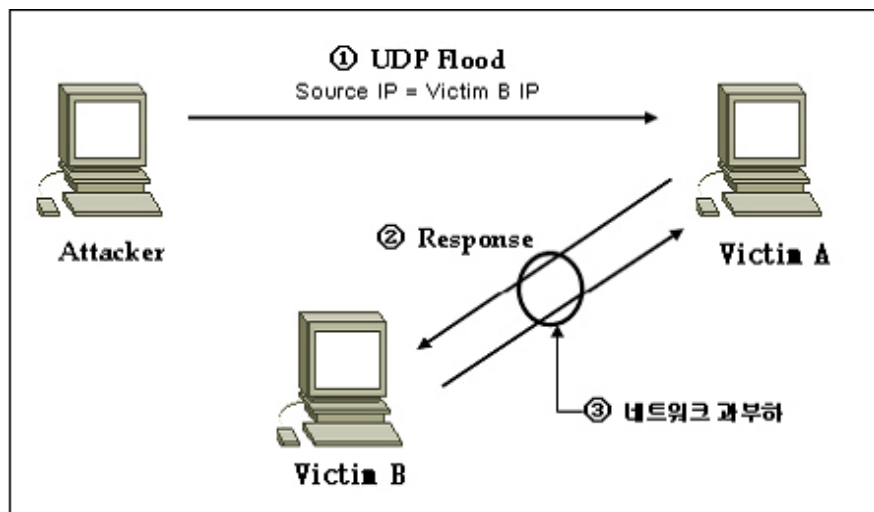
다. UDP Flooding

UDP(User Datagram Protocol)를 이용한 패킷전달은 비연결형(connectionless)서비스로서 포트 대 포트에 전송한다. 대표적인 응용 서비스로는 TFTP, SNMP, 실시간 인터넷 방송 등이 있다. UDP Flooding은 UDP의 비연결성 및 비신뢰성 때문에

100) 이경현, 조현호, 박영호, “네트워크를 통한 시스템침입에 대한 고찰Ⅱ” 한국멀티미디어 학회 2000년도 추계 학술발표논문집, 제3권 제2호, pp. 525-529, 2000.

L.Garber, “Denial-of-Service Attacks rip the Internet” IEEE Computer pp.12-17, April 2000.

공격이 용이한 방법이다. UDP는 source address와 source port를 스푸핑하기 쉽다. 이러한 약점들을 이용해 과도한 트래픽을 victim에 전송함으로써 spoof 되는 victim간 네트워크를 마비시킨다. [그림 5-4]에서 나타낸 바와 같이 공격자가 victim A에게 source IP address를 victim B의 IP address로 spoofing하여 대량의 UDP 패킷을 전송하면 victim A와 victim B는 계속해서 서로 패킷을 주고받게 되어 두 시스템 사이의 네트워크에 과부하가 초래된다. 이 공격은 주로 echo와 chargen 서비스를 이용한다.



[그림 5-5] UDP Flooding에 의한 DoS 공격

라. 눈물방울 공격

이 형태의 DoS 공격은, 라우터에서 처리하기에 너무 큰 패킷을 IP가 여러 조각으로 분리한다는 점을 악용하는 것이다. 조각난 패킷은 수신측 시스템에 의해 완전한 패킷으로 재조립될 수 있도록 첫 번째 패킷의 시작으로부터 오프셋을 인식한다. 그러나 공격자의 IP는 이를 혼란시킬 목적으로 두 번째 이후의 조각에 엉뚱한 오프셋 값을 집어넣는다. 만약 수신측의 운영체계가 이러한 상황에 대해 대응할 수 있는 계획을 가지고 있지 못하다면, 그 시스템은 결국 멈추게 된다.

즉, 자원을 고갈(Resource Starvation)시킴으로서 시스템 자원(CPU Utilization), 메모리 파일 시스템 할당 등)을 소모하는 공격이다.

마. 스머프(Smurf) 공격

스머프 공격에서 가해자는 수신측 사이트로 IP 핑 요청을 보낸다. 핑 패킷은 수신

측 사이트의 근거리 통신망 내에 있는 다수의 호스트들에게 보내어진다. 이 패킷은 또한 그 요청을 자신이 아닌 다른 사이트로부터 온 것처럼 위장함으로써 표적이 된 다른 사이트가 DoS를 겪게 된다. (다른 사람의 주소로 응답되도록 한 채 패킷을 보내는 것을 스푸핑이라고 부른다). 그 결과 무고한 호스트 (가해자가 응답주소로 설정해 놓은 엉뚱한 호스트)로 엄청나게 많은 량의 핑 응답이 홍수처럼 밀려들게 된다. 이렇게 핑 응답이 엄청나게 밀려들게 되면, 자신의 주소를 도용당한 호스트는 더 이상 정상적인 다른 트래픽을 수신하거나, 또는 구별해 낼 수 없게 된다.

바. 바이러스

다양한 방법으로 네트워크 전반에 걸쳐 자신을 복제하는 컴퓨터 바이러스 역시 일종의 DoS 공격으로 볼 수 있다.

사. DDoS(Distributed Denial of Service)

네트워크로 연결되어 있는 여러 호스트에 패킷을 범람시킬 수 있는 DoS용 프로그램을 분산 설치하여 이들이 서로 통합된 형태로 한 대의 표적 시스템에 대해 성능 저하 및 시스템 마비를 일으키는 서비스 거부 공격이다.

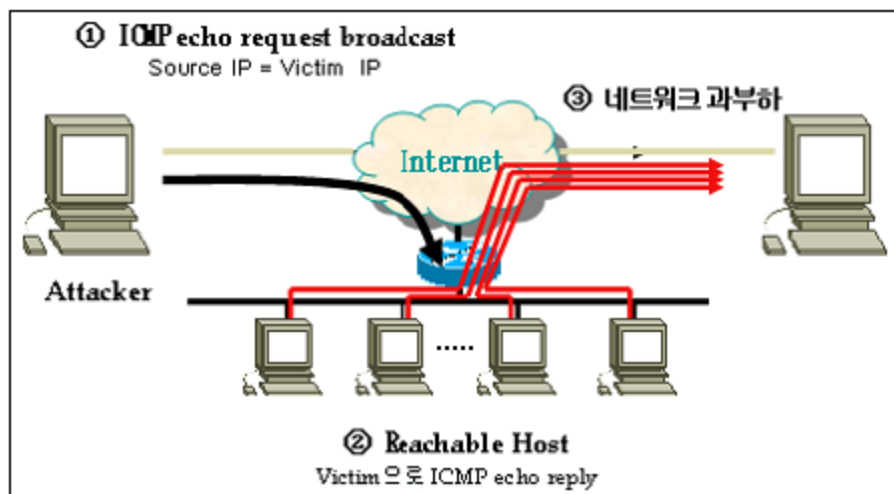
아. DRDoS(Distributed Reflection Denial of Service)

DRDoS 공격은 별도의 에이전트를 설치할 필요 없이 네트워크 통신 프로토콜 구조의 취약을 이용해 정상적인 서비스를 운영하고 있는 시스템을 DDoS 공격의 에이전트로 활용한다. 기존 DDos 공격에 비해 사용하기 쉽고 공격을 당한 사이트의 복구가 어려우며, DRDoS 공격은 피해의 정도와 성공확률 측면에서 DDoS 공격과 거의 일치하고, 피해 결과 또한 DDoS 공격과 유사하여 피해를 입은 후에도 공격 방법을 파악하기 어렵다.

즉, 리더가 태그 간에 질의와 반응의 메커니즘이 존재하는 특징을 이용하여 공격자가 리더를 가지고 수많은 질의를 리더 및 태그에게 보낸다면 리더와 태그는 많은 질의에 대해서 일일이 반응해야 하기 때문에 태그와 리더사이에 너무 많은 계산이 요구되고, 정상적인 기능을 못하게 만드는 결과를 초래한다. 서비스 거부공격은 RFID 시스템이 작동을 못하도록 하는 위협이다.

자. ICMP Flooding

ICMP(Internet Control Message Protocol)는 IETF RFC 792에 정의된 프로토콜로써 호스트간 혹은 호스트와 라우터간의 에러 상태 혹은 상태 변화를 알려주고 요청에 응답을 하는 기능을 담당하는 네트워크 제어 프로토콜이다. 활성화된 서비스나 포트가 필요하지 않는 유일한 프로토콜이다. 이러한 ICMP의 특징을 악용한 ICMP Flooding은 대량의 ICMP패킷을 공격자가 직접 victim에게 전송하는 방법으로 그 변종의 예로 Smurf, Welchia worm 등이 있다. Smurf는 공격자가 source IP address를 victim의 IP address로 설정한 후, broadcast address로 ICMP echo request 패킷을 전송하면 그 하위 모든 시스템들이 ICMP echo reply 패킷을 victim으로 전송하게 되어 대량의 패킷들이 집중하여 네트워크 부하를 높지게 된다. [그림 5-5]은 Smurf의 개념도이다.



[그림 5-6] Smurf에 의한 DOS 공격

최근 발견된 Welchia worm은 감염 시스템에 대하여 IP address의 B클래스를 고정시키고 C클래스부터 증가시키며 ICMP 패킷을 전송하여 다른 감염 대상을 찾고 감염 시스템의 성능을 저하시키는 형태이다.¹⁰¹⁾

5. 세션가로채기(Hijacking), 재생(Reply)공격, 중간자 공격(Man In Middle Attack)

101) hauri- virus information, http://www.hauri.co.kr/virus/vir_new.html

RFID 리더와 태그사이의 상호인증을 위한 인증 프로토콜 수행 시 발생할 수 있는 공격들로, 인증된 세션을 가로채는 세션 가로채기 공격, 공격자가 검증자에게 이전에 수행되었던 프로토콜 부분 중 일부분을 다시 실행시키는 재생 공격, 공격자가 인증 프로토콜 수행 중간에 자신의 정보를 삽입하는 중간자 공격 등이 있다.

6. 물리적 공격

태그의 메모리는 내용을 노출시키게 하는 물리적 공격에 취약하다. 그러나 스마트카드에 적용될 수 있는 프로브공격(칩에 탬퍼방어패키지를 제거하여 직접 IC Chip에 프로브를 해 중요정보를 해석하는 수법), TEMPEST공격(통신장비 및 컴퓨터에서 방출되는 전자파를 분석하여 이들 사이에 송수신되는 내용을 도청할 수 있는 공격기법) 등의 물리적 공격을 방어하기에는 비용이 너무 비싸진다는 문제점이 있다. 또한, 향후 스마트카드처럼 암호 알고리즘을 지원하는 태그가 설계되는 경우, 스마트카드에 적용될 수 있는 전력분석(Power Analysis), 타이밍 분석(Timing Analysis) 등의 사이드채널공격(혹은 부채널 공격)¹⁰²⁾에 대한 위험요인도 존재할 수 있다.

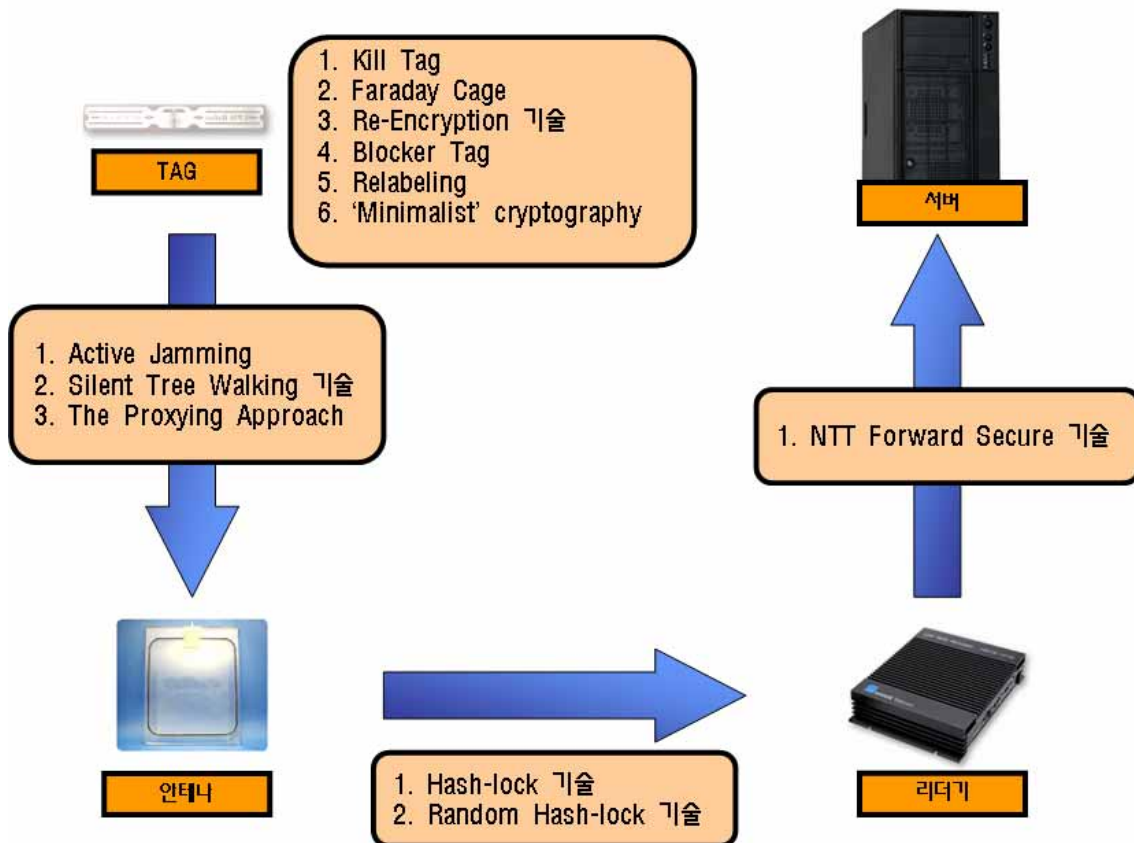
7. 위조

태그에는 메모리에 데이터 항목이 존재한다. 이 항목은 항상 공격자의 대상이 될 수 있다. 공격자는 데이터 항목을 지우거나 대신할 수 있는 방법을 사용할 수 있다. 이것은 리더와 태그 간의 통신에 잘못된 데이터를 서로 교환가능하게 되므로 치명적인 위험이 존재한다. 또한, 리더를 위조하여 태그의 데이터 항목을 읽어가는 위험도 존재한다.

제2절 보호기술

본 절에서는 1절에서 조사한 침해기술에 대응하는 보호기술들을 조사하였다. 다음의 그림은 RFID 시스템에서의 보호기술을 정리한 그림으로 조사내용과 더불어 참조하길 바란다.

102) 스마트카드 설계자가 예기치 못한 정보(Side Channel information)를 이용해 스마트의 비밀정보를 해석하는 방법으로, 타이밍 해석, 전력해석, 고장이용해석 등이 있음.



[그림 5-7] RFID 시스템에서의 대응기술

1. Kill Tag

고객의 프라이버시 보호를 위한 가장 단순한 방법으로 상품이 고객에게 인도되기 전에 RFID Tag를 비활성화 시키는 방법이다. 비활성화된 Tag는 다시 활성화되어 사용될 수 없다. 이 방법은 AutoID Center에 의해 제안된 “Kill Command” 기법으로 그 동작의 기본적인 내용을 살펴보면 RFID Tag는 Tag가 부착된 상품을 구매함으로써 비활성화 되는 것을 의미한다. 이러한 Tag 설계에서는 8-bit 패스워드를 포함하는 Kill Command가 존재하게 되고 이를 통해서 Tag가 비활성화 되는 것이다. 예를 들어 어떤 매장에서 진열되어 있는 제품을 감시하거나 재고품의 관리를 쉽게 하기 위해 RFID Tag를 사용한다고 하자. 이 매장에서는 고객의 프라이버시를 보호하기 위해 계산대 점원이 구매한 상품의 Tag를 비활성화시킬 것이다. 그리고 구매되지 않는 상품은 여전히 활성화되어 있는 RFID Tag를 가지고 있다.

그러나 RFID Tag를 비활성화 하는 방법은 여러 문제점을 가지고 있다. 가장 일반적인 문제로는 RFID Tag를 사용하는 환경은 매우 다양하고 복잡한 환경으로 존

재할 수 있으며 이러한 환경에서 비활성화와 같은 단순한 방법은 반드시 개인 프라이버시 시행을 위해서만 동작하지 않을 수 있다는 것이다. 예를 들어 고객은 자기가 물건을 소유하고 있는 동안에도 여전히 동작하는 RFID Tag를 원할 수도 있다. 가정에서 RFID Tag를 사용하는 예로써 즉석 가공식품 패키지로부터 요리 방법을 읽어 들일 수 있는 마이크로웨이브는 능동적으로 동작 Tag에 의존하는데 Tag가 비활성화 되어 있을 경우 그 인식이 불가능하다. 일반 고객을 위한 RFID Tag 응용의 다른 예로는 특정한 노력을 들이지 않고서도 물리적 접근을 제어하고 소유물의 도난을 방지하며 무선 현금 카드 등을 사용하는 방법을 생각할 수 있다. RFID Tag와 같은 낮은 가격의 강력한 기술은 오늘날 우리가 상상할 수 없을 정도로 수많은 분야의 응용에 필연적으로 사용될 것이다. 대부분의 응용에서는 고객이 제품을 소유하고 있는 동안에 Tag가 능동 상태로 있기를 요구한다. 따라서 구매자는 Tag의 비활성화를 원하지 않을 수도 있다. 가능한 몇 가지 응용을 알아보면 다음과 같다.

- 상점은 만약 제품이 하자로 인하여 반품될 때 여전히 스캐닝이 가능한 Tag를 갖고 있는 제품을 원한다.
- 제품을 재활용 목적으로 분류하기 위해 제품의 스캔이 필요한 경우가 있다.
- 상점은 부착된 RFID Tag를 이용하여 영수증을 발행하며 그 제품이 반품될 때 제품의 스캔이 필요한 경우가 있다.
- 개인은 수취인에게 쉽게 스캐닝이 가능하도록 명함에 끼워진 RFID Tag를 원할 수 있다. 여기서 Tag ID는 실제 카드 데이터를 나타내는 URL을 만드는데 사용될 수 있다.
- 상점은 상점이 발행한 쿠폰에 RFID Tag를 삽입시켜 카운터 점원이 쉽게 스캐닝 할 수 있기를 원한다.
- 사용자는 특별한 제품을 리콜 할 때 자기가 소유한 제품을 스캐닝하기를 원한다.
- CD나 기호품 같은 수집품은 RFID Tag를 갖고 있기를 원한다. 이를 통해서 소유자가 자신의 재산목록을 잘 취급할 수 있기 때문이다.
- 상인은 마케팅 목적으로 고객의 스캐닝을 원할 수도 있다. 예를 들어 지금 상대하고 있는 고객은 오늘 사전에 무슨 상점을 방문하였는가? 이 고객은 이미 어떤 물건을 샀는가? 등과 같은 경우가 있다.
- 냉장고나 식료품 진열대는 어떤 식료품이나 약품이 유통기간이 지났을 때 알려줄 수 있다.
- 공항 내에서 승객의 추적을 간단하게 수행하기 위하여 항공권에 RFID Tag를

끼워 넣을 수 있다.

- 사업상 문서를 회신할 때 분류를 쉽게 하기 위해 invoices, 쿠폰, 회신용 봉투 등에 RFID Tag가 포함되기를 원한다.

이처럼 RFID Tag는 수많은 분야에서 응용될 수 있으며 능동 Tag는 고객 및 사업자에게 부가 가치를 부여할 것이다. 따라서 고객은 자신도 모르는 사이에 누군가에 의해 몰래 위치가 추적되고 신원이 확인될 위험에 노출되어 있다. 그러므로 개인의 프라이버시를 보호하는 노력을 기울이는 대부분의 응용에서는 구매와 동시에 Tag를 비활성화 하는 방법을 사용하지만 이것이 만족스러운 방법이 아닐 수 있기 때문에 다른 대안을 개발하여야 할 수도 있다.

실제로 이러한 문제를 해결하기 위하여 기능정지 명령과 재개 명령을 사용하는 방법이 있다. 이 방법을 사용하면 RFID Tag의 기능이 불필요할 때에는 일시적으로 기능을 정지시키고 필요한 경우에 다시 기능을 재개시키는 것이 가능하다. 이러한 명령은 기능 Kill Command와 똑같이 실행 명령 시 패스워드를 사용하는 방법을 생각할 수 있지만 전파에 의한 통신 특성상 RFID Tag와 Reader 사이의 정보 교환은 간단히 도청되므로 패스워드를 도난당해 그 기능이 악용될 소지가 있다. 또한 RFID Tag가 부착된 대상이 증가함에 따라 이러한 명령을 관리하는 것도 복잡하게 된다. 이러한 문제를 해결하기 위하여 RFID Tag와 Reader 사이의 통신에 암호화나 인증을 이용하는 방법이 있다. 그러나 이러한 암호화도 Tag의 연산, 기억 능력에 제한을 가지는 RFID 시스템에서는 기존의 암호 알고리즘을 통해 암호화가 구현되기 어렵다. 이를 위해서는 제한적인 환경에서도 충분한 보안성을 가지는 충분히 효율적인 새로운 알고리즘이 필요하다. 인증 역시 보안상의 문제점과 보완해야 할 부분이 많다. RFID Tag와 Reader 사이의 상호인증은 Tag를 잠그는 Lock 동작이나 해제시키는 Unlock 동작이 요구되는 상황에서 반드시 선행되어야 하는 요구사항이다. RFID Tag는 기본적으로 저성능의 독립된 개체로서 Tag가 Reader를 인증하기 위해서 신뢰할 수 있는 외부 서버에 접근하기가 어렵다. 그러나 Tag와 Reader가 서로 신뢰할 수 있는 방법 중 하나는 Tag에 내장된 비밀 Key를 사용하는 방법인데 이는 기존의 보안기술에 비하면 보안성과 안정성이 상당히 결여된 방식이다. 이를 뒷받침하기 위하여 이를 충분히 지원해 줄 수 있는 인프라 시스템이 필요한 실정이다. 또한 RFID 네트워크를 구성하는 요소(ODS, 정보서버, Reader 등) 사이의 상호인증도 보장되어야 하는 복잡성을 지닌다.

2. Faraday Cage

RFID Tag는 faraday cage(어떤 범위의 무선주파수를 차단할 수 있는 포일이나 금속 그물망으로 만들어진 용기 혹은 컨테이너)를 사용하여 정밀 조사로부터 차폐가 가능하다.¹⁰³⁾ 이러한 기술은 도둑이 도난 방지 시스템을 속이기 위하여 foil-lined 가방을 이용하는 것에서 착안된 것이다. 현재 미국의 mobileClock 사는 Tag의 내용을 허가되지 않은 Reader가 읽는 것을 방지하기 위하여 라디오 신호가 투과되지 않도록 하는 'mClock' 제품을 판매하고 있다.

만약 고액권 지폐에 RFID Tag를 사용하게 된다면 foil-lined 지갑과 같은 제품이 큰 인기를 누릴 것이다. 또한 일부 회사는 개인 프라이버시 보호를 목적으로 faraday cage 기술을 기반으로 하는 제품을 제공하게 될 것이다. RFID Tag는 광범위한 영역에서 각 사물들에 이용될 것이다. 따라서 faraday cage는 적어도 고객의 프라이버시 보호를 위한 부분적인 해법을 제시할 것이다.

하지만 일반적인 소비자들에게 적용할 경우 이런 방법은 효과적이지 못하다. 쉬운 예로 슈퍼마켓에서 구입한 용품의 스캐닝을 방지하기 위해 foil-lined 가방을 사용할 수 있다. 이럴 경우 너무도 간단하게 RFID 시스템의 무용화를 가져오게 된다. 또한 이러한 방법은 소비자가 직접 착용하는 제품들(의류, 핸드백, 손목시계 등)에는 효과를 기대할 수 없다. 사람 자체를 faraday cage 안에 포장할 수는 없기 때문이다.

3. Active Jamming

RFID 신호의 Active Jamming은 Tag 통신을 차폐시키는 다른 형태의 물리적인 방법이다. 이는 근처에 있는 RFID Reader의 기능을 막거나 혹은 방해할 수 있는 라디오 신호를 브로드캐스트 하는 장치를 이용하는 것이다. 고객은 부근에 있는 RFID Reader의 동작을 방해하거나 차단시키기 위해 능동적으로 무선 신호를 브로드캐스트 하는 이 장치를 소지하고 있을 수 있다. 그러나 고출력으로 브로드캐스트 한다면 이는 불법이 되며 결코 근본적 해결책이 될 수 없다. 또한 주위의 모든 RFID 시스템을 교란시킬 수 있으며 프라이버시 보호와 관련이 없는 합법적인 시스템도 방해하게 될 것이다. 따라서 이 방법은 앞에서 살펴본 Killing Tag 기술보다 덜 사용되어진다.

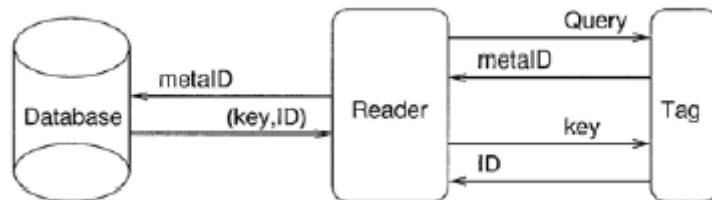
103) Wikipedia – The Free Encyclopedia, Entry = Faraday Cage,
<http://en.wikipedia.org/wiki/Faraday_cage>

4. Hash-lock 기술

지금까지 설명한 방식과 다른 방법을 통한 접근으로 RFID Tag 자체의 기능을 향상시키는 기술이다. 이 방법은 active 기능을 부여하여 개인 프라이버시 보호를 좀 더 효과적일 수 있도록 상호 교환을 하는 것으로 대부분 암호학적 방법에서의 접근이다.

MIT는 저렴한 비용(5센트 이하)의 Tag에서 resource 제한 문제를 해결하면서 인가를 받은 Reader에만 Tag 정보를 전송하기 위한 방법으로 Hash-Lock 기술을 제안하였다. 이 방법에서 Tag는 “unlocked” 되기 전까지 ID를 표시하는 것을 방지하기 위하여 “locked” 상태를 유지하게 된다. 즉 Tag가 lock 될 때, 값 y (metaID)가 주어지며 이는 다만 PIN 값 혹은 key의 값 x 에 unlock 된다. 이때 관계는 $y = h(x)$ 이며 여기서 h 는 단방향 해쉬 함수(one-way Hash Function)이다. 이는 낮은 비용의 Tag의 resource 제한을 해결하기 위하여 하드웨어적으로 최적화를 이루어 구현된 함수로 Hash-Lock 기술에서는 이 함수만을 가정하고 있다.

Tag가 Reader를 인증하는 과정은 다음과 같다. Back-End DB와 Reader 사이의 통신 채널은 안전하다는 것이 가정되어 있지만 Reader와 Tag 사이의 채널은 도청될 수 있는 안전하지 않은 채널이다.



[그림 5-8] Hash-Locking : Reader unlock protocol¹⁰⁴⁾

- Reader는 Tag에 query를 전달한다.
- Tag는 자신의 key에 대한 해쉬 값인 metaID를 계산한 뒤 Reader가 제시하는 query에 대해 응답한다.
- Tag의 잠금 상태를 풀기 위해 Reader는 metaID 값을 Back-End DB에 query로 제시하면 Back-End DB는 저장된 ID에 대한 key를 찾아 Reader에 전송한다.
- 찾은 key를 Reader가 Tag에 전송하면 Tag는 그 key를 해쉬하여 metaID 값

104) S.A.Weis, S.E.Sarma, R.L. Revest, D.W. Engels, "Security and Privacy Aspects of Low-Cost Radio Frequency Identification Systems" accepted for publication to the First International Conference on Security in Pervasive Computing (SPC 2003), March 12-14, 2003.

과 일치하는지 여부를 검증한다.

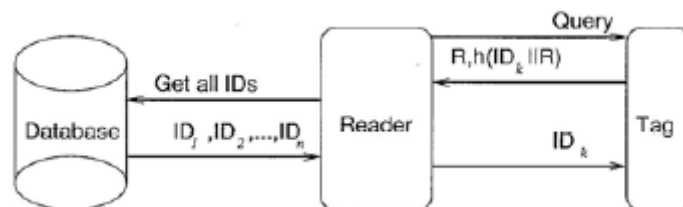
- 일치하면 잠금 상태를 풀고 근처 Reader에게 자신의 ID 및 모든 기능을 제공한다.

이 방법은 단방향 해쉬 함수의 역원을 구하는데 따르는 어려움을 원리로 하여 인가되지 않은 Reader가 Tag의 내용을 읽어내는 것을 방지하는 방법이다. 하지만 이 방법은 스푸핑(spoofing) 공격을 탐지할 수는 있으나 공격 자체를 방지할 수는 없다. 스푸핑 공격자는 Tag에 query를 주어 Tag의 metaID를 받은 뒤 나중에 정당한 Reader에 재생방법으로 스푸핑한 Tag의 metaID를 전달한다. 이렇게 되면 스푸핑된 Tag에게 Reader는 올바른 key를 노출할 수 있는 위험이 생긴다. 이를 탐지하기 위하여 Reader는 Tag의 ID가 제시된 metaID와 일치하는지를 검증하기 위해 Back-End DB에 검증과정을 요청하여야 한다. 검증을 통해서 ID가 일치하지 않으면 Back-End DB는 Reader에게 스푸핑이 일어나고 있다는 것을 경고하게 된다.

이 방법의 또 다른 문제점은 metaID가 ID대신 여전히 식별자의 역할을 수행하기 때문에 사용자가 추적될 수 있다는 문제를 완벽하게 해결하지 못한다는 것이다. 도청을 방지하기 위해서 unlocked 상태가 아주 짧은 시간 동안에만 이뤄질 수밖에 없다는 점도 단점이라고 할 수 있다. 나아가 소비자들이 수많은 Tag들 가운데서 필요한 특정 metaID를 제어하고 업데이트하기에는 현실적으로 많은 어려움이 있다.

5. Random Hash-lock 기술

앞 절에서 살펴본 MIT의 Hash-Lock 기술을 발전시킨 것으로 해쉬 함수 이외에 의사난수생성기(random number generator)가 있는 Tag를 기본적으로 가정하고 있다. 이 방법은 Hash-Lock 기술의 문제점인 개인의 위치 추적 문제를 해결한 방법이다. 전체 과정은 다음과 같다.



[그림 5-9] Hash-Locking: Enhanced reader unlock protocol using a randomized hash 105)

105) S.A.Weis, S.E.Sarma, R.L. Revest, D.W. Engels, "Security and Privacy Aspects of Low-Cost

- Reader는 Tag에 query를 전달한다.
- Tag는 의사난수생성기를 이용해 랜덤 넘버 R 을 생성하고 R 과 ID_k 를 연결한 값을 해쉬한 $h(ID_k | R)$ 값과 함께 Reader의 query에 대한 응답값으로 Reader에 전송한다.
- 정당한 Reader는 DB에 저장되어 있는 모든 ID 값에 난수 R 을 연접시키고 해쉬하여 Tag가 보낸 값과 일치하는 ID_k 를 찾는다. 이 방법은 유통업자에게는 비실용적이기 때문에 적은 양의 Tag만을 소지한 소유자에게 적절한 방법이다.
- 더 안전성을 증대한 방법으로 Tag와 Reader가 공유 비밀 key k 를 갖고 있다고 가정하고 query될 때 응답값으로 $R, h(ID_k | R)$ 대신 $(R, ID_k \oplus f_k(R))$ 로 응답하는 방법이 사용될 수 있다. 단, 여기서 사용되는 f_k 는 의사난수 함수 앙상블 $F = \{f_k\}_{k \in N}$ 에서 선택되는 의사난수함수이다.

이 방법은 Hash-Lock에서 제시한 metaID = hash(key) 대신 난수값 R 을 이용함으로써 임의의 객체에게 Tag의 출력을 임의적이고 아무런 의미를 가지지 않는 정보인 $R, h(ID_k | R)$ 을 사용하여 사용자가 봉착하게 되는 추적문제를 해결한다.

현재 의사난수(PRF: Pseudo Random Function) 함수 앙상블 대칭키를 사용하는 암호 알고리즘보다 더 적은 resource로 구현될 수 있는 알고리즘은 알려져 있지 않다.

이 방법의 단점으로는 Reader가 수행하는 Hash-Lock의 임의화(randomized)에 소요되는 시간이 길고 이에 따라 Tag의 수가 적을 경우에만 그 효과를 나타낼 수 있다는 것을 들 수 있다. 또한 단방향 해쉬 함수는 역으로 해를 구하기 어렵기 때문에 input 상에서 비트의 누락이 생길 가능성이 있다. 이러한 누락은 Tag의 ID 값을 다르게 나타낼 수 있으므로 치명적일 수 있다.

6. Silent Tree Walking 기술

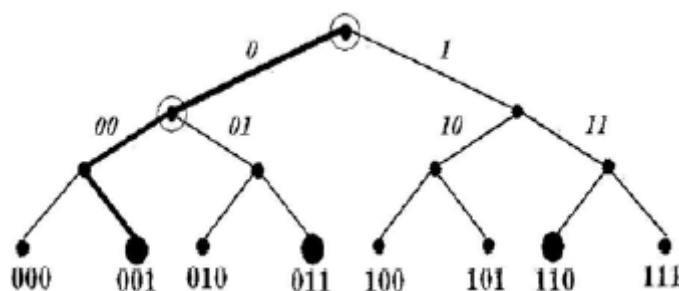
수동적인 도청자에 의해서 정보가 노출되는 위협은 근거리에서 도청이 가능한 RFID Tag 신호의 도청보다 수백 미터 이상 떨어진 원거리에서도 도청이 가능한

Radio Frequency Identification Systems" accepted for publication to the First International Conference on Security in Pervasive Computing (SPC 2003), March 12-14, 2003.

Reader에 의해 브로드캐스트 되는 신호를 도청하는 위협이 더 크다고 할 수 있다. 이러한 사실은 표준 tree-walking singulation 프로토콜에 의해 읽혀지는 ID들이 단순히 Reader에 의해 브로드캐스트 되는 신호만을 듣고 추론이 가능한 것이기 때문에 매우 안타까울 수밖에 없다.

Weis et al. 등은 수동적인 도청자가 읽은 ID를 추론하지 못하도록 하기 위해 Reader의 전송을 암호화하는 방법을 제시했다. Active 공격에 대해서는 방어할 수 없다는 사실은 다른 문제로 하더라도 논문에서 사용한 가정이 Tag들 사이에 공유할 수 있는 공통적인 비밀 스트링이 어느 정도 비현실적인 가정에 의존한다고 하였다. 만약에 Tag들이 singulation 전에 자신의 random pseudo ID를 발생할 수 있다면 이러한 가정은 제거될 수 있다. 이는 선택적인 블로킹 방법이 도청으로부터 Reader의 전송을 보호하는 방법과 조화를 이룰 수 있다는 것을 나타낸다.

일반적인 Tree Walking 기술은 다음과 같은 알고리즘을 갖는다.



[그림 5-10] Tree Walk example : Each tag in this example has a 3-bit serial number ¹⁰⁶⁾

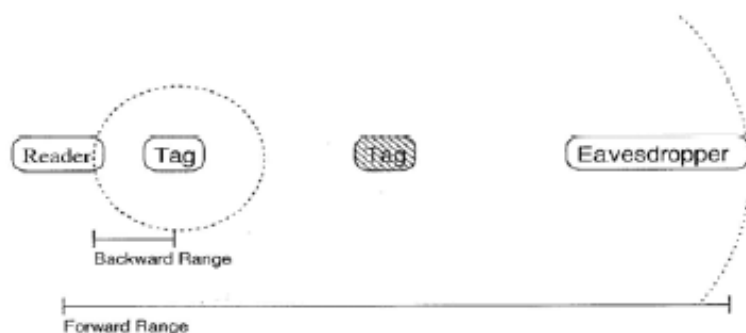
RFID 시스템에서는 여러 개의 Reader와 동시에 정보의 교환을 이루기 위해서 여러 개의 Transponder를 장려하는 경우가 발생한다. 이러한 multi-access를 위해서 Reader는 데이터의 collision이 일어날 경우 반드시 Transponder로부터의 데이터가 손상되는 것을 방지할 수 있어야 한다. 또한 Tag ID의 singulation을 위한 anti-collision 프로세스 역시 필요하다.

통신이 이루어지는 구간에서 Reader는 Transponder로부터 ID에 관한 정보를 요청하게 된다. 수신된 정보를 분석하면서 데이터의 collision 여부를 파악하게 되고 존재한다면 어느 비트에서 일어난 collision인지를 파악한다. collision 여부에 관한 정

106) A. Juels, R.L. Rivest, M. Szydlo, "The Blocker Tag: Selective Blocking of RFID Tags for Consumer Privacy." Conference on Computer and Communications Security Proceedings of the 10th ACM conference on Computer and communication security, October 2003, 103-111.

보를 인식한 Reader는 모든 Transponder에 collision이 일어난 부분에 관하여 ID 정보를 요청할 수 있다. 이러한 요청과정의 복잡성을 줄이기 위해 binary search 알고리즘이 사용된다.

이러한 Tree Walking 알고리즘에 입각하여 Silent Tree Walking 기술은 Reader에서 Tag로 가는 전방향(Forward) 채널의 신호에 대해서 도청을 방지한다. Binary Tree Walking Anti-collision 알고리즘은 Reader가 Tag ID의 각 비트를 브로드캐스트 하기 때문에 전방향 채널에 존재하는 도청공격에 취약한 문제점이 있다. MIT가 제시한 Silent Tree Walking 알고리즘은 이러한 안전하지 않은 Tag의 ID를 Reader가 브로드캐스트 하지 않아 도청공격에 안전하면서 동시에 Binary Tree Walking 알고리즘과 유사한 수행속도를 갖도록 변형한 변형기법이라고 할 수 있다. 전체 과정은 다음과 같다.



[그림 5-11] The forward reader to tag range is much greater than the less powerful tag to reader range¹⁰⁷⁾

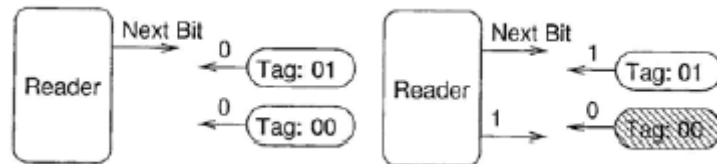
Tag들은 제품코드, 혹은 제조사 ID 등과 같은 공통된 ID 영역을 갖고 있다고 가정한다. 도청자는 수백 미터 떨어진 지점에서 Reader로부터 Tag로 전송되는 전방향 채널을 모니터 하여 Tag의 내용을 얻어낼 수 있지만 Tag가 Reader에 전송하는 응답값은 도청이 불가능하다. Tag를 호출하기 위해 Reader는 모든 Tag에 공통된 영역의 다음 비트를 브로드캐스트 하라고 요청한다. 충돌이 없으면 모든 Tag는 그 비트에서 같은 값을 공유하게 된다.

이 방법에서는 ID 값이 b_1b_2 , $b_1\overline{b_2}$ 인 두 개의 Tag가 있다고 가정한다. Reader는 두 개의 Tag로부터 충돌이 없는 b_1 을 받고 나서 그 다음 비트에서 충돌이 있는지를 탐지한다. b_1 이 도청자에게 비밀로 유지되어야 하고 Reader가 어떤 Tag를 호출하

107) S.A.Weis, S.E.Sarma, R.L. Revest, D.W. Engels, "Security and Privacy Aspects of Low-Cost Radio Frequency Identification Systems" accepted for publication to the First International Conference on Security in Pervasive Computing (SPC 2003), March 12-14, 2003.

는지 알 수 없도록 하기 위해 Reader는 $b_1 \oplus b_2$ 혹은 $b_1 \oplus \overline{b_2}$ 로 원하는 Tag를 호출한다.

예를 들어 설명하면 다음과 같다.



[그림 5-12] Silent Tree Walking: Left hand represents a non-collision; the right hand illustrates a collision¹⁰⁸⁾

- ID 값이 01, 00인 두 개의 Tag가 있다고 가정한다.
- Reader는 두 개의 Tag로부터 충돌이 없는 0을 받고 나서 그 다음 비트에서 충돌이 있는지를 탐지한다. 0정보가 도청자에게 비밀로 유지되어야 하고 Reader가 어떤 Tag를 호출하는지를 알 수 없도록 하기 위해 Reader는 $b_1 \oplus b_2 = 1$ 혹은 $b_1 \oplus \overline{b_2} = 0$ 을 이용해 원하는 Tag를 호출한다.

이 방법은 전 방향(Reader에서 Tag방향)에 있을 수 있는 도청 공격에 안전한 방법이지만 후 방향(Tag에서 Reader방향)에 있을 수 있는 도청자에 의해서 Tag가 전송하는 ID는 도청될 수 있다는 문제점을 갖고 있다.

7. Re-Encryption 기술

이 기술은 RSA사의 Ari Juels et al.이 Tag가 부착된 지폐를 이용할 경우 발생할 수 있는 프라이버시 위험을 해결하는 하나의 방법으로 제시되었다. 즉 Re-Encryption 기법은 Tag가 노출할 수 있는 정보를 보호하면서 법 집행기관이 지폐를 지속적으로 추적할 수 있는 기술이다.¹⁰⁹⁾ RFID 칩을 지폐에 내장하게 되면 인식기 근처를 통과시키는 것만으로 많은 양의 지폐의 진위를 정확히 판별할 수 있

108) S.A.Weis, S.E.Sarma, R.L. Revest, D.W. Engels, "Security and Privacy Aspects of Low-Cost Radio Frequency Identification Systems" accepted for publication to the First International Conference on Security in Pervasive Computing (SPC 2003), March 12-14, 2003.

109) A. Juels, R. Pappu, "Squealing Euros: Privacy Protection in RFID-Enabled Banknotes." In R. Wright, ed., Financial Cryptography '03. Springer-Verlag. 2003

다. 또한 지폐의 유통과정이 그대로 기록되어 돈세탁이나 불법자금 유통까지도 추적 가능하다. 이에 유럽중앙은행(ECB)은 2005년까지 Euro 지폐에 RFID Tag를 부착하는 계획을 제안하였으나 기술적으로 상세한 해결방안은 공개하지 않은 상태에 있다. 최근 일본 HITACHI는 연성이 강한 0.03mm 두께의 초소형 RFID 칩(제품명: mu-chip)을 개발하여 유로화에 내장시키는 프로젝트를 유럽중앙은행(ECB)과 진행 중인 것으로 알려져 있다.

프라이버시 보호를 위해 먼저 제안된 MIT의 Hash-Lock 기법은 고정된 key 값을 해쉬한 metaID값을 사용함으로써 ID에 대해 일정 고정된 값을 유지하기 때문에 지폐 추적문제를 방지하지 못한다. 또한 지폐에 사용되는 key가 비록 암호화된 것이라 할지라도 암호화된 일련번호 자체가 특정한 지폐에 관한 정보를 나타내는 표식이므로 개인의 추적에 이용되어질 수 있다. 따라서 지폐의 Re-Encryption에 사용된 암호문은 본연의 일련번호에 관련된 정보를 변경시키지 않으면서 겉으로 드러나는 표식은 달라질 수 있도록 하는 대책이 필요하다.

Re-Encryption 기술은 Tag가 전송하는 ID의 암호문 C 의 형태를 계속적으로 변경하는 것으로 이러한 문제점을 해결한다. Re-Encryption기술은 ElGamal 암호기술을 이용하여 다음과 같이 설계할 수 있다.

- 시스템 설정 : 결정론적 디피 헬만 문제(Decision Diffie Hellman)가 어려운 위수가 q 인 타원곡선 그룹 G 를 선택한다. 또한 p 를 G 의 생성자로 선택한 뒤 공개한다.
- Key 생성 : 법집행기관은 자신의 개인 key $SK_L = x \in {}_R Z_q$, 공개 key $PK_L = Y = xP$ 를 계산한다. 개인 key는 비밀로 유지하고 공개 key는 공개한다.
- 암호화 : 메시지 m 에 대한 PK_L 에 대한 암호문은 다음과 같이 계산되어진다.

$$C = Enc(PK_L, m, r) = (\alpha, \beta) = (m + rY, rP)$$

- 복호화 : PK_L 에 대한 비밀 key SK_L x 를 알지 못하면서도 임의의 난수 r' 를 선택하여 암호문 C 를 새로운 암호문 $C' = (m + r'Y, r'P)$ 로 변형하는 것이다. 즉, 같은 평문에 대한 여러 암호문들이 만들어 질 수 있다. 이로 인해 ID의 암호문의 형태인 C 가 고정되어 있지 않고 계속 변경될 수 있어 사용자의 추적을 방지하는 기법이라 할 수 있다. 그러나 위에 제시한 ElGamal 암호기법은 적응적 선택 암호문 공격(Adaptive chosen ciphertext attack)에 안전하지 않기 때문에 Fujisaki-Okamoto의 기법을 이용하여 다음과 같이 적응적 선택 암호문 공격에 대한 안전한 방법을 설계할 수 있다.

$$Enc(PK, m, \sigma) = (Enc(PK, \sigma, h_1(\sigma \parallel m)), h_2(\sigma) \oplus m)$$

단, $h_1, h_2: \{0, 1\}^* \rightarrow \{0, 1\}^*$ 는 랜덤 오라클 가정에서 안전한 해쉬 함수이며 $\sigma \in \{0, 1\}^*$ 는 난수를 말한다.

Re-Encryption방법이 사용하는 ElGamal 공개 key 암호는 매우 강인한 암호 알고리즘으로 이러한 연산을 수행할 수 있는 Tag를 가정하는 것은 비용적인 측면에서 그 구현에 어려움이 있다는 것이 하나의 단점이 될 수 있다. 또한 Re-Encryption을 사용하는 비율에 관련하여 그 비율이 너무 낮을 경우 암호문 C 는 지속적으로 변형되지 못하게 되는 문제점도 존재한다.

8. Blocker Tag

Blocker Tag의 개념은 프라이버시 보호를 위해서 Juels et al.이 제안한 것이다.¹¹⁰⁾ Blocker Tag란 RFID Tag 위에 부착하게 되는 것으로 RFID Reader를 혼란시켜 Tag의 데이터 송신을 무효화함으로써 개인이나 상품에 관한 데이터를 추적할 수 없게 설계한 통신방해 기술이다. Blocker Tag에 근접해 있을 때 데이터 추적으로부터 보호될 수 있으며 Blocker Tag가 제거될 때 Tag는 평상시처럼 사용될 수 있다.

이 기술에서 중요한 점은 Blocker Tag가 tree-walking singulation 프로토콜과 어떻게 선택적으로 조화를 이루는가를 이해하는 것이다. Blocker Tag는 통신방해 기술이나 Active Jamming의 형태는 아니다. 아주 정확한 방법으로 Tag 인식 과정에 참여함으로써 Passive Jamming의 한 종류로 생각할 수 있다. 이는 Tag의 가능한 모든 일련번호의 모든 스펙트럼을 방해하여 다른 Tag들의 일련번호를 감출 수 있다. 고객에 요청에 의해서 Blocker Tag는 프라이버시 보호와 관련하여 Reader가 Tag를 구별하지 못하도록 하여 물리적 영역에서의 해결책을 제시하여 준다.

Blocker는 2k개의 가능한 RFID Tag의 일련번호 모두를 방해(simulation)할 수 있다. 이러한 Tag를 'full blocker' 혹은 'universal blocker'라 한다. Tree-walking 알고리즘의 구조에 의해서 Blocker는 쉽게 구현된다. Reader가 다음 비트의 값을 위해 노드 B의 서브트리(subtree) 내에 있는 Tag에 질의를 할 때마다 Blocker Tag는 동시에 '0' 비트 혹은 '1'비트를 브로드캐스트 한다.

110) Juels, R.L. Rivest, M. Szydlo, "The Blocker Tag: Selective Blocking of RFID Tags for Consumer Privacy." Conference on Computer and Communications Security Proceedings of the 10th ACM conference on Computer and communication security, October 2003, 103-111.

개인 프라이버시 보호를 위해 Blocker Tag는 다만 Tag의 서브넷만을 효과적으로 블로킹하는 것으로 한정할 수 있다. 이와 같은 Blocker를 ‘partial blocker’ Tag 혹은 ‘선택적인 blocker’ Tag라 부른다.

예를 들어 선택적인 blocker는 단지 root의 왼쪽 서브트리에서 tree-walking을 수행하는 동안만 Reader에 응답할 수 있다. 이와 같은 선택적인 차단기의 특징은 다만 일련번호에서 ‘0’ prefix를 갖는 Tag를 읽는데 방해 효과를 가지고 있다. 이때 ‘1’ prefix를 갖는 Tag는 읽혀진다. 이러한 방법으로 선택적인 Blocker Tag는 보호를 위한 특별한 영역을 목적으로 할 수 있다.

만약 Blocker Tag가 어떤 영역은 블로킹하고 다른 영역은 그대로 둔다면 다음과 같은 문제가 일어난다. 예를 들어 ‘0’으로 시작하는 ID는 블록 시킨다고 하자. 이 경우 Reader는 ‘1’로 시작하는 ID는 반드시 읽게 된다는 사실은 절대로 피할 수 없다.

따라서 어떤 서브트리 내에서 읽기를 시도하지 않는다는 것을 Reader에 알려 줄 어떤 방법이 필요하다. 즉 Reader는 서브트리가 블록 되었을 시점을 파악할 필요가 있다. 그래서 블록된 서브트리에 갇히지 않고 트리의 다른 부분을 프로세스 할 수 있다. 다시 말해 서브트리 Tag가 존재할 때 좀 더 효과적으로 동작하도록 tree-walking singulation 프로토콜을 약간 개조한 방법을 생각할 수 있다.

예를 들어 노드가 주어지면 기본 tree-walking 프로토콜이 서브트리에 있는 모든 나뭇잎에 다음 비트(노드에서 나뭇잎으로 향하는 가지에 있는 레이블)를 브로드캐스트 하도록 요구한다. 우선 Reader가 특별한 질의에 응하도록 허용함으로써 프로토콜이 약간 증가할 수도 있다. “현재 노드에서 root된 서브트리는 블록 되어 있는가?” 만약 블록 되어있지 않다면 Reader는 표준 next 비트 질문을 요구한다.

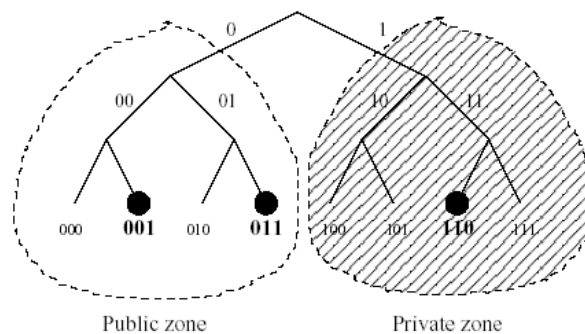
여기서 이것을 ‘polite blocking’이라 한다. 이는 Blocker Tag가 어느 서브트리가 블로킹되어 있는 것을 선언하기 때문이다.

Blocker Tag 접근 방식은 구현 비용이 매우 적기 때문에 매우 매력적인 방법이다. 일반적으로 consumer-product RFID Tag는 전혀 변경될 필요가 없다. RFID Tag는 값이 비싼 암호 방식을 원하지 않는다. 이는 전체 시스템 코스트 항목으로서 아주 중요한 사항이다. 그리고 Blocker Tag 자체가 매우 싸다. Blocker Tag는 본질적으로 아주 적은 회로 변경을 동반한 한 두 개의 표준 RFID Tag로 구성되어진다. 또한 Blocker Tag는 부수적으로 요구되는 구현이 아주 적다. 패스워드는 각 표준 RFID Tag를 관리하기 위해 필요하며 프라이버시 영역(privacy zone)을 변경하도록 권리를 부여하기 위해 필요하다. 이것은 이미 앞에서 설명한 Kill Command의 것과 같다.

고객의 프라이버시 보호를 위해 널리 이용되는 도구로서 매력을 확인할 수 있는 또 다른 부분은 Blocker Tag가 재고 관리와 같은 정상적인 RFID 기반 상업과정은 조금도 방해하지 않는 방식이라는 점이다. 따라서 이 관점에 비추어 판단할 경우 Universal Blocker Tag는 이러한 의도에 반대되고 있다고 할 수 있다.

프라이버시 개선을 목적으로 Universal Blocker Tag 대신에 선택적인 Blocker Tag 사용을 요구한다. Blocker Tag는 프라이버시 보호를 위해 한 개 혹은 그 이상의 영역에 걸쳐 특별한 명령(command)을 가지고 있다. 따라서 프라이버시 영역은 선택적인 Blocker Tag에 의해 보호될 Tag 일련번호(restricted number)로 구성된다. 선택적인 Blocker Tag는 Reader가 프라이버시 영역으로써 Blocker Tag에 의해 규정된 영역에 들어갈 때마다 Reader의 tree-walking 알고리즘 수행을 방해한다. 그리고 이외의 영역에서는 reading이 허용되며 Blocker Tag는 inactive 상태로 남는다.

프라이버시 영역과 Tag 일련번호의 동적 변경을 이용하여 상인 및 고객이 동시에 만족할 수 있는 프라이버시 정책의 영역(natural range)을 구현하는 것이 가능하다. 사용하는 환경에 의존하여 프라이버시 영역 내외로 움직일 수 있는 일련번호를 갖는 시스템을 상상할 수 있다.



[그림 5-13] Using the rst bit to divide into public and private zones illustrated on the Tree Walk¹¹¹⁾

프라이버시 영역에 상응하는 선택적인 Blocker Tag는 아주 간단하게 구현할 수 있으며 이는 single 노드의 서브트리로 구성된다. 예를 들어 그러한 영역이 일련번호 트리의 오른쪽 반으로 간단하게 구성된다. 즉 모든 일련번호가 leading bit가 1

111) Thomas Hjorth, Supporting Privacy in RFID System, IMM, DTU, Lyngby, Denmark M.Sc. project, no. 04/87, December 14, 2004

인 것을 의미한다.

이와 같은 간단한 방식을 자연스럽게 AutoID Center의 EPC-Code 시스템으로 통합시킬 수 있다. EPC Code는 96비트이며 다음과 같이 나누어져 있다.¹¹²⁾

- 8비트 header
- 28비트 EPC 매니저 코드는 Tag를 소유하는 조직이 사용
- 24비트 Object 매니저 코드는 EPC 매니저에 의해 결정되는 object 등급용으로 사용
- 36비트 일련번호는 object를 유일하게 구분하기 위해 사용

따라서 표준 프라이버시 비트로 설계된 object 매니저 코드 비트의 하나를 가짐으로써 지금까지 설명한 프라이버시 구조를 구현할 수 있다. 즉 모든 Blocker Tag는 유일한 EPC 매니저 코드에 할당할 수 있다.

이 방법의 단점으로는 Blocker Tag가 다중 ID의 시뮬레이션에 의해 의도된 RFID Reader 프로토콜을 방해하는 방향으로 잘못 사용되어질 수 있다는 것을 들 수 있다. Blocker Tag의 합법적인 프라이버시 응용은 multiple ID를 방해하지만 악의를 지닌 Blocker Tag는 ID의 허용된 프라이버시 영역 경계를 지키지 않는다.

RFID Reader는 프라이버시 영역에서 의도된 Blocker 행위와 조화를 이루도록 설계되어 있다. 그러나 기본적인 기능은 프라이버시 영역 외에서는 Tag를 읽을 수 있다. 따라서 악의의 Blocker Tag는 RFID Reader 프로토콜에 대해 DOS 공격으로 주어진다. 이러한 공격은 간단하게 서비스를 교란하도록 설계되어 있다. 또한 악의의 Blocker Tag의 기능은 Actual Tag를 방해하는 프라이버시 Tag와 유사하다. 검출에도 불구하고 공격은 성공되며 주위에 있는 Actual Tag는 Reader에 의해 구별되지 못한다.

선택적인 악의의 Blocker Tag는 좀 더 정교할 수 있다. 이는 검출을 피하기 위하여 Tag의 특정 부분 방해를 시도할 수도 있다. 이처럼 분산 공격에도 불구하고 속임수를 당한 Tag의 수는 singulation 프로토콜을 지연시킬 만큼 충분히 많을 수도 있다.

DoS Blocker Tag 공격의 검출은 상대적으로 단순하다. 만약에 감지된 RFID Tag의 수가 어떤 타당성 있는 임계값을 초과하면 공격이 진행 중에 있다고 가정할 수

112) 홍도원(D.W. Hong), 장구영(K.Y. Chang), 박태준(T.J. Park), 정교일(K.I. Chung), "Trend of Cryptography for Ubiquitous Environment", 전자통신동향분석 제20권 제1호 2005년 2월

있다. 이러한 임계값 검출 방법은 간단하고 견고하다. 그 이유는 이것은 악의의 Blocker Tag의 정확한 행위에 의존한 검출 방식이 아니기 때문이다. 즉 악의의 Universal Blocker Tag나 선택적인 Blocker Tag는 더욱 정교한 검출 메커니즘을 이용하며 이것은 규정된 Tag ID 영역의 사용에 의존한다. 예를 들어 Reader는 특정 제작자에 관련된 ID 영역에서 매번 Valid Tag를 나타내는 데이터베이스에 연결되어 있다. Tag ID는 이 영역 내에 있지만 만일 이 영역 내에 있지 않으면 부정으로 간주한다. 만약 Tag ID가 적어도 부분적으로 불특정하다면 공격자가 정확한 제품의 ID를 추정한다는 것이 거의 불가능하게 될 것이다.

9. NTT Forward Secure 기술

NTT사는 Tag의 비밀정보가 향후 템퍼링 등에 의해 노출되어도 이전 전송된 데이터가 여전히 안전하다는 것을 보장해 주는 순방향 안전성(Forward Secure)을 보장해주는 방법을 제안하였다. Tag는 안전성 요구사항을 다음과 같이 구별불가능성(Indistinguishability)과 순방향 안전성으로 정의하였으며 이를 만족하는 방법으로 저렴한 비용의 해쉬 체인 메커니즘을 이용하였다.

- 구별불가능성(Indistinguishability) : Tag의 출력은 순수 난수값(Truly Random Values)과 구별 불가능해야 한다. 또한 출력값과 Tag의 ID를 연결시킬 수 없어야 한다. 공격자가 특정 출력값이 공격 목표로 하는 Tag로부터 온다는 사실을 구분할 수 있다면 Tag를 추적할 수 있게 된다. 이는 Tag ID의 익명성의 개념에 포함된다.
- 순방향 안전성(Forward Secure) : 공격자가 Tag에 저장된 비밀 Tag 데이터를 얻을 수 있더라도 그 정보를 이용하여 Tag가 만든 이전 데이터를 추적할 수 없어야 한다. 즉, Tag의 출력을 도청하는 공격자는 현재의 출력값을 이전 출력값과 연계시킬 수 없어야 한다.

10. 기타

가. Relabeling

Inoue and Yasuura (IY)가 제안한 이 기술은 제품에 relabel Tag를 사용하여 새로운 식별자로 사용이 가능하게 하는 것으로 relabel 이전의 Tag 인식자는 후에

re-activation을 통해서 다시 사용이 가능하도록 착안되었다. 폐기물의 재활용과 같은 개념이라고 할 수 있다.

스웨덴의 IY는 이 기술에서 제품 자체의 인식을 위한 정보를 담고 있는 Tag와 고유 정보를 담고 있는 Tag 두 가지를 하나의 Tag로 제작하여 이를 분리가 가능하도록 한 RFID Tag를 제안하였다. Tag의 분리는 통해서 소비자들은 Tag가 담고 있는 정보의 복잡한 밀도를 줄일 수 있다.

나아가 Karjoth and Moskowitz는 이 방법을 발전시켜 사용자가 직접 Tag를 물리적인 방법으로 개조할 수 있도록 하여 데이터가 방출되는 것을 막고 제품의 변화된 상태를 물리적인 증거를 통해서 기록할 수 있도록 하였다.

하지만 이 방법의 한계점은 명확하게 드러난다. 우선 정보의 양을 줄여간다는 것이 불법적인 사용과 방법 자체를 방지할 수는 없다. 따라서 추적에 대한 위협도 모두 제거할 수 없다. Tag가 지닌 정보를 단순히 제품 자체 인식만을 위한 정보로 한정한다고 하더라도 이 역시 모든 Tag 정보들 사이에서는 고유 정보로써의 역할을 하게 된다.

나. 'Minimalist' cryptography

RFID Reader와 같은 고성능의 장치를 통해 프라이버시를 위해서 Tag의 relabel을 할 수 있으나 Tag 역시 스스로 relabel을 이룰 수 있다. Juels et al. 은 'minimalist' 시스템을 제안하면서 모든 Tag는 일정 개수의 pseudonyms를 갖도록 하였다. 이러한 pseudonyms 번갈아가며 사용하면서 Reader query를 거칠 때 마다 하나씩 제거하도록 한다. 인증된 Reader만이 각 Tag의 모든 pseudonyms를 저장할 수 있고 지속적으로 Tag를 인식할 수 있다. 반면 인증되지 않은 불법의 Reader의 경우 모든 pseudonyms 정보를 가지지 못하기 때문에 같은 Tag가 가지는 여러 인식자들을 연관시켜 파악하는 것이 불가능하다.

이러한 상반된 Reader들 사이에서의 불법적인 정보 유출을 방지하기 위해서 Juels는 데이터의 방출을 조절(throttle)하는 Tag를 제안하였다. 조절은 query가 너무 갑자기 일어났을 경우 반응을 늦추는 방식으로 이루어진다. 기본적인 시스템의 보안을 위해서 Reader가 Tag의 pseudonyms를 업데이트할 수 있게 하였다.

이런 방법은 소비재 환경에서 일어날 수 있는 조직적인 도청활동에 저항력을 가능하게 한다.

다. The Proxying Approach

일반 장소에 설치되어 있는 RFID Reader를 통한 정보의 보호를 대신하여 소비자들이 직접 자신만의 RFID 시스템 하의 프라이버시 보호를 위한 장비를 가지고 다니는 것을 의미한다. 실제로 일부 휴대전화는 이러한 기능을 가지고 있다. 이런 장비들은 프라이버시 보호를 위한 다양한 도움을 줄 수 있다. 다음은 제안된 몇 가지 시스템들을 나타낸다.

- Floerkemeier, Schneider, and Langheinrich은 ‘Watch Dog Tag;’를 제안하였다. 이는 RFID 시스템의 프라이버시 안전성을 검증할 수 있는 시스템으로 RFID Tag의 스캐닝 활동을 감지할 수 있고 Reader로부터 정보를 수집할 수 있다.
- Rieback, Crispo, Tanenbaum, Juels, Syverson, Bailey는 Watch Dog Tag와 비슷한 장비로 ‘RFID Guardian’ 혹은 ‘RFID Enhancer Proxy(REP)’로 불리는 장비를 제안하였다. 이는 RFID 개인 보호벽으로 Reader가 Tag에 요청하는 정보를 조절하는 기능을 수행한다. 다시 말해 통제 아래 선별적으로 Tag를 인식하는 것이다. 높은 전원을 필요로 하는 고성능 장비로 복잡한 프라이버시 문제를 해결하는데 도움을 줄 것이고 데이터 환경을 보완해줄 수 있는 RFID 외의 채널을 가진다.

제 6 장 RFID 개인정보보호 관련 전망 및 대응방안

제1절 RFID 개인정보보호의 전망

국내의 RFID 개인정보보호는 2003년을 시작으로 시민단체와 정부기관, 민간기관과의 협력으로 발전되어 왔다. RFID 프로젝트가 가장 많이 진행되고 있는 미국의 경우, 월마트의 대형시범사례를 필두로 여러 시범사례가 진행됨에 따라 개인정보보호에 관한 이슈들이 많이 발생하였다. 국내는 올해를 필두로 RFID 사업들이 많이 실행될 것이라 예상되며, 이에 대한 RFID 개인정보보호의 이슈도 많이 발생할 것이라 예상된다.

2005년 RFID태그 기술을 응용한 자동차요일제가 서울지역에서 실시되었다. 자동차요일제가 실시됨에 따라 시민단체 및 사용자들은 사생활 침해에 관련한 문제를 제기하였다. 하지만 이는 RFID에 대한 정확한 정보를 홍보하지 못하여 발생한 문제인 것으로 판단된다. 현재 진행되고 있는 자동차 요일제에 쓰이는 RFID 태그는 사용자의 정보가 전혀 들어가지 않은 자동차 식별 태그이다. 이 태그에는 UDDI 정보만 있을 뿐 개인정보는 전혀 들어가지 않은 상태이다. 따라서 리더기를 통해 태그가 인식되더라도 차량의 식별정보만이 입력된다. 물론 중앙의 정보시스템에서 다른 개인정보와 연계됨으로써 개인정보화 될 수도 있으나 이는 정부의 행정시스템 내부와의 연계를 통해 개인정보화가 된 것이므로 사실상 RFID 기술의 문제로 보기 어렵다. 하지만 자동차요일제의 홍보용지와 홈페이지 정보를 보면 RFID 개인정보보호에 대한 언급이 전혀 제공되지 않고 있다. 자동차 요일제를 전국지역으로 확대 실시하려면 RFID 개인정보보호에 관련한 정확한 정보를 홍보함으로써 RFID 개인정보 유출 가능성에 대한 오해를 불식시켜 줄 필요가 있다고 판단된다.

위의 사례처럼 하나의 RFID 사업이 진행되면 그에 관련된 RFID 개인정보보호 이슈가 흔히 발생된다. RFID 개인정보사례를 바탕으로 발생하는 문제원인(기술적인 문제원인 제외)을 분류하면, 시스템 구조상 개인정보보호 침해를 일으킨 경우와 정확한 정보를 얻지 못함으로 발생하는 경우로 나눌 수 있다.

시스템 구조상의 문제는 사업자의 윤리적 의식이 부족한 경우¹¹³⁾와 시스템 설계에서 개인정보보호에 대한 문제를 예상하지 않고 진행을 하는 경우에서 발생한다. 이러한 경우는 RFID 사업을 할 때 기술적인 적용에 중심을 두는 경우가 많다. 이는 시스템을 가동함으로서 발생하는 개인정보보호에 관련한 문제를 예상하지 않고 기

113) 질레트의 MACH3사례가 이에 해당된다.

술적용을 우선으로 사업을 수행하는 것을 의미한다. RFID 관련 컨퍼런스, 전시회에 개인정보보호에 관한 정보가 많이 나와 있지 않다는 사실을 이러한 분위기를 반영한다고 볼 수 있다. 이는 아직 RFID기술이 발전 및 개선이 필요한 분야이기 때문에 대부분이 기술에 시선이 집중되어 있기 때문이라 생각된다. 하지만 RFID의 개인정보보호는 매우 중요한 이슈이기 때문에 사업자들은 시스템을 구성할 때 개인정보관리 측면을 반드시 염두에 두어야 한다.

정확한 정보를 얻지 못함으로써 발생하는 문제는 사업자 및 정부의 RFID 기술에 대한 정확한 홍보부족으로 발생하는 문제이다. 위에서 언급한 자동차요일제의 경우 시행 이전에 정확한 정보를 홍보하였다면 문제제기를 미연에 방지할 수도 있었을 것이다.¹¹⁴⁾

RFID 개인정보보호 관련된 성공적인 사례들은, 공통적으로 사업자가 RFID 개인정보보호의 중요성을 인식하여, 이에 대한 정확한 정보를 고객에게 전달했었다는 점을 알 수 있다.¹¹⁵⁾

기술적인 문제와 관련된 RFID 개인정보의 문제점은 태그에 보안기술을 접목시키지 못했던 시점에서 발생될 수 있다고 우려를 한 것이었다. 이후에 태그관련 기술이 개선되어 가면서 보안기술이 태그에 접목하기 위하여 지속적인 노력을 하였다. 특히 EPCglobal Class1 Gen2¹¹⁶⁾태그는 보안기술이 강화되어 기존에 우려하였던 문제점들이 대부분 해결될 것이라고 생각된다.¹¹⁷⁾

EPCglobal Class1 Gen2 태그는 중요한 2가지 기능이 포함되어 있다. 하나는 태그의 기능을 제어하는 LOCK기능이고, 또 하나의 기능은 태그의 기능을 상실케 하는 KILL기능이다. 이 2가지 기능은 이전과의 시스템과 전혀 다른 시스템을 제공한다. LOCK과 KILL 기능은 2기술 모두 다 소비자에게 선택권을 줄 수 있다는 것이다. 즉 소비자가 개인정보 주체로서의 권리를 행사할 수 있는 시스템을 구성할 수 있다는 것이다. 이전의 시스템에서의 소비자의 개인정보 보호 권리는 즉시적으로 행할 수 없었으나, EPCglobal Class1 Gen2의 기술을 적용하면 즉각적인 소비자의 보호 행동을 취할 수 있다.¹¹⁸⁾

이렇듯 보호기술의 발달을 통해 소비자의 개인정보는 즉시적으로 지켜질 수 있으

114) 여기서 홍보의 범위는 개인정보보호에 관련한 정보를 의미한다.

115) “제 4 장 RFID 개인정보 침해사례” 내용 참조

116) 국제표준인 ISO 18000-6 type c 으로 확정되었다.

117) EPCglobal Class1 Gen2는 킬태그 기능의 보안이 첨가된 새로운 RFID 규격이다. 킬태그에 관한 자세한 내용은 “제 5 장 RFID 개인정보보호 관련 기술” 참조

118) 2006년 4월 24일에 있었던 RFID/EPCglobal 컨퍼런스 및 전시회에서는 EPCglobal Class1 Gen2 기술과 관련된 내용이 발표되었다. 발표내용에 따르면 EPCglobal Class1 Gen2의 기술은 완성도가 높으며, 가격 또한 상용화를 통해 저렴해질 것이고, 여러 분야에서 상용화함으로써 지속적인 기술보완이 이루어지고 있다고 한다.

며, 정부의 RFID 기술에 대한 정확한 정보전달과 시민단체, 사용자, 관련사업체들의 지속적인 관심을 통해 가이드라인을 개선해 나간다면 RFID의 개인정보관련 이슈는 발생되지 않을 것이라 생각된다.

제2절 RFID 개인정보보호에 관한 대응방향

RFID 개인정보보호를 위한 방법은 사회적인 방법과 기술적인 방법이 있으며, 이들의 조화를 이루는 것이 최선의 방향이다. RFID 기술적인 방법은 Gen2의 상용화를 통해 개선되어 갈 것이며, 사회적인 방향은 가이드라인의 개선과 RFID 기술에 대한 성숙한 의식을 통해 해결할 수 있을 것이라 생각된다.

현재 국내의 RFID 개인정보보호의 규제방식인 가이드라인 방식은 RFID 기술의 도입을 단계적으로 적용하고 있는 국내의 RFID 도입방식에 잘 어울리는 방식이다. 입법화는 기술의 도입기에는 바람직하지 않은 방향이다. 새로운 기술이 완전히 자리를 잡기도 전에 법을 제정하는 것은 그 기술이 성장하여 조속히 자리잡는 것을 방해한다. 법적인 제약으로 인하여 최상의 조건으로 성장하기 힘들 수도 있기 때문이다. 또한 한번 법 제정이 되면 개정이 쉽지 않기 때문에 계속 변화하면서 자리를 잡아야 하는 성장초기의 기술 환경에서는 부정적으로 작용할 수 있다.¹¹⁹⁾ 강제성이 부족하다는 시민단체의 의견에도 불구하고, 정확한 문제점을 예상할 수 없는 점과 기술이 아직 초기단계인 점을 고려하면 입법화는 성급한 해결방안이다. 이와 관련해 정통부에서 RFID 개인정보보호 관련 가이드라인을 발표하였는데, 가이드라인 방식은 기술이 발전해 가면서 지속적으로 개선되어야 한다는 점을 잊지 말아야 할 것이다.¹²⁰⁾

RFID 개인정보보호 가이드라인은 사용자의 입장이 충분히 반영되어야 한다. RFID 기술도입에서 사용자의 개인정보보호는 반드시 우선적으로 고려되어야 할 부분이다. 그러나 RFID 기술의 무분별한 반대는 주의해야 한다. 구체적으로 잘못된 부분에 대한 문제제기는 바람직하겠지만, 설부른 추측으로 인한 RFID 기술자체에 대한 반대여론의 형성은 바람직하지 못한 현상이다.¹²¹⁾ RFID 기술이 주는 이점을 정확히 이해하고 문제점 개선을 위하여 성숙된 자세로 서로 협력을 해야 할 필요가 있다.

EPCglobal의 자료에 따르면 현재 한국을 포함한 아시아지역은 물류, 유통의 중심

119) 이 부분에 대한 자세한 내용은 “제 1 장 RFID에서의 개인정보보호의 의미” 참조

120) 개선점에 대한 내용은 “제 3 장 RFID 개인정보보호 관련 국내동향” 참조

121) 미국에서는 한 시민단체에 의해서 종교적인 이유로 반대를 하는 운동이 발생되고 있다.

지로서 RFID 기술도입이 매우 빠르게 진행되고 있다.¹²²⁾ 이처럼 빠른 발전이 이루어지고 있는 기술 분야에서 기술적인 우위를 선점해 나가기 위해서, 정부는 관련기술의 로드맵을 가지고 체계적으로 기술개발과 상용화를 추진해 나가고 있으며, 여기서 파생되는 개인정보보호 오용의 부작용을 최소화하기 위해 가이드라인 방식의 지속적 보완을 추진하고 있다.

성공적인 RFID 산업발전과 RFID 개인정보보호를 동시에 이루기 위해서는 사업자, 소비자, 정부의 전략적인 행보가 요구된다. 사업자는 RFID 개인정보보호의 중요성을 인식하고, 이에 맞는 개인정보보호 시스템을 갖추어야 할 것이며, 소비자를 위해 어떤 더 나은 서비스를 제공할 수 있을지를 고민해야 한다. 그리고 소비자는 성숙한 자세로 기술도입을 지켜봐야 할 것이고, 정부는 RFID기술의 정확한 정보를 홍보하고, 가이드라인의 개선을 위해 힘써야할 것이다.

결국 문제점은 추측일 뿐이다. 추측을 사실로 만드는 것은 실행이다. RFID 기술의 국가적인 발전을 위해 RFID 단계적 도입과 체계적인 시스템 구성으로 RFID 개인정보보호 문제를 해결해나가야 할 것이며, 이를 위한 사회 구성원 전반의 노력과 협조가 필요하다는 점을 거듭 강조하고 싶다.

122) 한국은 미국을 제외한 전 세계에서 RFID 성장률 4위, 아시아지역 3위를 기록하고 있다. 아시아 지역은 일본, 홍콩, 한국 순이다. 시점: 2006년 3월

[부록 1] RFID에서의 프라이버시 보호를 위한 10대 최소 가이드라인 v1.0

● RFID에 관한 개인의 권리문제

RFID에 관한 제도적 규범은 RFID의 유통과 재고관리의 효용성에 대한 부정이 아니라 개인정보와 프라이버시를 보호하기 위해 필요한 것이다. RFID의 기술적 특징은 전파를 이용하여 소리 없이 원거리에서 정보를 추적하고 수집할 수 있다. 무방비 상태의 개인이 정보의 절취를 막기 위해서 할 수 있는 것은 극히 제한적이다.

그렇기 때문에 개인은 RFID 시스템으로부터 『회피할 수 있는 권리』·『추적을 거부할 수 있는 권리』를 보장 받아야 한다.

이러한 권리는 RFID 시스템의 존재유무를 알 수 있어야 비로소 보장받을 수 있는 것으로 기존의 개인정보보호 관련법으로는 보호받기 힘들다. 또한, 기술적 특성상 국제적 규범인 OECD 프라이버시보호 가이드라인의 ‘수집제한의 원칙’의 내용인 개인의 사전 동의권을 얻는 것이 힘든 기술 특성을 갖고 있다. 그런 의미에서 RFID에 의해서 수집되는 정보가 개인의 동의 없이 직접적으로 혹은 제 3자를 통하여 분석·제공·가공되는 것에 대한 더욱 엄격한 통제가 당연히 필요할 것이다.

● RFID의 정의 문제

RFID(무선주파수인증)는 ①A transponder (RF tag) electronically programmed with unique information ②An antenna or coil, ③A transceiver (with decoder), 세 가지 요소로 이루어진다. ①사물에 부착된 ‘RF tag(이하 전자추적표)’의 정보를 ②안테나를 통하여 전파로 ③컴퓨터로 해석되어 정보가 분석·집적되는 것이다.

RFID란 위와 같은 시스템임을 의미한다. ①RF tag, ②RF tag의 정보 전파·읽어들이는 리더기, ③RF tag 정보를 기록하는 컴퓨터 등등의 요소. RFID에 대한 규범을 이야기 할 때는 각 요소 뿐 아니라 통합적 시스템에 관한 규범을 의미 한다. 특히, RF tag는 본질적 특성을 명확히 하기 위하여 ‘전자추적표’로 사용되어야 할 것이다.

1. (사전 신고의 원칙)

기업·공공기관의 RFID 시스템 도입 시 정부(개인정보보호독립기구)에 사전 보고가 의무화 되어야 한다.

기업·공공기관에 RFID 시스템이 도입된다면 그 사업주체는 관계 규범에 의하여 정부측에 사전 보고가 의무화되어야 한다. 향후 설립되어야 할 (가칭)개인정보보호위원회는 이러한 각종 자료를 바탕으로 개인에게 직·간접적으로 영향을 주는 RFID 시스템에 대하여 프라이버시 영향평가를 수행할 수 있어야 한다.

2. (이용목적 심의의 원칙)

모든 RFID 시스템은 이용 목적을 밝히고 사전 심의를 받아야 한다.

‘RFID로 수집된 정보를 마케팅으로 활용하기 위해서’와 같은 추상적 이용목적을 갖는 RFID시스템은 사회적으로 용인될 수 없어야 한다. 예를 들어 ‘티머니 카드’라면 요금정산이 이용 목적이라는 것을 명확하게 규정해한다. (가칭)개인정보보호위원회는 이용 목적의 구체성을 심의할 수 있어야 한다. 이용 목적의 구체성을 따지는 것은 RFID시스템의 무분별한 개인정보 수집을 제한하는 효과를 갖는 것이다.

3. (추적시스템 제한적 도입의 원칙)

개인정보수집·개인의 추적·감시를 목적으로 하는 RFID 시스템의 도입의 경우 다섯가지의 전제조건이 성립된 후 시행될 수 있어야 한다.

- ① 추적 거리·장소·시간에 제한이 없는 RFID 추적 시스템은 원칙적으로 금지한다.
- ② 추적 감시 시스템은 (가칭)개인정보보호위원회의 프라이버시 영향평가를 필수적으로 받아야 한다.
- ③ 개인의 사전 동의를 받은 후 시행이 가능하도록 해야 한다.
- ④ 주민등록번호와 같은 개인식별번호는 ‘전자추적표’에 입력되지 않아야 한다.
- ⑤ 작업장에서 노동자에게 부착되는 RFID시스템은 단체협약이 전제가 되어야 한다.

4. (제 3자공유 제한의 원칙)

사업주체는 RFID시스템에 의해서 수집된 개인정보는 개인의 동의 없이 어떠한 경우라도 직접적으로 혹은 제3자에 의해서 가공, 유통, 분석되지 않음을 보증해야 한다.

보증에 대한 부인은 RFID 시스템의 폐기와 관련 DB 추적·몰수를 의미한다. 의도된 혹은 의도되지 않은 개인정보침해사고에 대해서 삼진 아웃제를 적용하여 관련 RFID 시스템의 폐기 DB의 몰수·폐기해야 한다.

5. (제한적 동의의 원칙)

RFID 시스템에 의한 개인정보 활용 동의는 제한적 동의임을 명백히 해야 한다.

개인정보 활용 동의는 무제한적 활용·유통을 의미하지 않는다. 동의 받은 개인정보가 활용될 경우 가공되고 있다는 사실, 가공되었다는 사실에 대한 구체적인 정보를 각 사안별로 개인에게 통보해야 한다. 구체적인 사실이란, 가공목적, 가공시점, 이용기간, 정보의 폐기 시점, 정보를 가공하여 얻은 수익 등을 의미한다. RFID 시스템은 효율적인 DB를 구축한다. DB간의 결합·이동이 점증할 수 있기 때문에 엄격한 규제가 필요한 것이다.

6. (배상의 원칙)

RFID 시스템을 도입하는 주체(기업, 공공기관 등)는 프라이버시 침해와 관한 배상 기준을 마련해야 한다.

RFID 시스템 가동 중 발생하는 고의·실수에 의한 프라이버시 침해 문제의 발생을 대비하여 사업주체는 배상 기준을 마련해야 한다. 이는 사후 피해 구제 절차를 신속하게 진행하기 위해 필요 한 것이다.

7. (회피의 원칙)

RFID 시스템에 대한 회피는 권리로 보장받아야 한다.

RFID 시스템을 이용하는 기업·공공기관은 RFID 시스템을 회피하는 개인을 부당하게 차별하거나 회유·강요·협박할 수 없다. 이 권리에 대한 침해는 법적으로 처벌받아야 한다. 또한, RFID 시스템에 대한 회피의 권리는 RFID 시스템으로 결제시스템 작동할 경우 이외의 결제수단이 보장되어야 함을 의미한다.

회피의 권리는 엄격히 보장되어야하며 출입·통제 등에 이용되는 보안관련 시스템은 프라이버시 영향평가에 따라 예외가 될 수 있을 것이다.

8. (투명성의 원칙)

전자추적표가 장착된 물품에는 그 존재와 관련 내용을 표기해야 한다.

모든 소비자가 그 물품에 존재하고 있는 전자추적표를 인지할 수 있도록 사업주체는 물품에 표기를 해야 한다.

예를 들어 ‘티머니 카드’라면 “1) 전자추적표가 부착된 카드입니다. 2) 전자추적표의 이용목적은 요금 정산을 위한 것입니다. 3) 전자추적표에 담긴 정보는 000입니다. 4) 전자추적표는 13.56MHz의 단파에 작동하며 인식거리는 10cm입니다. 5) 전자추적표의 인식은 교통시스템에 한해서 작동합니다. 6) 전자추적표는 요금정산을 위하여 승차시간, 요금내역 등의 개인정보를 수집합니다.” 등과 같은 내용이 명확하게 이용자가 알 수 있도록 카드에 기술되어야 한다.

9. (선택 가능성의 원칙)

이용자들이 전자추적표를 쉽게 떼어낼 수 있도록 위치를 표기해야 한다.

물품 구입을 했다는 이유로 추적·감시·침해에 관한 잔존하는 위험을 제거하기 위하여 소비자는 전자추적표를 떼어낼 수 있어야 한다.

10. (인지의 원칙)

전자추적표를 읽는 리더기 위치는 알려져야 하며 어떤 전자추적표를 수집하고 있는지 알 수 있도록 공개되어야 한다.

어떤 장소에 리더기가 위치하고 있다면 어떤 주파수 대역의 정보를 수집하는 것인지, 정보 수집 주체, 연락처 등등의 기록을 사람들이 즉시 관련 정보를 알 수 있도록 그 장소에 기술되고 있어야 한다.

[부록 2] 정보통신부 가이드라인

제1장 총칙

제1조(목적) 이 가이드라인은 RFID 시스템의 이용에 따른 이용자의 프라이버시를 보호하고 안전한 RFID 이용환경을 조성하는 것을 목적으로 한다.

제2조(정의) 이 가이드라인에서 사용되는 용어의 정의는 다음과 같다.

1. “개인정보”라 함은 생존하는 개인에 관한 정보로서 당해 개인을 알아볼 수 있는 정보(당해 정보만으로는 특정 개인을 알아볼 수 없는 경우에도 다른 정보와 용이하게 결합하여 알아볼 수 있는 것을 포함한다)를 말한다.
2. “RFID 시스템”이라 함은 대상이 되는 사물 등에 RFID 태그를 부착하고 전파를 사용하여 해당 사물 등의 식별 정보 및 주변 환경 정보를 인식하여 각 사물 등의 정보를 수집·저장·가공 및 활용하는 시스템을 말한다.
3. “RFID 태그(Radio Frequency Identification Tag)”라 함은 사물 등에 내장 또는 부착되어 당해 사물 등에 관한 정보 또는 기타 정보를 기록하고, 전파를 이용하여 이들 정보에 대한 판독 또는 저장이 가능한 것을 말한다.
4. “RFID 취급사업자”라 함은 RFID 칩이나 태그를 제조·판매하거나 RFID 태그가 부착 또는 내장된 물품을 제조(가공 및 포장을 포함한다) 또는 판매하는 자, RFID 태그에 기록된 물품정보 등을 개인정보와 연계하는 자, RFID 태그에 개인정보를 기록하거나 RFID에 기록된 개인정보를 수집하는 자를 말한다.
5. “이용자”라 함은 RFID 태그가 내장 또는 부착된 물품을 구매하거나 RFID 태그가 내장 또는 부착된 물품을 이용하여 제공되는 용역을 이용하는 자를 말한다.

제3조(적용범위) 이 가이드라인은 RFID 태그에 개인정보를 기록하여 당해 개인정보를 수집하거나 RFID를 통하여 수집한 물품정보와 개인정보를 연계하는 등 RFID 시스템을 이용하여 개인프라이버시를 침해할 수 있는 경우에 적용한다. 다만, 개인정보와 프라이버시 침해 위험 없이 물품정보를 수집하여 이용하는 경우에는 적용하

지 아니한다.

제2장 개인정보의 기록·수집 및 연계

제4조(개인정보 기록의 금지 등) ① RFID 취급사업자는 RFID 태그에 개인정보를 기록하여서는 아니 된다. 다만, 법률에 정한 경우 또는 서면 등을 통한 이용자의 명시적인 동의가 있는 경우는 그러하지 아니하다.

② RFID 취급사업자는 제1항 규정에 의한 동의를 얻고자 하는 경우에는 당해 이용자에게 미리 개인정보의 기록목적 및 이용목적 등을 고지하여야 한다.

제5조(RFID 태그를 통한 개인정보의 수집) RFID 취급사업자는 제4조제1항 규정의 RFID 태그에 기록된 개인정보를 수집하는 경우에는 당해 이용자에게 이를 통지하거나 또는 쉽게 알아볼 수 있는 방법으로 표시하여야 한다.

제6조(RFID 태그의 물품정보 등과 개인정보의 연계) RFID 취급사업자는 RFID 태그의 물품정보 등과 개인정보를 연계하는 경우에는 미리 그 사실을 당해 이용자에게 통지하거나 쉽게 알아볼 수 있는 방법으로 표시하여야 한다.

제3장 RFID 태그 부착 사실의 표시

제7조(RFID 태그 부착 사실 등의 표시 등) ① RFID 취급사업자는 이용자가 물품을 구입하거나 제공받은 이후에도 당해 물품에 RFID 태그가 내장 또는 부착되어 있는 경우에는 다음 각 호의 사항을 미리 이용자에게 설명하거나 당해 물품 또는 그 포장에 표시하여야 한다.

1. RFID 태그가 부착되어 있다는 사실 및 그 부착 위치
2. RFID 태그의 성질 및 기능
3. RFID 태그에 기록되어 있는 정보
4. 제12조의 규정에 의한 개인정보관리책임자의 연락처 등

② RFID 취급사업자는 제1항의 규정에 의한 설명 또는 표시가 곤란한 경우에는 당해 물품을 판매하거나 용역을 제공하는 장소에서 이용자가 쉽게 알아볼 수 있는 방법으로 제1항 각호의 사항을 게시하여야 한다.

제8조(RFID 태그의 기능제거 방법 등에 대한 표시 등) ① RFID 취급사업자는 이용자가 물품을 구입하거나 제공받은 이후에도 당해 물품에 RFID 태그가 내장 또는 부착되어 있는 경우에는 이용자가 스스로 RFID 태그의 기능을 제거할 수 있는 방법 등을 설명하거나 해당 물품 또는 그 포장에 표시하여야 한다.

② RFID 취급사업자는 제1항의 규정에 의한 설명 또는 표시가 곤란한 경우에는 당해 물품을 판매하거나 용역을 제공하는 장소에서 이용자가 쉽게 알아볼 수 있는 방법으로 제1항 각호의 사항을 게시하여야 한다.

③ RFID 취급사업자는 RFID 태그가 내장 또는 부착된 물품 등을 구입한 이용자가 용이하게 RFID 태그의 기능을 제거할 수 있는 수단을 제공하여야 한다.

④ RFID 취급사업자는 이용자가 RFID 태그를 제거하였다는 이유로 부당하게 이용자에게 불이익을 주거나 이용자를 차별하여서는 아니된다.

⑤ RFID 취급사업자는 제1항 규정의 RFID 태그의 기능을 제거하는 것이 이용자의 이익이나 공공의 이익을 해칠 우려가 있는 경우에는 그 이유를 이용자에게 설명하거나 해당 물품 또는 그 포장에 표시하여야 한다.

제4장 보 칙

제9조(RFID 태그의 인체이식 등 금지) ① 누구든지 RFID 태그를 인체에 이식하거나 제거할 수 있는 권한을 부여하지 아니하고 이용자의 신체에 RFID 태그를 지속적으로 착용하도록 하여서는 아니된다. 다만, 법률에 특별한 규정이 있는 경우는 그러하지 아니하다.

② 누구든지 법률에 특별한 규정이 있는 경우를 제외하고는 RFID 태그를 이용자가 인식할 수 없는 방법으로 물품 등에 부착하여서는 아니된다.

제10조(RFID 리더기 설치의 표시) 누구든지 RFID 태그가 부착 또는 내장되어 이용자에게 교부된 물품에 대한 정보 또는 RFID 태그에 기록된 개인정보를 관독할 수 있는 리더기를 설치한 경우에는 리더기가 설치되어 있다는 사실을 이용자가 용이하게 인식할 수 있도록 표시하여야 한다.

다만, 물류유통·내부 보안유지·재고 관리를 목적으로 리더기를 설치하거나 고정된 장소에 설치되지 않아 설치장소를 용이하게 표시하기 힘든 경우에는 그러하지 아니하다.

제11조(RFID 시스템의 개인정보보호를 위한 관리적·기술적 조치) RFID 취급사업자는 RFID 시스템을 이용하여 개인정보를 기록·수집하거나 RFID 태그의 물품정보 등과 개인정보를 연계하는 경우, 당해 개인정보가 분실·도난·누출·조 또는 훼손되지 아니하도록 「개인정보의 관리적·기술적 조치 기준」(정보통신부고시 제 2005-18호)에 준하는 조치를 취하여야 한다.

제12조(RFID 시스템에 대한 프라이버시 영향평가) RFID 취급사업자는 RFID 시스템을 이용하여 개인정보를 기록·수집하거나 RFID 태그의 물품정보 등과 개인정보를 연계하는 경우 RFID 시스템 이용에 따른 프라이버시 침해 요인 등을 당해 RFID 시스템 도입 시에 분석·평가하여 이용자의 프라이버시가 침해되지 않도록 노력하여야 한다.

제13조(개인정보관리책임자의 지정) RFID 취급사업자는 RFID 시스템을 이용하여 개인정보를 기록·수집하거나 RFID 태그의 물품정보 등과 개인정보를 연계하는 경우 RFID 태그와 관련한 이용자의 프라이버시를 보호하고 이용자의 불만 등을 신속하게 처리하기 위하여 개인정보관리책임자를 지정하여야 한다.

제14조(RFID 태그에 대한 이용자의 인식 제고) RFID 취급사업자 또는 RFID와 관련이 있는 사업자단체·기관은 이용자에게 RFID 태그의 유용성 및 장·단점 등에 관한 정보를 제공하는 등 이용자의 인식을 제고하기 위하여 노력하여야 한다.

제15조(개인정보 이용·제공·파기 등) 이 가이드라인에 정한 사항 외의 개인정보의 이용·제공·파기 및 이용자의 권리보호 등 개인정보 보호와 관련한 사항은 정보통신망 이용촉진 및 정보보호 등에 관한 법령 및 지침의 개인정보보호 원칙에 따른다.

제16조(가이드라인의 개정에 관한 사항) 이 가이드라인은 RFID 관련 기술의 발전 및 이와 관련한 개인정보 침해의 변화에 따라 이용자, RFID 취급사업자 및 관련기관 등의 의견수렴을 통해 개정할 수 있다.

[부록 3] KISA RFID 개인정보보호 가이드라인(안) - 2004. 11. 15

제1조(목적) 이 가이드라인(지침)은 RFID 태그가 부착된 물품 및 그와 관련된 용역(이하 “물품등”이라 한다)을 취급하는 자(이하 “사업자”라 한다)가 준수하여야 할 기본적 사항을 정함으로써 RFID 태그를 안전하게 사용할 수 있는 환경을 조성하고 RFID 태그의 사용에 따른 소비자의 개인정보 보호 및 프라이버시의 침해방지에 이바지함을 목적으로 한다.

제2조(정의) 이 가이드라인에서 사용되는 용어의 정의는 다음과 같다.

1. “개인정보”라 함은 생존하는 개인에 관한 정보로서 성명·주민등록번호 등에 의하여 당해 개인을 알아볼 수 있는 부호·문자·음성·음향 및 영상 등의 정보(당해 정보만으로는 특정 개인을 알아볼 수 없는 경우에는 다른 정보와 용이하게 결합하여 알아볼 수 있는 것을 포함한다)를 말한다.
2. “RFID 태그(Radio Frequency Identification Tag)”라 함은 물품 등에 부착되어 당해 물품 등의 식별정보 기타 정보를 기록하고, 전파를 이용하여 이들 정보의 읽기 또는 쓰기가 가능한 것을 말한다.
3. “소비자”라 함은 사업자가 제공하는 물품 및 용역을 소비생활을 위하여 사용하거나 이용하는 자를 말한다.
4. “사업자”라 함은 RFID 태그 및 RFID 태그 부착 물품 및 용역을 제공하는 자를 말한다.

제3조(적용범위) 이 가이드라인은 RFID 태그를 직접 또는 간접으로 개인정보의 수집·이용·제3자 제공에 사용하는 사업자에 대하여 적용한다.

제4조(RFID 태그 부착 사실 등의 고지) 사업자는 RFID 태그가 부착된 물품 등을 제공하는 경우 소비자가 쉽게 알 수 있도록 다음 각호의 사항을 당해 물품 또는 그 포장에 표시하여야 한다. 다만, 표시가 어려운 경우에는 특정 장소에 게시하는 등의 방법으로 소비자에게 고지하여야 한다.

1. 당해 물품에 RFID 태그가 부착되어 있다는 사실 및 그 부착 위치
2. RFID 태그의 형태 및 그에 기록되어 있는 정보
3. RFID 태그의 부착에 따른 고충을 해결하기 위한 전화번호 등 연락처

5조(RFID 태그를 통한 개인정보 수집·이용 등의 요건) ①사업자는 RFID 태그를

매개로 하여 개인정보를 수집·이용하고자 할 경우에는 그 수집사실 및 이용목적을 소비자에게 통지하거나 공표하여야 한다.

②사업자는 RFID 태그를 통하여 알 수 있는 개인정보를 수집 이용 목적 외에 이용하거나 제3자에게 제공하는 경우에는 해당 소비자의 동의를 얻어야 한다.

③사업자가 RFID 태그를 통한 개인정보의 수집목적 또는 제공받은 목적을 달성한 때에는 즉시 해당 개인정보를 파기하여야 한다.

제6조(소비자의 RFID 태그 기능정지 선택) ①사업자는 소비자가 RFID 태그의 기능 정지를 선택할 수 있도록 그 방법을 직접 설명·게시하거나 해당 물품 또는 그 포장에 표시하여야 한다.

②사업자는 RFID를 제거하는 것이 소비자의 이익이나 공공의 이익을 해칠 우려가 있는 경우에는 소비자에게 그 사유를 직접 설명 또는 특정 장소에 게시 등의 방법으로 알려야 한다.

제7조(RFID 태그와 연계된 소비자정보 데이터베이스의 개인정보보호 조치)

사업자는 RFID 태그와 연계된 소비자정보 데이터베이스를 취급함에 있어서 개인정보가 분실·도난·누출·변조 또는 훼손되지 아니하도록 안전성의 확보를 위한 다음 각호의 조치를 취하여야 한다.

1. 개인정보의 안전한 취급을 위한 내부관리계획 수립 및 시행
2. RFID 태그의 보안에 필요한 적정 보안기술의 설치
3. 그밖에 개인정보의 보호를 위하여 필요한 조치

제8조(RFID 태그 사용시 프라이버시 사전영향평가) 사업자는 RFID 시스템을 활용하여 개인정보를 수집·이용하는 경우에는 그 사용 이전에 해당 RFID 시스템 이용에 따른 프라이버시 침해요소 등을 평가하여 그 침해를 최소화할 수 있도록 노력을 하여야 한다.

제9조(소비자의 개인정보 열람 및 정정요구 등) 소비자는 RFID 태그와 관련된 자신의 정보에 대하여 열람, 정정 및 보완을 요구할 수 있으며, 사업자는 소비자 권리 보호를 위하여 개인정보처리와 관련된 RFID 시스템의 설치, 활용 및 관련 정책을 공개하여야 한다.

제10조(개인정보관리책임자의 지정) 사업자는 소비자의 개인정보를 보호하고, RFID

태그와 관련된 소비자의 불만 또는 고충을 처리하기 위하여 개인정보관리책임자를 지정하고 그 연락처를 소비자에게 고지하여야 한다.

제11조(RFID 태그에 대한 인식의 제고) 사업자 또는 전자인식표와 관련이 있는 사업자단체·기관은 소비자가 RFID 태그를 바로 알고 그의 취급에 관하여 의사를 결정할 수 있도록 RFID 태그의 이용 목적, 장·단점 등에 관한 정보를 제공하는 등 소비자의 인식을 제고하기 위하여 노력하여야 한다.

참 고 문 헌

[기관보고서]

- 과기부, “2005년도 RFID 기술영향평가 보고서”, 2006년 2월
- 미 감사원, “Key Considerations Related to Federal Implementation of RFID Technology”, 2005년 6월
- 법무부, “주요국의 개인신용정보보호법제”, 1999
- 서울 高判 1995.8.24 선고, 94구 39262
- 전자정보센터, “IT리포트 : RFID 시스템의 보안 및 프라이버시 보호를 위한 기술 분석”, 주학수, 전자부품연구원
- 전자정보센터, “IT리포트 : RFID 동향 및 사례분석 보고서”, 주)KRG
- 정보통신정책연구원, “유비쿼터스 사회의 역기능에 관한 법제도적 기초연구”, 한국전산원, 2004년 12월
- 한국기술거래소, “RFID”, 전자정보센터, 2005.12
- 한국전산원, “2001한국인터넷백서”, 2001년
- 한국전산원, “개인정보보호의 법적쟁점과 해결과제”, 2004년 8월
- 한국전산원, “NCA CIO REPORT”, 2005년 3월 31일(05-6호)
- 한국전산원, “우리나라의 개인정보보호체계와 제도적 이슈”, 오강탁, 2004.5
- 한국전산원, “NCA CIO REPORT : RFID 도입과 프라이버시 보호 관련 법제 현안 분석”, 구병문, 2004년 10월 15일(04-13호)
- KETI 전자부품연구원, “RFID(Radio Frequency IDentification)”, 2005년 12월
- KISA 한국정보보호진흥원, “RFID 프라이버시 가이드라인 해설서”, 2005년 11월
- 한국정보보호진흥원, “전자거래보호 이슈리포트 : 유타주 하원의 RFID 알권리 법안”, 이용필, 2004.3
- 함께하는 시민연대, “제4차 빅브라더 보고서”, 2004년 11월
- APEC ECSG 2004년 10번째 Draft Version
- EPIC, Senator Simitian, “LEGISLATIVE COUNSEL'S DIGEST”,
<http://www.epic.org/privacy/rfid/sb682_33005.html>
- Information law grad. GW'06, “EU and US on RFID Privacy”,
<<http://luminousvoid.net/archives/32/eu-and-us-on-rfid-privacy>>, 2005.3.11
- NCC, “calling in the chips?”, Dr Susanne Lace, 2004.5
- NSRI “security radar”, NSRI 제5권 제14호, 2005.4.4
- NSRI “security radar”, NSRI 제5권 제 18호, 2005.5.2

Japanese Ministry of Public Management, Home Affairs, Posts and Telecommunications & Ministry of Economy, Trade and Industry, "Japanese RFID Privacy Guideline", 2004.1.8.

[논문]

강전일, 박주성, 양대현, “RFID 시스템에서의 프라이버시 보호기술”, 정보보호학회지 제14권 제6호, 2004.12

강홍렬(정보통신정책연구원) 외, “유비쿼터스 사회의 역기능에 관한 법제도적 기초 연구”, 한국전산원 최종연구개발결과보고서, 2004.12

권현영, “전자정부시대 개인정보보호법제의 쟁점”, 정보화정책 제11권 제3호, 2004.9.22

김광조, “RFID/USN 정보보호기술”, TTA저널, 제95호

김동성, 박종서, “RFID/USN 보안 연구대상 및 향후추세”, 정보보호학회지 제15권 제1호, 2005.2

김영선, “IT 기술발전과 개인정보보호의 중요성”, 한국정보통신산업협회

김윤정, 이응용, 김인호, “유비쿼터스 환경의 보안위협과 대응방안”, 정보보호뉴스, 2004

김일환, “개인정보보호법의 개정필요성과 내용에 관한 연구”, 공법연구 제26집 제2호, 한국공법학회(1998).

김성철 외 3명, “RFID 확산에 따른 정보보호 문제와 기업의 대응전략”, 정보통신정책연구, 제12권 제1호, 2005.3

김옥주(서울대조교수), “개인건강정보 보호와 생명의학연구”

김철완, 이민영, “인터넷 개인정보보호에 관한 법제도 연구”, 「정책연구」 제00-10호, 2000

남택용, 장중수, 손승원, “유비쿼터스 환경에서의 개인정보 보호 기술”, 전자통신동향분석 제20권 제1호, 2005.2

박주상, “RFID 기술 및 산업동향”, 한국전자통신연구원 정보통신9호, 2003.5

서동일, 김광식, 장중수, 손승원, “IT839 전략 추진을 위한 정보보호 기술개발 방향”, 전자통신동향분석 제20권 제1호, 2005.2

신일순, “유비쿼터스 IT와 유통산업 : 자산소유권 모형을 이용한 월마트 RFID 도입 사례 연구”, 정보통신정책연구 제 12권 제3호, 2005.9

엄태석, “개인정보보호에 관한 입법론적 고찰” 경희대학교 석사학위논문, 2002

오길영, “개인정보보호를 위한 RFID 규제에 관한 연구”, 정보화정책, 2005. 제12권

이경현, 조현호, 박영호, “네트워크를 통한 시스템침입에 대한 고찰Ⅱ” 한국멀티미디어 학회 2000년도 추계 학술발표논문집, 제3권 제2호, pp. 525-529, 2000.

이규정, “개인정보보호의 규제메커니즘”, 한국전산원 정보화이슈분석 04-06, 2004.6.30

이동훈, “RFID Authentication”, 고려대 CIST,유비쿼터스연구회 ppt자료, 2004.3

이민영, “개인정보보호법제의 개편논의와 개선방안”, 정보통신정책 제16권 1호, 2004.1.16

이민영, “주민등록번호 남용억제에 관한 법제적 고찰”, 정보통신정책 제16권 1호, 2004.5.1

이민영, “차세대 전자정부의 개인정보보호 정책방향”, 정보통신정책 제18권3호, 2006.2.16

이성옥, “유비쿼터스 사회 대비 개인정보 보호 강화”, 국정브리핑, 2005. 12. 29

이은곤, “RFID 확산 추진현황 및 전망”, 정보통신정책 제16권 6호, 2004.4.1

임영덕, “유비쿼터스 컴퓨팅에서의 개인정보보호”, 성공회대학교 대학원 석사학위 청구논문, 2005.6

장명희, 노미진, "국내외 물류부분의 RFID 도입에 따른 SWOT 분석과 사례연구", 2005.12

정상호, “개인정보보호기술과 정보보호산업 동향”, 한국정보통신산업협회

정철현, 변대용, “트래픽 분석을 통한 서비스 거부공격 추적”, <<http://www.certcc.or.kr/paper/tr2003/030115-DoS.pdf>>, 2003.1.

조규백, “유비쿼터스 환경에서의 정보보호 기술동향”, 2005 Active Innovation Leader, 2005

조희석, “RFID와 개인정보보호”, IT Solutions Infosec(주), 2005.12

최성규, “RFID 산업동향 및 전망”, TTA저널 제95호, 2004.10

최정열, “인터넷과 개인정보의 보호”

황종성, “IT 발전과 개인정보보호 관련 법적 현안 분석”, 한국전산원, 2004년 12월

홍도원(D.W. Hong), 장구영(K.Y. Chang), 박태준(T.J. Park), 정교일(K.I. Chung), "Trend of Cryptography for Ubiquitous Environment", 전자통신동향분석 제20권 제1호 2005년 2월

홍순화, “로드 분산 방법을 이용한 네트워크 트래픽 모니터링 및 분석”, <<http://dpnm.postech.ac.kr/thesis/01/soonhwa/powerpoint.pdf>>, 분산처리 및 네트워크 관리 연구실, 2001.12.17

홍진기, “정보보호 컨설팅 서비스가 다양해지고 있다”, IT Solutions Infosec(주),

2005.7

A. Juels, R.L. Rivest, M. Szydlo, "The Blocker Tag: Selective Blocking of RFID Tags for Consumer Privacy." Conference on Computer and Communications Security Proceedings of the 10th ACM conference on Computer and communication security, October 2003, 103–111.

A. Juels, R. Pappu, "Squealing Euros: Privacy Protection in RFID-Enabled Banknotes." In R. Wright, ed., Financial Cryptography '03. Pringer-Verlag. 2003

Ari Juels, "RFID Security and Privacy: A Research Survey", RSA Laboratories, 2005.9. 28.

Claire Swedberg, "New Mexico Kills RFID Privacy Bill",
<<http://www.rfidjournal.com/article/articleprint/1449/-1/1/>>, 2005.3

Dan Bailey, "RFID Tags and Privacy", RSA Laboratories, 2004.08.26

David Banistar & Simon Davis, "Privacy And Human Rights: An International Survey Of Privacy Laws and Practice", <<http://www.gilc.org/privacy/survey/intro.html>>, 2006

David Molnar, David Wagner, "Privacy and Security in Library RFID",
<<http://www.cs.berkeley.edu/~dmolnar/library.pdf>>

Dibya Sarkar, "California bill would restrict RFID use",
<<http://www.fcw.com/article89391-06-27-05-print>>, 2005.6.27

Dirk Henrici and Paul Müller, "Hash-based Enhancement of Location Privacy for Radio-Frequency Identification Devices using Varying Identifiers",
University of Kaiserslautern, Germany

Dr. Lutz Heuser, Dr. Zoltán Nochta, "Privacy Enhanced Active RFID Tag", SAP Research, 2005

Dr. Sarah Spiekermann, "E-privacy Research at the Institute of Information System at Humboldt University Berlin", Humboldt University Berlin

Frederic Debussere, "The EU E-Privacy Directive : A Monstrous Attempt to Starve the Cookie Monster?", International Journal of Law and Information Technology vol. 13 No.1, 2005

Gildas Avoine(EPFL, Lausanne, Switzerland), "Security and Privacy Issues in RFID Systems", Seminar G2I/Eurise, Saint-Etienne, France, January 26 2006

Grant Gross, "RFID and privacy: Debate heating up in Washington",
 <<http://www.thestandard.com/article.php?story=20040601171749721>>, 2004. 6. 1

Heese Marcel, "Privacy Protection against Ubiquitous RFID", zur Erlangung des
 Grades eines Diplom-Ökonomen der Wirtschaftswissenschaftlichen Fakultät der
 Universität Hannover, 2004.10

Jan E. Hennig, Peter B. Ladkin, Bernd Sieker, "Privacy Enhancing Technology
 Concepts for RFID Technology Scrutinised", RVS Group, 2004.10.28

Jan E. Hennig, "Preserving Privacy in RFID Deployment", RVS, Faculty of
 Technology, University of Bielefeld, 2004.03.24

Jan Möller, "독일 개인정보 보호제도의 경험과 사례", 슬레스비히 홀슈타인 주 개
 인정보보호 독립센터, 2004.11.1

Jerry Brito, "WHY RFID PRIVACY CONCERNS ARE EXAGGERATED",
 <http://www.lawtechjournal.com/articles/2004/05_041220_brito.pdf>

JOHN M. EDEN, "WHEN BIG BROTHER PRIVATIZES: COMMERCIAL
 SURVEILLANCE", THE PRIVACY ACT OF 1974, AND THE FUTURE OF RFID

Juels, R.L. Rivest, M. Szydlo, "The Blocker Tag: Selective Blocking of RFID
 Tags for Consumer Privacy." Conference on Computer and Communications
 Security Proceedings of the 10th ACM conference on Computer and
 communication security, October 2003, 103–111.

Kim Hargraves, Steven Shafer, "Radio Frequency Identification (RFID) Privacy
 ; The Microsoft Perspective The Microsoft Perspective", Microsoft, 2004.06.21

Marcel Heese, Günter Wohlers und Michael H. Breitner, "Privacy Protection
 against RFID Spying", IWI Discussion Paper Series # 11, 2004.07.05

Melanie R. Rieback, Bruno Crispo, Andrew S. Tanenbaum, "Uniting Legislation
 with RFID Privacy-Enhancing Technologies", Dept. of Computer Science Vrije
 Universiteit Amsterdam, The Netherlands

Nathan Good 외, "Radio Frequency Id and Privacy with Information Goods",
 <<http://www.cs.berkeley.edu/~daw/papers/rfid-wpes04.pdf>>

Rakesh Kumar, "Interaction of RFID Technology And Public Policy", RFID
 Privacy Workshop @ MIT, Massachusetts.

Ronald E. Quirk, Jr. "RFID: Customer Contracts, Privacy, and the Law",
 <[http://www.venable.com/publications.cfm?action=view&publication_id=1352&pu
 blication_type_id=4](http://www.venable.com/publications.cfm?action=view&publication_id=1352&publication_type_id=4)>, 2005.10.4

Sarah Spiekermann, Oliver Berthold, "MAINTAINING PRIVACY IN RFID ENABLED ENVIRONMENTS", Humboldt University Berlin

S.A.Weis, S.E.Sarma, R.L. Rivest, D.W. Engels, "Security and Privacy Aspects of Low-Cost Radio Frequency Identification Systems" accepted for publication to the First International Conference on Security in Pervasive Computing (SPC 2003), March 12-14, 2003.

Shin'ichi Konomi, "Personal Privacy Assistants for RFID Users", University of Colorado

Stephen August Weis, "Security and Privacy in Radio-Frequency Identification Devices", Massachusetts Institute of Technology, 2003.05.09

Stephen A. Weis, Sanjay E. Sarma, Ronald L. Rivest and Daniel W. Engels, "Security and Privacy Aspects of Low-Cost Radio Frequency Identification Systems", Laboratory for Computer Science, Auto-ID Center

Thomas Hjorth, "Supporting Privacy in RFID System", IMM, DTU, Lyngby, Denmark M.Sc. project, no. 04/87, December 14, 2004

Xiaolan Zhang and Brian King, "Integrity Improvements to an RFID Privacy", Indiana University Purdue University

[기사]

"일본, IT정책이 표류한다.", 전자신문, 2004,4,8

AIM Global, "AIM releases statement on RFID privacy issues",
<<http://www.foodproductiondaily.com/news/ng.asp?id=59357-aim-releases-statement>>, 2005.4.13

Alorie Gilbert, "Privacy questions arise as RFID hits stores.", CNET News, 2004. 10. 1.

Ann Cavoukian, "How privacy could affect the future Roll-out of RFIDs: Take Note", <www.ipc.on.ca>, 2004.9

IDTechEx, "European Union strongly progresses better tracking",
<<http://www.idtechex.com/products/en/articles/00000221.asp>>, 2005.8.11

Illuminati News, "CASPIAN Has Uncovered Evidence of Industry Plans to Deploy RFID Tracking Devices in Consumer Clothing Items", CASPIAN, 2004.10.3.

EE Times, "RFID policy seeks identity", Junko Yoshida, 2005.10.10.

InformationWeek, "Europeans Worry RFID Threatens Privacy", Laurie Sullivan, 2005.09

IT Week, "RFID tags need privacy policies", James Murray, 2005

Laurie Sullivan, "The European Union Works Out RFID Privacy Legislation",
<<http://www.informationweek.com/showArticle.jhtml>>, 2005.6.2

Micheal Kanellos, "빅브라더 시대, RFID(필수 또는 선택)", zdnet korea, 2005.8.16

OUT-LAW News, "Electronic Product Codes and RFID: privacy guidance",
<<http://www.out-law.com/page-5575>>, 2005. 4. 19.

rfidinternational, "OECD Examines RFID Privacy Challenges",
<http://www.rfidinternational.com/news.php?action=full_news&NewsID=98>,
2005.10.6

Shannon L. Kellogg(Director, Government and Industry Affairs, RSA Security, Inc.),<http://europa.eu.int/comm/justice_home/fsj/privacy/docs/rfid/rsa-security-usa_en.pdf>, 2005.3.31

Wikipedia, <http://en.wikipedia.org/wiki/Faraday_cage>

WIRED(통신관련 뉴스업체), "미, 리얼ID법 통과 논란 확산", 2005년 5월 11일

WIRED, "School RFID plan get F",

<<http://www.wired.com/news/privacy/0,1848,66554,00.html>>, 2006년

[도서]

문인주, 이정석 지음, *IC태그 활용가이드*, 북두출판사, 2004년

유승화 지음, *유비쿼터스 사회의 RFID*, 전자신문사, 2003년

일경 BP RFID 기술편집부, *유비쿼터스 RFID*, 성안당

Solove Rotenberg, *Information Privacy Law*, Aspen Publishers, New York, 2003